



DISEÑO E IMPLEMENTACIÓN DEL SISTEMA DE GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN (SGSI) BAJO LA NORMA ISO 27001:2022 EN INSPECCIÓN CERTIFICADA SL.



18 DE MAYO DEL 2026

AGUILAR ESPINOZA JUAN DIEGO - 17387
JASSO DÁVILA PEDRO DAMIAN - 176658
MORENO SOLIS GISELA GERALDINE – 176522
PALOMO CERDA JOSE ARMANDO – 175932
ZARATE DOMINGUEZ DAVID - 175842
ZORRILLA RIVERA EDUARDO – 175877

ÍNDICE

1. DESCRIPCIÓN DE LA INSTITUCIÓN.....	4
1.1 Datos Generales	4
1.2 Breve Historia de la Empresa	4
1.3 Misión, Visión y Valores Corporativos	5
1.3.1 Misión	5
1.3.2 Visión	5
1.3.3 Valores Corporativos	5
1.4 Descripción del Área donde se realiza el Proyecto.....	5
1.5 Organigrama	8
2. PLANTEAMIENTO DEL PROYECTO	9
2.1 Título del Proyecto	9
2.2 Definición del Problema	9
2.3 Justificación	9
2.4 Objetivos.....	10
2.4.1 Objetivo General	10
2.4.2 Objetivos Específicos.....	10
3. DEFINICIÓN DEL ALCANCE (SGSI – ISO/IEC 27001).....	12
3.1 Límites del Lugar Físico e Infraestructura Tecnológica	12
3.2 Límites de los Procesos, Servicios y Flujo de Información.....	12
3.3 Grupos de Personal Incluidos (Usuarios de la Información)	14
3.4 Exclusiones, Supuestos, Restricciones y Declaración de Aplicabilidad (SoA)	14
4. CRONOGRAMA DE ACTIVIDADES	16
4.1 Distribución de Etapas y Horas	16
5. REFERENCIAS NORMATIVAS	17
5.1 Norma Base del SGSI.....	17
5.2 Normas de Controles y Buenas Prácticas	17
5.3 Norma de Gestión de Riesgos de Seguridad de la Información	18
5.4 Normas Complementarias de la Familia ISO/IEC 27000.....	19
5.5 Tabla Resumen de Referencias Normativas Aplicadas	21
6. TÉRMINOS Y CONDICIONES.....	23
6.1 Términos y Definiciones	23
6.1.1 Activo de Información	23
6.1.2 Amenaza	23
6.1.3 Vulnerabilidad.....	23
6.1.4 Riesgo de Seguridad de la Información	24
6.1.5 Control de Seguridad.....	24
6.1.6 Confidencialidad	24
6.1.7 Integridad	24
6.1.8 Disponibilidad	25

6.1.9 Incidente de Seguridad de la Información.....	25
6.1.10 Auditoría del SGSI.....	25
6.1.11 Tratamiento del Riesgo	26
6.1.12 Propietario del Activo.....	26
6.1.13 Declaración de Aplicabilidad (SoA).....	26
6.2 Condiciones de la Intervención	26
6.2.1 Límites de la Intervención.....	27
6.2.2 Confidencialidad del Proyecto	27
6.2.3 Manejo de Evidencias	28
6.2.4 Supuestos de la Intervención	28
6.2.5 Exclusiones de la Intervención	28
6.2.6 Responsabilidades durante la Intervención	29
7. CONTEXTO DE LA ORGANIZACIÓN — GESTIÓN DE ACTIVOS DE INFORMACIÓN.....	31
7.1 Criterios de Clasificación y Codificación.....	31
7.2 Activos Internos.....	31
7.3 Activos Externos	51
7.4 Tabla Resumen de Activos — Clasificación CIA y Trazabilidad	72
8. LIDERAZGO	74
8.1 Política General de Seguridad de la Información.....	74
8.1.1 Declaración de la Dirección General	74
8.1.2 Objetivo de la Política.....	74
8.1.3 Alcance de la Política	74
8.1.4 Compromiso de la Dirección General	75
8.2 Políticas Funcionales de Seguridad de la Información	75
8.3 Matriz RACI — Políticas del SGSI.....	87
8.3.1 Definición de Roles RACI	87
8.3.2 Tabla RACI — Políticas de Seguridad ISL.....	88
8.3.3 Lectura de la Matriz RACI por Rol	89
9. PLANIFICACIÓN — EVALUACIÓN Y TRATAMIENTO DE RIESGOS	90
9.1 Metodología de Evaluación de Riesgos	90
9.1.1 Marco Metodológico	90
9.1.2 Escala de Probabilidad.....	90
9.1.3 Escala de Impacto.....	90
9.1.4 Clasificación del Nivel de Riesgo.....	91
9.2 Matriz de Evaluación y Tratamiento de Riesgos.....	91
9.3 Tabla Resumen de la Matriz de Riesgos.....	120
9.4 Priorización de Riesgos.....	122
9.4.1 Justificación del Orden de Atención.....	122
9.4.2 Mapa de Calor de Riesgos ISL.....	123
10. MINUTA DE REUNIÓN: PRESENTACIÓN DEL SISTEMA DE GESTIÓN DE CALIDAD	124

10.1 Participantes.....	124
10.2 Objetivo de la Sesión	124
10.3 Puntos Tratados	124
10.3.1 Diagnóstico de la Situación Actual	124
10.3.2 Alcance del Sistema y Exclusiones	125
10.3.3 Gestión de Activos y Seguridad.....	125
10.4 Acuerdos y Compromisos	125
10.5 Cierre	125
11. OPERACIÓN	126
11.1 Política Seleccionada y Justificación Estratégica	126
11.2 Relación con Activos, Riesgos y Controles Definidos.....	126
11.3 Procedimiento Operativo Paso a Paso.....	127
11.6 Responsables, Frecuencia, Criterios Mínimos y Posibles Fallos	130
11.7 Acciones para Tratar los Riesgos (Resumen Actualizado)	131
12. EVALUACIÓN DEL DESEMPEÑO — AUDITORÍA INTERNA DEL SGSI	134
12.1 Programa de Auditoría Interna.....	134
12.1.1 Declaración del Programa	134
12.1.2 Ficha General del Programa de Auditoría.....	134
12.2 Formatos de Auditoría Interna	134
12.2.1 Formato A — Checklist de Verificación de Controles (IC-SGSI-AUD-01)	134
12.2.2 Formato B — Guía de Entrevista al Personal (IC-SGSI-AUD-02)	141
12.2.3 Formato C — Lista de Revisión Documental (IC-SGSI-AUD-03)	143
12.3 Simulación de la Auditoría — Resultados por Área	144
12.3.1 Resumen de Resultados del Checklist CHK	144
12.4 Hallazgos, No Conformidades, Observaciones y Oportunidades de Mejora.....	145
12.4.1 No Conformidades Identificadas.....	145
12.4.2 Observaciones Identificadas.....	148
13.4.3 Oportunidades de Mejora Identificadas	150
14. MEJORA — GESTIÓN DE INCIDENTES Y MEJORA CONTINUA DEL SGSI	150
14.1. Planificación y Preparación para la Gestión de Incidentes (Control Anexo A.5.24)	150
14.2. Detección y Reporte de Eventos de Seguridad	151
14.3. Evaluación y Decisión sobre Eventos de Seguridad (Control Anexo A.5.25)....	151
14.4. Respuesta, Contención y Recopilación de Evidencia (Controles Anexo A.5.26 y A.5.28)	151
14.5. Lecciones Aprendidas e Informe Post-Mortem (Control Anexo A.5.27)	151
14.6. Tratamiento de No Conformidades y Acciones Correctivas (Cláusula 10.1).....	152
14.7. Mantenimiento y Mejora Continua del SGSI (Cláusula 10.2)	152
15. BIBLIOGRAFÍA.....	152
15.1 Documentación Interna.....	152
15.2 Lineamientos Académicos.....	153
15.3 Nota Ejecutiva	153

1. DESCRIPCIÓN DE LA INSTITUCIÓN

1.1 Datos Generales

En este apartado se detallan los elementos de identificación legal y comercial de la entidad donde se desarrolla la residencia profesional.

Concepto	Detalle Informativo
Nombre Oficial	Inspección Certificada SL
Nombre Comercial	Servicios de Inspección de Alta Calidad (ISL)
Giro	Prestación de servicios profesionales, científicos y técnicos.
Ramo	Servicios de inspección, control de calidad y outsourcing técnico para la industria manufacturera y automotriz.
Carácter	Institución de carácter Privado.
Tamaño de la Empresa	Pequeña empresa (Cuenta con una plantilla activa de 23 colaboradores).
Ubicación Sede	San Luis Potosí, SLP, México.
Presencia Digital	inspeccionsl.com / WhatsApp: +52 444 300 6175

1.2 Breve Historia de la Empresa

Inspección Certificada SL (ISL) fue fundada con la visión de cerrar la brecha de calidad en la cadena de suministro industrial de la región del Bajío. Identificando la necesidad de las plantas manufactureras de contar con filtros de inspección externos confiables, la empresa se especializó en la verificación técnica de componentes.

Desde sus inicios, ISL se ha enfocado en facilitar la operatividad de sus clientes, resolviendo contingencias de calidad mediante personal capacitado. A lo largo de su trayectoria, ha pasado de ser un equipo pequeño a una organización de 23 empleados, consolidando alianzas estratégicas con empresas locales y globales que requieren asegurar que sus productos cumplan con especificaciones técnicas rigurosas antes de su ensamblaje o envío final.

1.3 Misión, Visión y Valores Corporativos

1.3.1 Misión

"Proveer servicios de inspección y control de calidad con los más altos estándares de precisión, confiabilidad y ética profesional. Nuestra misión es garantizar que los procesos de nuestros clientes fluyan sin interrupciones por defectos de calidad, aportando valor a través de la excelencia técnica y la entrega oportuna de información crítica para la toma de decisiones."

1.3.2 Visión

"Convertirnos para el año 2030 en el referente principal de servicios de certificación e inspección industrial en el centro del país. Aspiramos a ser reconocidos no solo por nuestra capacidad operativa, sino por la integración de tecnologías de la información que permitan una trazabilidad digital impecable y procesos de mejora continua certificados bajo estándares internacionales."

1.3.3 Valores Corporativos

- **Integridad:** Garantizamos la veracidad absoluta en cada reporte de inspección; nuestros resultados reflejan la realidad técnica sin alteraciones.
- **Precisión:** Entendemos que en la industria la diferencia está en los detalles; por ello, aplicamos rigor técnico en cada medición y verificación.
- **Responsabilidad:** Nos hacemos cargo del cumplimiento de los plazos acordados, entendiendo el impacto que nuestro trabajo tiene en la cadena productiva del cliente.
- **Innovación:** Buscamos constantemente optimizar la gestión de datos mediante herramientas digitales para ofrecer reportes más claros y rápidos.

1.4 Descripción del Área donde se realiza el Proyecto

El proyecto se lleva a cabo dentro del **Departamento de Operaciones**, interactuando directamente con la Gerencia General y el Área de Tecnologías de la Información (TI). Para efectos de la implementación del SGSI, se establece la siguiente jerarquía de intervención:

- **Dirección:** Dirección General — Inspección Certificada SL
- **Área:** Departamento de Operaciones (con interacción directa del Área de TI y el Área Administrativa)
- **Proceso:** Gestión y protección de la información vinculada a la prestación de servicios de inspección industrial y control de calidad
- **Actividad específica:** Captura, transmisión, resguardo y entrega de reportes técnicos de inspección, hallazgos de no conformidad y evidencia fotográfica generados por los inspectores en campo y procesados desde la sede central

Esta área es el núcleo operativo de la empresa, ya que es donde se gestionan las solicitudes de servicio, se asigna al personal de inspección y se generan los reportes técnicos que se entregan al cliente. Al ser un entorno con flujo constante de datos sensibles (entradas de piezas, criterios de aceptación/rechazo, registros de hallazgos y propiedad intelectual del cliente), es el lugar idóneo para la implementación del SGSI.

Justificación del área como zona prioritaria de seguridad: El Departamento de Operaciones concentra el manejo de propiedad intelectual de los clientes (planos CAD, criterios de aceptación, NDAs), genera evidencia técnica con valor contractual (fotografías, resultados de medición y certificados de inspección) y opera con dispositivos móviles en entornos industriales externos sin controles formales de seguridad previos. Una brecha de confidencialidad en este proceso podría derivar en incumplimiento de acuerdos de confidencialidad (NDAs), pérdida de clientes Tier 1 y Tier 2, sanciones contractuales y daño reputacional irreparable. Por ello, la implementación del SGSI bajo ISO/IEC 27001:2022 en esta área garantizará la **confidencialidad, integridad y disponibilidad** de los activos de información más críticos del negocio.

Relación entre procesos de negocio y activos de información:

Proceso de Negocio	Área Responsable	Activos de Información Asociados
Contratación y recepción del servicio	Administración / Dirección	Contratos, NDAs, planos técnicos del cliente, base de datos de clientes (SQL Server)
Planificación de la inspección	Gerencia de Operaciones	Órdenes de servicio, asignación de inspectores, hojas de ruta
Ejecución técnica en campo	Cuerpo de Inspectores	Planos industriales, Tablets Samsung, resultados de medición, evidencia fotográfica
Emisión y entrega de reportes	Operaciones / TI	Certificados PDF con firma RSA-2048, Servidor Dell PowerEdge, canales de transmisión cifrada
Gestión de accesos y seguridad	Área de TI	Active Directory, VPN IPsec, YubiKeys FIDO2, Switch Cisco Catalyst 9200

Facturación y cierre administrativo	Administración	API SAT v4.0, contratos digitales, Microsoft 365
-------------------------------------	----------------	--

1.5 Organigrama

ORGANIGRAMA DE INSPECCIÓN CERTIFICADA SL Estructura Funcional y de Residencia



Ilustración 1 Organigrama de Inspección Certificada S

2. PLANTEAMIENTO DEL PROYECTO

2.1 Título del Proyecto

"Diseño e Implementación del Sistema de Gestión de Seguridad de la Información (SGSI) basado en la norma ISO/IEC 27001:2022 para Inspección Certificada SL"

2.2 Definición del Problema

Actualmente, **Inspección Certificada SL** ha experimentado un crecimiento acelerado en su demanda de servicios y en su plantilla laboral (23 colaboradores). Sin embargo, la organización enfrenta los siguientes retos operativos:

1. **Falta de Estandarización:** Los procesos de inspección y control de calidad se ejecutan con base en la experiencia del personal, pero no cuentan con una metodología documentada y unificada. Esto genera el riesgo de criterios variables al momento de reportar hallazgos a los clientes.
2. **Trazabilidad Limitada:** El flujo de información, desde la solicitud del servicio hasta la entrega del reporte final, carece de un sistema de control de registros que asegure la integridad y disponibilidad de la información histórica de manera eficiente.
3. **Dependencia del Conocimiento Tácito:** Al no existir procedimientos operativos estándar (SOPs) formalizados, la capacitación de nuevo personal es lenta y el conocimiento crítico del negocio reside sólo en individuos específicos y no en la estructura de la empresa.
4. **Ausencia de Indicadores de Medición:** No se cuenta con métricas formales (KPIs) que permitan evaluar la eficacia de los procesos de inspección, lo que dificulta la toma de decisiones basada en datos para la mejora continua.

2.3 Justificación

La implementación de un Sistema de Gestión de Seguridad de la Información (SGSI) basado en la norma internacional ISO/IEC 27001:2022 es fundamental por las siguientes razones:

- **Competitividad:** En el sector industrial manufacturero y automotriz, la confidencialidad de los diseños, patentes y datos de producción es crítica. Contar con un SGSI robusto (o un marco de ciberseguridad estructurado) es un requisito indispensable para garantizar a las grandes empresas (Tier 1 y Tier 2) que su

información sensible está protegida frente a amenazas informáticas al contratar servicios de inspección y outsourcing técnico.

- **Eficiencia Operativa y Resiliencia:** La estandarización de controles tecnológicos, organizativos y de acceso minimizará las vulnerabilidades de la infraestructura. Esto reduce el riesgo de brechas de datos o ataques de ransomware, garantizando la continuidad del negocio y evitando interrupciones operativas en los servicios de inspección.
- **Satisfacción del Cliente:** Garantizar que los reportes técnicos y los datos de cada inspección se manejan bajo los principios fundamentales de confidencialidad, integridad y disponibilidad (Triada CID) aumentará la confianza de los clientes, facilitando la retención y captación de nuevas cuentas en un mercado que exige cada vez más madurez digital.
- **Aporte desde la Ingeniería (ITI):** Este proyecto permite aplicar conocimientos avanzados en seguridad informática, evaluación de vulnerabilidades, auditoría de sistemas (fase de post-explotación) y diseño de controles tecnológicos (como el establecimiento de estrategias de respaldo y "Modos de mitigación"). Esto transforma una infraestructura tradicional en un entorno digital seguro, monitoreado y regido por estándares internacionales.

2.4 Objetivos

2.4.1 Objetivo General

Diseñar, documentar e implementar las bases del Sistema de Gestión de Seguridad de la Información (SGSI) en Inspección Certificada SL, cumpliendo con los requisitos de la norma ISO/IEC 27001:2022, para asegurar la confidencialidad, integridad y disponibilidad de los datos manejados en los servicios de inspección industrial en un periodo de 480 horas de residencia.

2.4.2 Objetivos Específicos

- **Diagnóstico Inicial:** Realizar un análisis de brechas (*Gap Analysis*) para identificar el estado actual de los activos de información y los procesos frente a los controles y requisitos de la norma.
- **Documentación de Procesos y Controles:** Elaborar las Políticas de Seguridad de la Información, la Declaración de Aplicabilidad (SoA), los procedimientos operativos de seguridad y los formatos de registro para el área operativa.
- **Definición de Alcance y Política:** Establecer formalmente los límites del sistema (SGSI) y la declaración de intenciones de la alta dirección respecto a la seguridad de la información.

- **Implementación de KPIs:** Diseñar un tablero de indicadores clave de desempeño para monitorear la eficacia de los controles de seguridad y la correcta gestión de incidentes.
- **Sensibilización del Personal:** Capacitar a los 23 colaboradores en la importancia de la cultura de seguridad de la información, el manejo seguro de datos y el uso de la nueva documentación.

3. DEFINICIÓN DEL ALCANCE (SGSI – ISO/IEC 27001)

El alcance establece los límites y la aplicabilidad del Sistema de Gestión de Seguridad de la Información (SGSI) dentro de la organización, con el objetivo de proteger los activos de información del negocio. Para Inspección Certificada SL, se define de la siguiente manera:

3.1 Límites del Lugar Físico e Infraestructura Tecnológica

El SGSI es aplicable a todas las actividades administrativas, estratégicas, operativas e infraestructura tecnológica que se gestionan desde la sede central:

- **Ubicación:** San Luis Potosí, SLP, México.
- **Áreas e Infraestructura Incluidas:** Oficinas administrativas, área de atención a clientes, área de gestión operativa, infraestructura de red/servidores y el centro de resguardo de información documentada (archivos físicos y digitales de registros técnicos y confidenciales).
- **Nota sobre Operaciones Externas (Trabajo en campo y remoto):** Aunque los servicios de inspección se ejecutan físicamente en las instalaciones de los clientes (plantas industriales), el alcance del sistema cubre la protección de la información capturada en campo. Esto incluye el uso seguro de dispositivos móviles/equipos por parte de los inspectores, el acceso remoto a la red y la transmisión segura de los reportes generados bajo los estándares de Inspección Certificada SL, independientemente de la ubicación física.

3.2 Límites de los Procesos, Servicios y Flujo de Información

Se definen los siguientes procesos críticos donde el SGSI tiene aplicabilidad total:

1. **Entrada de Datos (Ventas y Contratación):**
 - **Información:** Planos técnicos, especificaciones de piezas, estándares de calidad del cliente y acuerdos de confidencialidad (NDA).
 - **Control:** Recepción y almacenamiento seguro de la propiedad intelectual del cliente.
2. **Procesamiento y Planificación:**
 - **Información:** Ordenes de servicio, asignación de inspectores y hojas de ruta.
 - **Control:** Gestión de accesos (quién puede ver qué planos) y protección de la integridad de los criterios de inspección.
3. **Captura de Datos en Campo (Ejecución Técnica):**
 - **Información:** Resultados de mediciones, hallazgos de no conformidad y evidencia fotográfica.

- **Control:** Seguridad en dispositivos móviles, integridad de los datos recolectados en sitios remotos (plantas industriales) y sincronización segura con los servidores centrales.
- 4. **Salida y Entrega (Reporte Final):**
 - **Información:** Certificados de inspección, informes de resultados y bases de datos históricas.
 - **Control:** Firmas digitales para asegurar la no alteración de resultados y canales de transmisión segura (correo cifrado o portales protegidos).

El sistema se centra en la protección de los datos generados y gestionados durante el núcleo del negocio:

- **Servicio Incluido:** "Gestión y protección de la información vinculada a la prestación de servicios de inspección industrial y control de calidad".
- **Ciclo del Proceso:** Comprende el resguardo de la información desde la etapa de Ventas/Contratación (recepción, manejo y protección de planos, requisitos o propiedad intelectual del cliente), la Planificación, la recolección de datos técnicos en sitio, hasta la transmisión, emisión y almacenamiento seguro del Reporte Final.

Clasificación de la Información Incluida

Para efectos de este alcance, se consideran dentro del SGSI las siguientes categorías de activos de información:

Categoría	Ejemplos de Activos	Requisito de Seguridad Primario
Propiedad del Cliente	Planos industriales, diseños CAD, manuales técnicos.	Confidencialidad
Registros Técnicos	Resultados de inspección, fotos de hallazgos.	Integridad

Datos de Negocio	Contratos, facturación, bases de datos de clientes.	Disponibilidad
Credenciales	Contraseñas de sistemas, firmas electrónicas.	Confidencialidad

3.3 Grupos de Personal Incluidos (Usuarios de la Información)

El SGSI aplica a la totalidad de la plantilla (23 colaboradores), quienes deben cumplir con las políticas de seguridad de la información según su nivel de acceso y responsabilidad:

- **Alta Dirección (Director General):** Liderazgo, aprobación de políticas de seguridad, gestión de riesgos y asignación de recursos.
- **Gestión Operativa (Gerente de Operaciones y Supervisores):** Aseguramiento del cumplimiento de los controles de seguridad en los procesos operativos.
- **Personal Técnico (Cuerpo de Inspectores de Calidad):** Manejo confidencial de la información del cliente, resguardo de datos en campo y uso seguro de los activos proporcionados por la empresa.
- **Soporte (Administrativo y TI):** Gestión de accesos, respaldos de información, mantenimiento de la infraestructura de red, ciberseguridad y control de la documentación digital.

3.4 Exclusiones, Supuestos, Restricciones y Declaración de Aplicabilidad (SoA)

Exclusiones

De acuerdo con la norma **ISO/IEC 27001:2022**, el alcance del SGSI excluye los siguientes controles del **Anexo A**, con su respectiva justificación:

**Control
Excluido
(Anexo A)**

Justificación de Exclusión

**Controles 8.25 a
8.31 —
Desarrollo
seguro de
software**

Inspección Certificada SL no realiza actividades de desarrollo de software como parte de su giro principal. La empresa se limita a verificar e inspeccionar piezas y materiales con base en criterios y especificaciones proporcionados por el cliente. El único desarrollo interno existente es un script auxiliar (App Inspección SL) cuyo mantenimiento es mínimo y no representa un ciclo de desarrollo formal.

**Control 5.30 —
Preparación
de las TIC
para la
continuidad
del negocio**

En esta etapa inicial del SGSI (periodo de residencia de 480 horas), la implementación de un plan de continuidad de TIC completo queda fuera del alcance temporal. Se documenta como actividad a incluir en una fase posterior de madurez del sistema.

Supuestos

Para efectos del presente SGSI, se establecen los siguientes supuestos:

- La Dirección General mantendrá su compromiso activo y proporcionará los recursos humanos, tecnológicos y económicos necesarios durante las 480 horas del proyecto.
- Los 23 colaboradores estarán disponibles para participar en las sesiones de capacitación y concientización programadas.
- La infraestructura tecnológica existente (Servidor Dell, Switch Cisco, VPN IPsec) se encuentra operativa al inicio de la implementación.
- Los proveedores externos críticos (Microsoft 365, AWS EC2, Telmex) mantendrán sus niveles de servicio contratados durante el periodo de implementación.

Restricciones

Las siguientes restricciones delimitan el alcance y alcanzabilidad del proyecto:

- El periodo de implementación está limitado estrictamente a la duración de la residencia profesional (**480 horas**), por lo que el SGSI resultante corresponde a una **fase de diseño e implementación base**, no a un sistema completamente maduro listo para certificación externa.
- El presupuesto para adquisición de herramientas adicionales de seguridad está sujeto a aprobación y disponibilidad financiera de la Dirección General.
- Los servicios de inspección en campo se ejecutan físicamente en instalaciones de terceros (plantas industriales de los clientes), lo que implica que ciertos controles de seguridad física dependen parcialmente de las políticas del cliente y no son totalmente controlables por ISL.

- La certificación formal ante un organismo externo acreditado **no está contemplada** dentro del alcance de este proyecto de residencia; dicho proceso queda como objetivo estratégico para el año 2027.

4. CRONOGRAMA DE ACTIVIDADES

El proyecto se desarrollará en un periodo total de **480 horas**, distribuidas estratégicamente para cubrir desde el diagnóstico hasta la preparación para la certificación externa.

4.1 Distribución de Etapas y Horas

#	Etapas / Actividad	Descripción Técnica	Horas
1	Diagnóstico y Gap Analysis	Evaluación del estado actual de la seguridad de la información vs. requisitos de la norma ISO/IEC 27001:2022.	40
2	Capacitación y Concientización	Formación de los 23 colaboradores en cultura de ciberseguridad, buenas prácticas y normatividad del SGSI.	40
3	Inventario de Activos y Gestión de Riesgos	Identificación de activos de información y ejecución de la evaluación/tratamiento de riesgos de seguridad.	80
4	Documentación del SGSI y SOA	Redacción de Políticas de Seguridad, procedimientos operativos y la Declaración de Aplicabilidad (SOA).	120
5	Implementación de Controles de Seguridad	Despliegue de controles técnicos y organizativos sobre la infraestructura (Servidor Dell, Cisco, VPN, M365, AWS).	100
6	Auditoría Interna y Ajustes	Simulación de auditoría interna del SGSI para detectar vulnerabilidades, brechas y corregir no conformidades.	60
7	Cierre y Memoria Técnica	Elaboración del reporte final de residencia para la universidad, documentando el diseño e implementación del SGSI.	40
			Total de horas 480

5. REFERENCIAS NORMATIVAS

El presente Sistema de Gestión de Seguridad de la Información (SGSI) se fundamenta en la familia de normas internacionales **ISO/IEC 27000**, desarrolladas por la Organización Internacional de Normalización (ISO) y la Comisión Electrotécnica Internacional (IEC). Cada norma cumple un rol específico dentro del diseño e implementación del sistema en **Inspección Certificada SL**, considerando su giro industrial, su infraestructura tecnológica y los riesgos asociados a sus operaciones.

5.1 Norma Base del SGSI

ISO/IEC 27001:2022 — Sistemas de Gestión de Seguridad de la Información: Requisitos

Referencia formal:

International Organization for Standardization. (2022). *ISO/IEC 27001:2022: Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. ISO.

Descripción: Es el estándar internacional certificable que establece los **requisitos obligatorios** para establecer, implementar, mantener y mejorar continuamente un SGSI. Se estructura bajo el ciclo PHVA (Planear, Hacer, Verificar, Actuar) y el marco de alto nivel (HLS) común a todas las normas de sistemas de gestión ISO.

Aplicación en Inspección Certificada SL: Constituye el marco rector de todo este proyecto. Sus cláusulas 4 a 10 definen los requisitos que ISL debe cumplir para proteger la confidencialidad, integridad y disponibilidad de la información manejada en sus servicios de inspección industrial. Específicamente, sustenta la definición del alcance (Cláusula 4.3), la evaluación de riesgos (Cláusula 6.1), la gestión de activos y la política de seguridad que rigen la operación de los 23 colaboradores.

5.2 Normas de Controles y Buenas Prácticas

ISO/IEC 27002:2022 — Controles de Seguridad de la Información

Referencia formal:

International Organization for Standardization. (2022). *ISO/IEC 27002:2022: Information security, cybersecurity and privacy protection — Information security controls*. ISO.

Descripción: Norma complementaria a ISO/IEC 27001 que proporciona una **guía de referencia y buenas prácticas** para seleccionar, implementar y gestionar los controles de

seguridad listados en el Anexo A de la norma base. Organiza los controles en cuatro categorías: organizacionales, de personas, físicos y tecnológicos.

Aplicación en Inspección Certificada SL: Guía la selección e implementación de los controles de seguridad aplicables al contexto de ISL. Los controles más relevantes para la organización son:

<i>Control ISO/IEC 27002:2022</i>	<i>Aplicación directa en ISL</i>
5.15 — Control de acceso	Gestión de privilegios en Active Directory y VPN para inspectores y personal administrativo
6.8 — Reporte de eventos de seguridad	Procedimiento para que los inspectores reporten anomalías detectadas en campo
7.10 — Medios de almacenamiento	Política de uso de Tablets Samsung y discos externos WD en entornos industriales
8.5 — Autenticación segura	Implementación de MFA con YubiKey 5C para el personal de TI
8.7 — Protección contra malware	Controles antimalware en laptops HP EliteBook y servidor Dell PowerEdge
8.8 — Gestión de vulnerabilidades técnicas	Ventana semanal de parcheo de servidores y monitoreo de CVEs activos
8.12 — Prevención de fuga de datos	Cifrado BitLocker en laptops y AES-256 en expedientes digitales del personal

5.3 Norma de Gestión de Riesgos de Seguridad de la Información

ISO/IEC 27005:2022 — Gestión de Riesgos de Seguridad de la Información

Referencia formal:

International Organization for Standardization. (2022). *ISO/IEC 27005:2022: Information security, cybersecurity and privacy protection — Guidance on managing information security risks*. ISO.

Descripción: Norma que proporciona las **directrices para la identificación, análisis, evaluación y tratamiento de riesgos** de seguridad de la información, siendo complementaria a los requisitos de gestión de riesgos establecidos en la Cláusula 6.1 de

ISO/IEC 27001:2022. Define conceptos como activo, amenaza, vulnerabilidad, probabilidad e impacto dentro de un proceso estructurado.

Aplicación en Inspección Certificada SL: Fundamenta metodológicamente la **Matriz de Evaluación de Riesgos** presentada en la Sección 10 de este documento. Su marco de referencia justifica los criterios utilizados para valorar la probabilidad (escala 1-5) e impacto (escala 1-5) de riesgos como el acceso no autorizado a reportes confidenciales vía VPN/AD (nivel EXTREMO: 25) o el robo de tablets en campo (nivel MUY ALTO: 16). Asimismo, orienta la priorización de los planes de tratamiento establecidos en la Sección 12.

5.4 Normas Complementarias de la Familia ISO/IEC 27000

Las siguientes normas son pertinentes al giro, infraestructura y contexto operativo específico de Inspección Certificada SL:

ISO/IEC 27000:2018 — Fundamentos y Vocabulario

Referencia formal:

International Organization for Standardization. (2018). *ISO/IEC 27000:2018: Information technology — Security techniques — Information security management systems — Overview and vocabulary*. ISO.

Descripción: Norma introductoria de la familia que establece los **fundamentos conceptuales y el vocabulario unificado** utilizado en todos los estándares ISO/IEC 27000.

Aplicación en ISL: Proporciona las definiciones formales utilizadas a lo largo de este SGSI, incluyendo términos como activo de información, confidencialidad, integridad, disponibilidad, amenaza, vulnerabilidad y control. Garantiza que el lenguaje técnico empleado en las políticas y procedimientos de ISL sea coherente con los estándares internacionales, facilitando una eventual auditoría de certificación externa.

ISO/IEC 27017:2015 — Controles de Seguridad para Servicios en la Nube

Referencia formal:

International Organization for Standardization. (2015). *ISO/IEC 27017:2015: Information technology — Security techniques — Code of practice for information security controls based on ISO/IEC 27002 for cloud services*. ISO.

Descripción: Norma que extiende los controles de ISO/IEC 27002 para entornos de **computación en la nube**, estableciendo responsabilidades compartidas entre el proveedor del servicio y el cliente.

Aplicación en ISL: ISL opera servicios críticos en infraestructura de nube, incluyendo la instancia AWS EC2 (t3.medium) que aloja el portal de clientes y Microsoft 365 Business Premium para correo, Teams y OneDrive. Esta norma orienta la definición de responsabilidades de seguridad que corresponden a ISL frente a las que son responsabilidad de AWS y Microsoft, así como los controles adicionales necesarios para proteger la información de los clientes almacenada en estos entornos.

ISO/IEC 27018:2019 — Protección de Datos Personales en la Nube

Referencia formal:

International Organization for Standardization. (2019). *ISO/IEC 27018:2019: Information technology — Security techniques — Code of practice for protection of personally identifiable information (PII) in public clouds acting as PII processors*. ISO.

Descripción: Norma que establece controles para la **protección de información de identificación personal (PII)** procesada en servicios de nube pública.

Aplicación en ISL: ISL almacena y procesa datos personales de sus 23 colaboradores (expedientes cifrados con AES-256) y de los contactos de sus clientes industriales a través de Microsoft 365 y su base de datos SQL Server. Esta norma orienta las medidas de protección de privacidad necesarias para el manejo responsable de dichos datos, especialmente relevante ante posibles requerimientos de clientes corporativos Tier 1 que exigen cumplimiento de normativas de privacidad en sus proveedores de servicio.

ISO/IEC 27035:2023 — Gestión de Incidentes de Seguridad de la Información

Referencia formal:

International Organization for Standardization. (2023). *ISO/IEC 27035-1:2023: Information technology — Information security incident management — Part 1: Principles and process*. ISO.

Descripción: Norma que define el proceso estructurado para la **detección, reporte, evaluación, respuesta y aprendizaje** ante incidentes de seguridad de la información.

Aplicación en ISL: Sustenta el procedimiento de respuesta ante incidentes definido en la Sección 12 (Operación) de este SGSI. En el contexto de ISL, los incidentes más probables identificados incluyen el robo de tablets con información técnica del cliente en campo, ataques de phishing al personal administrativo e intentos de acceso no autorizado a los reportes de inspección vía VPN. Esta norma establece el flujo formal de notificación (desde

el inspector o colaborador afectado hasta el Responsable de TI y la Dirección General) y los criterios para clasificar la severidad del incidente.

ISO/IEC 27701:2019 — Gestión de Información de Privacidad (SGIP)

Referencia formal:

International Organization for Standardization. (2019). *ISO/IEC 27701:2019: Security techniques — Extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy information management — Requirements and guidelines*. ISO.

Descripción: Extensión de ISO/IEC 27001 que incorpora un **Sistema de Gestión de Información de Privacidad (SGIP)**, abordando los requisitos relacionados con el procesamiento de datos personales y la privacidad.

Aplicación en ISL: ISL firma acuerdos de confidencialidad (NDAs) con sus clientes industriales, comprometiéndose a proteger la propiedad intelectual de los mismos (planos CAD, diseños, criterios técnicos). Esta norma orienta la implementación de controles de privacidad que refuercen dichos compromisos contractuales, fortaleciendo la confianza de los clientes Tier 1 y Tier 2 que requieren garantías formales sobre el manejo de su información sensible.

5.5 Tabla Resumen de Referencias Normativas Aplicadas

Aplicación en ISL: ISL firma acuerdos de confidencialidad (NDAs) con sus clientes industriales, comprometiéndose a proteger la propiedad intelectual de los mismos (planos CAD, diseños, criterios técnicos). Esta norma orienta la implementación de controles de privacidad que refuercen dichos compromisos contractuales, fortaleciendo la confianza de los clientes Tier 1 y Tier 2 que requieren garantías formales sobre el manejo de su información sensible.

Norma	Versión	Rol dentro del SGSI de ISL
ISO/IEC 27001	2022	Marco rector y requisitos obligatorios del SGSI

ISO/IEC 27002	2022	Guía de selección e implementación de controles de seguridad
ISO/IEC 27005	2022	Metodología de evaluación y tratamiento de riesgos
ISO/IEC 27000	2018	Vocabulario y fundamentos conceptuales del sistema
ISO/IEC 27017	2015	Controles de seguridad para servicios en nube (AWS, Microsoft 365)
ISO/IEC 27018	2019	Protección de datos personales procesados en nube pública
ISO/IEC 27035	2023	Gestión estructurada de incidentes de seguridad
ISO/IEC 27701	2019	Gestión de privacidad y cumplimiento de NDAs con clientes

6. TÉRMINOS Y CONDICIONES

6.1 Términos y Definiciones

Los siguientes términos son los más relevantes para la comprensión e implementación del presente SGSI en **Inspección Certificada SL**. Las definiciones base se extraen de la norma **ISO/IEC 27000:2018** (*Information security management systems — Overview and vocabulary*) y se contextualizan al entorno operativo específico de la organización. No se reproducen las 81 definiciones del estándar; se seleccionan únicamente los términos esenciales para la intervención.

6.1.1 Activo de Información

(ISO/IEC 27000:2018, término 3.3)

Definición: Cualquier elemento que tiene valor para la organización y que, por tanto, requiere protección.

En ISL: Incluye tanto activos tangibles (Servidor Dell PowerEdge T550, Tablets Samsung Galaxy Tab Active4 Pro, discos de respaldo WD) como intangibles (base de datos de clientes en SQL Server, planos técnicos del cliente, certificados de inspección con firma RSA-2048, credenciales de Active Directory y el conocimiento técnico certificado del cuerpo de inspectores). El inventario completo se documenta en la Sección 7 de este SGSI.

6.1.2 Amenaza

(ISO/IEC 27000:2018, término 3.74)

Definición: Causa potencial de un incidente no deseado que puede resultar en daño a un sistema u organización.

En ISL: Las amenazas identificadas en el contexto operativo incluyen ataques de phishing dirigidos al personal administrativo, robo o extravío de tablets de los inspectores en plantas industriales de los clientes, accesos no autorizados a reportes confidenciales a través de la VPN, y la explotación de vulnerabilidades en software de servidores sin actualizar.

6.1.3 Vulnerabilidad

(ISO/IEC 27000:2018, término 3.77)

Definición: Debilidad de un activo o control que puede ser explotada por una o más amenazas.

En ISL: Ejemplos directos incluyen el uso de software de servidor sin parches de seguridad aplicados (CVEs activos), la ausencia previa de autenticación multifactor (MFA) en el acceso remoto vía VPN, y la falta de cifrado en dispositivos móviles utilizados para captura de datos en campo antes de la implementación del SGSI.

6.1.4 Riesgo de Seguridad de la Información

(ISO/IEC 27000:2018, término 3.61)

Definición: Efecto de la incertidumbre sobre los objetivos de seguridad de la información, expresado en función de la probabilidad de que ocurra un evento y la magnitud de sus consecuencias.

En ISL: El riesgo se cuantifica mediante la fórmula **Riesgo = Probabilidad × Impacto** en una escala de 1 a 5 para cada variable, generando valores que se clasifican como Bajo, Medio, Alto, Muy Alto o Extremo. La metodología completa y la matriz de riesgos se desarrollan en la Sección 10 de este documento.

6.1.5 Control de Seguridad

(ISO/IEC 27000:2018, término 3.14)

Definición: Medida que modifica o mantiene el riesgo, incluyendo políticas, procedimientos, directrices, prácticas o estructuras organizacionales de naturaleza administrativa, técnica, de gestión o legal.

En ISL: Los controles implementados incluyen la autenticación multifactor (MFA) con YubiKey 5C para el personal de TI, el cifrado de disco completo con BitLocker en laptops HP EliteBook, la segmentación de red mediante VLANs en el Switch Cisco Catalyst 9200, y el software de gestión MDM con capacidad de borrado remoto en las tablets de campo.

6.1.6 Confidencialidad

(ISO/IEC 27000:2018, término 3.10)

Definición: Propiedad que garantiza que la información no se pone a disposición ni se revela a individuos, entidades o procesos no autorizados.

En ISL: Principio crítico dado que la empresa maneja planos industriales, diseños CAD, criterios de aceptación/rechazo y acuerdos de confidencialidad (NDAs) de sus clientes manufactureros. Una violación de confidencialidad podría derivar en incumplimiento contractual, pérdida de clientes Tier 1 y Tier 2, y acciones legales por parte de los clientes afectados.

6.1.7 Integridad

(ISO/IEC 27000:2018, término 3.36)

Definición: Propiedad de exactitud y completitud de la información y sus métodos de procesamiento, garantizando que no ha sido alterada de forma no autorizada.

En ISL: Principio fundamental para los certificados de inspección y reportes técnicos emitidos a los clientes. Para garantizarla, los documentos finales se generan en formato PDF/A con firma digital RSA-2048, asegurando que los resultados de inspección reflejen fielmente la realidad técnica evaluada y no puedan ser modificados sin detección.

6.1.8 Disponibilidad

(ISO/IEC 27000:2018, término 3.7)

Definición: Propiedad de ser accesible y utilizable bajo demanda por una entidad autorizada.

En ISL: Garantizada mediante el UPS APC Smart-UPS 2200VA que protege el servidor ante fallas eléctricas, los respaldos bajo la regla 3-2-1 (tres copias, dos medios distintos, una fuera de línea), y la instancia AWS EC2 que asegura la disponibilidad del portal de clientes externo independientemente del estado del servidor local.

6.1.9 Incidente de Seguridad de la Información

(ISO/IEC 27000:2018, término 3.31)

Definición: Evento único o serie de eventos de seguridad de la información, inesperados o no deseados, que tienen una probabilidad significativa de comprometer las operaciones del negocio y amenazar la seguridad de la información.

En ISL: Se considera incidente cualquier situación como: acceso no autorizado a reportes de inspección, extravío o robo de una tablet con datos técnicos del cliente, clic de un colaborador en un correo de phishing, caída del servidor central durante una jornada de trabajo activa, o modificación no autorizada de un certificado de inspección emitido.

6.1.10 Auditoría del SGSI

(ISO/IEC 27000:2018, término 3.4)

Definición: Proceso sistemático, independiente y documentado para obtener evidencias y evaluarlas objetivamente, con el fin de determinar en qué medida se cumplen los criterios de auditoría del sistema de gestión.

En ISL: Se contempla la realización de una auditoría interna al finalizar la etapa de implementación base (dentro de las 480 horas de residencia), conforme a lo establecido en

el cronograma de la Sección 4. Su propósito es identificar no conformidades, verificar la eficacia de los controles implementados y generar insumos para el plan de mejora continua.

6.1.11 Tratamiento del Riesgo

(ISO/IEC 27000:2018, término 3.72)

Definición: Proceso para modificar el riesgo, que puede incluir: evitar el riesgo, asumir o aumentar el riesgo para aprovechar una oportunidad, eliminar la fuente del riesgo, cambiar la probabilidad, cambiar las consecuencias, compartir el riesgo con otra parte, o retener el riesgo mediante decisión informada.

En ISL: Para cada riesgo identificado en la Sección 10, se aplica una de las siguientes opciones de tratamiento: **Mitigar** (implementar controles técnicos como MFA o MDM), **Transferir** (contratar seguros o externalizar responsabilidades a proveedores cloud como AWS), **Evitar** (discontinuar actividades que generen riesgo inaceptable) o **Aceptar** (documentar formalmente la decisión de asumir riesgos de nivel Bajo con conocimiento de la dirección).

6.1.12 Propietario del Activo

(ISO/IEC 27000:2018, término 3.53)

Definición: Persona o entidad que tiene la responsabilidad aprobada y autorizada para gestionar un activo.

En ISL: Cada activo crítico tiene un propietario designado responsable de su clasificación, protección y uso adecuado. Por ejemplo, el Responsable de TI es propietario del Servidor Dell PowerEdge y del Switch Cisco; el Gerente de Operaciones es propietario de las órdenes de servicio y los reportes técnicos; la Dirección General es propietaria de los contratos y la Política de Seguridad de la Información (PSI-2026).

6.1.13 Declaración de Aplicabilidad (SoA)

(ISO/IEC 27001:2022, Cláusula 6.1.3)

Definición: Documento que especifica los controles del Anexo A de ISO/IEC 27001 que son aplicables al SGSI de la organización, con su justificación de inclusión o exclusión.

En ISL: La SoA constituye uno de los documentos obligatorios del SGSI y se desarrolla en la Sección 3.4 de este documento. Establece formalmente qué controles del Anexo A aplican a la operación de Inspección Certificada SL y cuáles quedan excluidos con su justificación técnica correspondiente.

6.2 Condiciones de la Intervención

Las siguientes condiciones rigen el desarrollo, implementación y documentación del presente SGSI durante el periodo de residencia profesional en Inspección Certificada SL.

6.2.1 Límites de la Intervención

<i>Dimensión</i>	<i>Límite Establecido</i>
Temporal	La intervención se limita al periodo de residencia profesional de 480 horas , distribuidas conforme al cronograma de la Sección 4
Organizacional	El SGSI aplica a la totalidad de los 23 colaboradores de ISL en su sede de San Luis Potosí, SLP
Geográfico	Sede central en San Luis Potosí, con extensión a operaciones en campo realizadas en instalaciones de clientes, conforme a lo definido en el alcance (Sección 3 del documento original)
Normativo	La implementación se circunscribe a los requisitos de ISO/IEC 27001:2022 y los controles aplicables del Anexo A, sin alcanzar la certificación formal en esta etapa
Tecnológico	Cubre la infraestructura tecnológica existente documentada en la Sección 7 (Gestión de Activos); no incluye la adquisición de infraestructura nueva no contemplada en el presupuesto aprobado

6.2.2 Confidencialidad del Proyecto

Toda la información obtenida durante el desarrollo de la residencia profesional en Inspección Certificada SL está sujeta a las siguientes condiciones de confidencialidad:

- La información técnica, comercial y operativa de los clientes de ISL a la que tenga acceso el residente profesional durante la implementación del SGSI se considera **información confidencial de terceros** y no podrá ser divulgada fuera del contexto académico y profesional de este proyecto.
- Los documentos internos generados (políticas, procedimientos, matrices de riesgo, inventarios de activos) son **propiedad de Inspección Certificada SL** y su uso queda restringido al ámbito de este proyecto y a la evaluación académica correspondiente.
- El residente profesional se compromete a no hacer uso indebido de las credenciales de acceso, sistemas o infraestructura a los que tenga acceso durante la implementación.

- Cualquier hallazgo de vulnerabilidad crítica detectado durante la auditoría interna deberá ser reportado **de forma inmediata y exclusiva** al Responsable de TI y a la Dirección General de ISL, antes de su documentación en el reporte académico.

6.2.3 Manejo de Evidencias

Las evidencias recopiladas durante la implementación del SGSI se gestionarán bajo los siguientes criterios:

- **Recolección:** Las evidencias (fotografías de infraestructura, capturas de pantalla de configuraciones, registros de auditoría, listas de asistencia a capacitaciones) se recopilarán únicamente con autorización expresa del Responsable de TI o la Dirección General.
- **Anonimización:** En la documentación académica entregada a la Universidad Politécnica de San Luis Potosí, los datos sensibles de clientes (nombres, especificaciones técnicas, NDAs) serán anonimizados o sustituidos por datos genéricos representativos.
- **Resguardo:** Las evidencias digitales del proyecto se almacenarán en el repositorio centralizado de ISL bajo el esquema de control de versiones **IC-SGSI-DOC-XX**, con acceso restringido al residente, el Responsable de TI y la Dirección General.
- **Integridad:** No se alterará, modificará ni eliminará ninguna evidencia recopilada durante el proceso de auditoría interna. Cualquier corrección o actualización quedará registrada con control de versiones.

6.2.4 Supuestos de la Intervención

Para efectos del presente SGSI, se establecen los siguientes supuestos sobre los cuales se basa el diseño e implementación del sistema:

- La **Dirección General** mantiene su compromiso activo y proporciona los recursos humanos, tecnológicos y económicos necesarios durante las 480 horas del proyecto.
- Los **23 colaboradores** estarán disponibles para participar en las sesiones de capacitación y concientización en los horarios programados.
- La **infraestructura tecnológica existente** (Servidor Dell PowerEdge T550, Switch Cisco Catalyst 9200, VPN IPsec) se encuentra operativa y funcional al inicio de la implementación.
- Los **proveedores externos críticos** (Microsoft 365, AWS EC2, Telmex Negocio) mantendrán sus niveles de servicio contratados durante el periodo de implementación.
- La **información proporcionada** por el personal de ISL durante entrevistas y sesiones de diagnóstico es veraz y refleja fielmente la operación actual de la empresa.

6.2.5 Exclusiones de la Intervención

Las siguientes actividades quedan **fuera del alcance** de la presente intervención:

- La **certificación formal** ante un organismo de certificación externo acreditado; dicho proceso queda como objetivo estratégico para una fase posterior, proyectada para 2027.
- La **adquisición e implementación de nueva infraestructura tecnológica** no contemplada en el presupuesto aprobado por la Dirección General al inicio del proyecto.
- El **desarrollo o modificación del código fuente** de la App Inspección SL más allá de las recomendaciones de seguridad documentadas.
- Los **controles de seguridad física** que dependen de las instalaciones de los clientes donde operan los inspectores en campo, dado que dichos entornos están fuera de la jurisdicción de ISL.
- La implementación de un **Plan de Continuidad de Negocio (BCP) completo**; el BCP v2.1 existente se revisa y documenta como referencia, pero su actualización integral queda para una fase posterior.

6.2.6 Responsabilidades durante la Intervención

Rol	Responsabilidad dentro del proyecto
Director General	Aprobar políticas, asignar recursos, validar el alcance y firmar la documentación oficial del SGSI
Gerente de Operaciones	Facilitar el acceso a los procesos operativos, coordinar la disponibilidad del personal para capacitaciones y validar los procedimientos documentados
Responsable de TI	Proveer acceso supervisado a la infraestructura tecnológica, validar los controles técnicos implementados y custodiar las evidencias digitales del proyecto
Cuerpo de Inspectores	Participar en las sesiones de capacitación y concientización, y adoptar los procedimientos y políticas de seguridad establecidos

Residente
Profesional

Diseñar, documentar e implementar las bases del SGSI conforme a ISO/IEC 27001:2022, elaborar la memoria técnica del proyecto y presentar los resultados ante la dirección y la universidad

7. CONTEXTO DE LA ORGANIZACIÓN — GESTIÓN DE ACTIVOS DE INFORMACIÓN

7.1 Criterios de Clasificación y Codificación

Para garantizar la trazabilidad de los activos a lo largo del SGSI y su referenciación directa en la Matriz de Riesgos (Sección 10), cada activo recibe un código único bajo el siguiente esquema:

Prefijo	Significado
ACT-INT-XXX	Activo Interno (bajo control directo de ISL)
ACT-EXT-XXX	Activo Externo (dependencia de terceros)

La clasificación CIA (Confidencialidad, Integridad, Disponibilidad) se asigna con los valores **Alto**, **Medio** o **Bajo** según el impacto que tendría el compromiso de esa propiedad específica para la continuidad operativa y contractual de ISL.

7.2 Activos Internos

Activos bajo control directo de Inspección Certificada SL.

ACT-INT-001 — Base de Datos de Clientes

Campo	Detalle
Código	ACT-INT-001
Nombre	Base de Datos de Clientes (SQL Server 2022)
Clasificación	Interno
Información que procesa/almacena/transmite	Registros fiscales, datos de contacto, historial de contratos, acuerdos de confidencialidad (NDAs) y condiciones comerciales de todos los clientes activos de ISL

Justificación de relevancia	Es el activo de información más crítico del negocio; concentra la totalidad de la relación comercial con los clientes. Sin esta base de datos, ISL no puede facturar, coordinar servicios ni cumplir compromisos contractuales
Impacto si se compromete	Exposición masiva de datos fiscales y contractuales, incumplimiento de NDAs firmados con clientes Tier 1 y Tier 2, sanciones legales, pérdida irreversible de confianza comercial y posible cierre de cuentas clave
Propietario del activo	Director General
Ubicación	Servidor Dell PowerEdge T550 — Sede San Luis Potosí
Proceso asociado	Contratación y recepción del servicio / Facturación y cierre administrativo
Responsable operativo	Responsable de TI
Dependencia tecnológica	Servidor Dell PowerEdge T550 (ACT-INT-003), Switch Cisco Catalyst 9200 (ACT-INT-010), UPS APC Smart-UPS 2200VA (ACT-INT-011)
Confidencialidad	Alto
Integridad	Alto
Disponibilidad	Alto

ACT-INT-002 — Certificados de Calidad Digitales

Campo	Detalle
Código	ACT-INT-002
Nombre	Certificados de Calidad Digitales (PDF/A con firma RSA-2048)

Clasificación	Interno
Información que procesa/almacena/transmite	Resultados oficiales de inspección, criterios de aceptación/rechazo aplicados, hallazgos técnicos y firma digital del inspector responsable
Justificación de relevancia	Son el producto entregable principal de ISL; su valor contractual y legal depende de que no puedan ser alterados. Representan la evidencia técnica que el cliente usa para tomar decisiones de producción
Impacto si se compromete	Alteración de resultados de inspección, incumplimiento contractual, pérdida de credibilidad técnica, posibles demandas legales por parte de clientes cuyas decisiones de producción se basen en datos manipulados
Propietario del activo	Gerente de Operaciones
Ubicación	Servidor Dell PowerEdge T550 y Microsoft 365 OneDrive
Proceso asociado	Emisión y entrega del reporte final
Responsable operativo	Gerente de Operaciones
Dependencia tecnológica	Servidor Dell PowerEdge T550 (ACT-INT-003), Microsoft 365 (ACT-EXT-005)
Confidencialidad	Alto
Integridad	Alto
Disponibilidad	Medio

ACT-INT-003 — Servidor Físico Dell PowerEdge T550

Campo

Detalle

Código	ACT-INT-003
Nombre	Servidor Físico Dell PowerEdge T550
Clasificación	Interno
Información que procesa/almacena/transmite	Aloja las máquinas virtuales, la base de datos SQL Server, los repositorios de reportes técnicos y los servicios de red internos de ISL
Justificación de relevancia	Es el núcleo de la infraestructura tecnológica local; su indisponibilidad detiene la operación completa de la empresa incluyendo emisión de reportes, acceso a datos de clientes y comunicaciones internas
Impacto si se compromete	Paro total de operaciones, pérdida de acceso a todos los datos históricos, imposibilidad de emitir reportes a clientes, tiempo de recuperación estimado de 24 a 72 horas con plan de continuidad activo
Propietario del activo	Responsable de TI
Ubicación	Cuarto de servidores — Sede San Luis Potosí
Proceso asociado	Todos los procesos del ciclo operativo de ISL
Responsable operativo	Responsable de TI
Dependencia tecnológica	UPS APC Smart-UPS 2200VA (ACT-INT-011), Switch Cisco Catalyst 9200 (ACT-INT-010), Red CFE 220V (ACT-EXT-018)
Confidencialidad	Alto
Integridad	Alto
Disponibilidad	Alto

ACT-INT-004 — Laptops HP EliteBook 840 G10

Campo	Detalle
Código	ACT-INT-004
Nombre	Laptops HP EliteBook 840 G10 (Windows 11 Pro)
Clasificación	Interno
Información que procesa/almacena/transmite	Documentación administrativa, correos electrónicos corporativos, acceso a sistemas internos vía VPN, elaboración de reportes técnicos y gestión de contratos
Justificación de relevancia	Son las estaciones de trabajo del personal administrativo y de gestión; concentran el acceso a los sistemas críticos del negocio y manejan información confidencial de clientes en el día a día
Impacto si se compromete	Acceso no autorizado a información de clientes, filtración de datos contractuales, vector de entrada para ataques de ransomware o phishing que comprometan toda la red interna
Propietario del activo	Responsable de TI
Ubicación	Oficinas administrativas — Sede San Luis Potosí
Proceso asociado	Contratación, planificación, emisión de reportes y gestión administrativa
Responsable operativo	Responsable de TI
Dependencia tecnológica	Active Directory (ACT-INT-007), VPN IPsec (ACT-EXT-007), Microsoft 365 (ACT-EXT-005), Servidores de Parches Microsoft (ACT-EXT-015)
Confidencialidad	Alto

Integridad

Medio

Disponibilidad

Alto

ACT-INT-005 — Tablets Samsung Galaxy Tab Active4 Pro

Campo	Detalle
Código	ACT-INT-005
Nombre	Tablets Samsung Galaxy Tab Active4 Pro (Android 13)
Clasificación	Interno
Información que procesa/almacena/transmite	Resultados de mediciones en campo, fotografías de hallazgos de no conformidad, planos técnicos del cliente consultados durante la inspección y datos de geolocalización de las visitas
Justificación de relevancia	Son el principal instrumento de captura de datos en campo; operan en entornos industriales externos con alto riesgo físico de robo o extravío, y contienen información confidencial del cliente en tránsito
Impacto si se compromete	Exposición de planos y criterios técnicos del cliente, pérdida de evidencia fotográfica de inspecciones en curso, incumplimiento de NDAs y potencial acceso no autorizado a la red interna si las credenciales almacenadas se ven comprometidas
Propietario del activo	Gerente de Operaciones
Ubicación	En campo — Instalaciones de clientes industriales (plantas manufactureras)
Proceso asociado	Ejecución técnica en campo (captura de datos de inspección)

Responsable operativo	Supervisores de Inspección
Dependencia tecnológica	Red Móvil 5G Telcel/AT&T (ACT-EXT-019), VPN IPsec (ACT-EXT-007), Servidor Dell PowerEdge T550 (ACT-INT-003)
Confidencialidad	Alto
Integridad	Alto
Disponibilidad	Medio

ACT-INT-006 — Código Fuente App Inspección SL

Campo	Detalle
Código	ACT-INT-006
Nombre	Código Fuente de "App Inspección SL" (Python 3.12)
Clasificación	Interno
Información que procesa/almacena/transmite	Lógica de negocio para el llenado automatizado de formularios técnicos, estructuras de datos de inspección y conexiones a los sistemas internos
Justificación de relevancia	Representa el know-how tecnológico desarrollado internamente; su compromiso podría revelar la lógica operativa de ISL o introducir vulnerabilidades en los sistemas de captura de datos
Impacto si se compromete	Ingeniería inversa de los procesos internos, introducción de código malicioso que altere resultados de inspección, pérdida de ventaja competitiva tecnológica
Propietario del activo	Responsable de TI

Ubicación	Repositorio GitHub Plan Pro (ACT-EXT-010) y copia local en Servidor Dell
Proceso asociado	Ejecución técnica en campo / Emisión de reportes
Responsable operativo	Responsable de TI
Dependencia tecnológica	Repositorio GitHub (ACT-EXT-010), Servidor Dell PowerEdge T550 (ACT-INT-003)
Confidencialidad	Alto
Integridad	Alto
Disponibilidad	Medio

ACT-INT-007 — Credenciales de Acceso (Active Directory)

Campo	Detalle
Código	ACT-INT-007
Nombre	Credenciales de Acceso — Active Directory
Clasificación	Interno
Información que procesa/almacena/transmite	Estructura de usuarios, grupos de seguridad, permisos de acceso a recursos de red, políticas de contraseña y registros de autenticación de los 23 colaboradores
Justificación de relevancia	Es la puerta de entrada a todos los sistemas internos de ISL; un compromiso de este activo equivale al compromiso de toda la infraestructura tecnológica de la empresa

Impacto si se compromete	Acceso total no autorizado a todos los sistemas internos, escalada de privilegios, modificación o eliminación de registros críticos, compromiso simultáneo de todos los activos dependientes
Propietario del activo	Responsable de TI
Ubicación	Servidor Dell PowerEdge T550 — Sede San Luis Potosí
Proceso asociado	Gestión de accesos y seguridad (todos los procesos)
Responsable operativo	Responsable de TI
Dependencia tecnológica	Servidor Dell PowerEdge T550 (ACT-INT-003), Switch Cisco Catalyst 9200 (ACT-INT-010)
Confidencialidad	Alto
Integridad	Alto
Disponibilidad	Alto

ACT-INT-008 — Manual de Procedimientos ISO 27001:2022

Campo	Detalle
Código	ACT-INT-008
Nombre	Manual de Procedimientos ISO 27001:2022 (v1.0)
Clasificación	Interno
Información que procesa/almacena/transmite	Políticas de seguridad, procedimientos operativos del SGSI, controles implementados y documentación de auditoría interna

Justificación de relevancia	Es el documento rector del SGSI; su integridad garantiza que todos los colaboradores operen bajo los mismos criterios de seguridad y que el sistema sea auditable
Impacto si se compromete	Pérdida de trazabilidad del SGSI, imposibilidad de demostrar cumplimiento ante clientes o auditores externos, invalidación de los procesos de certificación futura
Propietario del activo	Director General
Ubicación	Repositorio centralizado IC-SGSI-DOC — Servidor Dell y Microsoft 365
Proceso asociado	Gestión del SGSI / Auditoría interna
Responsable operativo	Responsable de TI
Dependencia tecnológica	Microsoft 365 (ACT-EXT-005), Servidor Dell PowerEdge T550 (ACT-INT-003)
Confidencialidad	Medio
Integridad	Alto
Disponibilidad	Alto

ACT-INT-009 — Discos Externos de Respaldo WD My Passport 5TB

Campo	Detalle
Código	ACT-INT-009
Nombre	Discos Externos de Respaldo (WD My Passport 5TB)
Clasificación	Interno

Información que procesa/almacena/transmite	Copias de seguridad de la base de datos de clientes, repositorio de reportes técnicos históricos y configuraciones críticas del servidor
Justificación de relevancia	Son el último recurso de recuperación ante un desastre; su disponibilidad e integridad determinan la capacidad de ISL para restablecer operaciones tras un incidente grave
Impacto si se compromete	Pérdida permanente de información histórica de inspecciones, imposibilidad de recuperar operaciones tras un ataque de ransomware, incumplimiento del plan de continuidad de negocio BCP v2.1
Propietario del activo	Responsable de TI
Ubicación	Caja Fuerte SentrySafe (ACT-INT-017) — Sede San Luis Potosí (almacenamiento offline)
Proceso asociado	Gestión de continuidad y respaldo de información
Responsable operativo	Responsable de TI
Dependencia tecnológica	Caja Fuerte SentrySafe (ACT-INT-017)
Confidencialidad	Alto
Integridad	Alto
Disponibilidad	Alto

ACT-INT-010 — Switch Administrable Cisco Catalyst 9200

Campo	Detalle
Código	ACT-INT-010

Nombre	Switch Administrable Cisco Catalyst 9200
Clasificación	Interno
Información que procesa/almacena/transmite	Tráfico de red interno segmentado mediante VLANs; separa el tráfico administrativo del operativo para reducir la superficie de ataque
Justificación de relevancia	Es el componente central de la arquitectura de red segura de ISL; sin su correcta configuración, la segmentación de red que protege los sistemas críticos deja de funcionar
Impacto si se compromete	Colapso de la segmentación de red, acceso transversal entre VLANs, exposición del servidor y sistemas críticos a dispositivos no autorizados, interrupción total de comunicaciones internas
Propietario del activo	Responsable de TI
Ubicación	Cuarto de servidores — Sede San Luis Potosí
Proceso asociado	Gestión de accesos y seguridad de red
Responsable operativo	Responsable de TI
Dependencia tecnológica	Red CFE 220V (ACT-EXT-018), UPS APC Smart-UPS 2200VA (ACT-INT-011)
Confidencialidad	Medio
Integridad	Alto
Disponibilidad	Alto

Campo

Detalle

Código	ACT-INT-011
Nombre	UPS APC Smart-UPS 2200VA
Clasificación	Interno
Información que procesa/almacena/transmite	No almacena información directamente; protege la integridad y disponibilidad de todos los activos tecnológicos ante interrupciones del suministro eléctrico
Justificación de relevancia	San Luis Potosí presenta interrupciones eléctricas que podrían dañar el servidor o corromper datos durante operaciones de escritura activa; el UPS es el único control contra este riesgo físico
Impacto si se compromete	Apagado abrupto del servidor con posible corrupción de la base de datos, pérdida de transacciones en curso y daño físico al hardware de almacenamiento
Propietario del activo	Responsable de TI
Ubicación	Cuarto de servidores — Sede San Luis Potosí
Proceso asociado	Continuidad operativa de todos los procesos
Responsable operativo	Responsable de TI
Dependencia tecnológica	Red CFE 220V (ACT-EXT-018)
Confidencialidad	Bajo
Integridad	Alto
Disponibilidad	Alto

ACT-INT-012 — Cámaras IP Hikvision 4K DS-2CD

Campo	Detalle
Código	ACT-INT-012
Nombre	Cámaras IP Hikvision 4K (Model DS-2CD)
Clasificación	Interno
Información que procesa/almacena/transmite	Grabaciones de video del perímetro físico de la sede, incluyendo el cuarto de servidores y áreas de acceso restringido
Justificación de relevancia	Proveen evidencia ante incidentes de seguridad física como accesos no autorizados al cuarto de servidores o manipulación de equipos fuera de horario laboral
Impacto si se compromete	Pérdida de evidencia ante incidentes físicos, acceso no autorizado al cuarto de servidores sin registro, posible uso del feed de cámaras como vector de espionaje industrial si no están debidamente aseguradas
Propietario del activo	Responsable de TI
Ubicación	Perímetro físico y cuarto de servidores — Sede San Luis Potosí
Proceso asociado	Seguridad física de la infraestructura
Responsable operativo	Responsable de TI
Dependencia tecnológica	Switch Cisco Catalyst 9200 (ACT-INT-010), Servidor Dell PowerEdge T550 (ACT-INT-003)
Confidencialidad	Alto
Integridad	Medio

Disponibilidad

Medio

ACT-INT-013 — Lector Biométrico ZKTeco SpeedFace

Campo	Detalle
Código	ACT-INT-013
Nombre	Lector Biométrico ZKTeco SpeedFace
Clasificación	Interno
Información que procesa/almacena/transmite	Datos biométricos (reconocimiento facial y huella dactilar) de los colaboradores autorizados para acceder al cuarto de servidores
Justificación de relevancia	Es el control de acceso físico al activo más crítico de la empresa (cuarto de servidores); su compromiso eliminaría la barrera de acceso físico al servidor y toda la infraestructura
Impacto si se compromete	Acceso físico no autorizado al cuarto de servidores, posibilidad de manipulación directa del hardware, robo de discos de respaldo o instalación de dispositivos maliciosos
Propietario del activo	Responsable de TI
Ubicación	Entrada del cuarto de servidores — Sede San Luis Potosí
Proceso asociado	Control de acceso físico a infraestructura crítica
Responsable operativo	Responsable de TI
Dependencia tecnológica	Red eléctrica CFE (ACT-EXT-018), Switch Cisco Catalyst 9200 (ACT-INT-010)

Confidencialidad **Alto**

Integridad **Alto**

Disponibilidad **Alto**

ACT-INT-014 — Expedientes de Personal Cifrados

Campo	Detalle
Código	ACT-INT-014
Nombre	Expedientes de Personal (Cifrado AES-256)
Clasificación	Interno
Información que procesa/almacena/transmite	Datos personales de los 23 colaboradores: contratos laborales, certificaciones técnicas, datos fiscales, información médica y evaluaciones de desempeño
Justificación de relevancia	Contienen información personal sensible cuya exposición violaría la privacidad de los empleados y podría derivar en sanciones bajo la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP)
Impacto si se compromete	Violación de privacidad de empleados, sanciones regulatorias por incumplimiento de la LFPDPPP, demandas laborales y daño al clima organizacional
Propietario del activo	Director General
Ubicación	Servidor Dell PowerEdge T550 — Sede San Luis Potosí (cifrado AES-256)
Proceso asociado	Gestión de recursos humanos

Responsable operativo	Coordinador Administrativo
Dependencia tecnológica	Servidor Dell PowerEdge T550 (ACT-INT-003)
Confidencialidad	Alto
Integridad	Alto
Disponibilidad	Medio

ACT-INT-015 — Política de Seguridad de la Información PSI-2026

Campo	Detalle
Código	ACT-INT-015
Nombre	Política de Seguridad de la Información (PSI-2026)
Clasificación	Interno
Información que procesa/almacena/transmite	Directrices, reglas y compromisos de la organización respecto al uso aceptable de los activos tecnológicos y la protección de la información
Justificación de relevancia	Es el documento maestro que da sustento legal interno a todos los controles del SGSI; sin él, los controles implementados carecen de respaldo normativo interno y no son exigibles a los colaboradores
Impacto si se compromete	Deslegitimización del SGSI, imposibilidad de aplicar medidas disciplinarias ante incumplimientos, invalidación de la base documental para una eventual auditoría de certificación
Propietario del activo	Director General

Ubicación	Repositorio centralizado IC-SGSI-DOC y mural físico en oficinas
Proceso asociado	Gestión del SGSI / Concientización del personal
Responsable operativo	Responsable de TI
Dependencia tecnológica	Microsoft 365 (ACT-EXT-005), Servidor Dell PowerEdge T550 (ACT-INT-003)
Confidencialidad	Bajo
Integridad	Alto
Disponibilidad	Alto

ACT-INT-016 — Certificaciones Técnicas del Personal

Campo	Detalle
Código	ACT-INT-016
Nombre	Certificaciones Técnicas del Personal (Know-how)
Clasificación	Interno
Información que procesa/almacena/transmite	Conocimiento especializado de los inspectores certificados: metodologías de inspección, criterios técnicos aplicados y experiencia en industria automotriz y manufacturera
Justificación de relevancia	Es el activo intangible más difícil de reemplazar; la pérdida de personal certificado clave afecta directamente la capacidad de ISL para prestar sus servicios con los estándares de calidad exigidos

Impacto si se compromete	Reducción crítica de la capacidad operativa, imposibilidad de atender contratos vigentes, dependencia del conocimiento tácito individual que no puede transferirse rápidamente
Propietario del activo	Director General
Ubicación	Personal activo de ISL — operación en campo y sede central
Proceso asociado	Ejecución técnica en campo
Responsable operativo	Gerente de Operaciones
Dependencia tecnológica	Expedientes de Personal (ACT-INT-014), Manual de Procedimientos (ACT-INT-008)
Confidencialidad	Alto
Integridad	Medio
Disponibilidad	Alto

ACT-INT-017 — Caja Fuerte SentrySafe Nivel II

Campo	Detalle
Código	ACT-INT-017
Nombre	Caja Fuerte SentrySafe (Nivel de Seguridad II)
Clasificación	Interno
Información que procesa/almacena/transmite	Resguarda documentos legales originales (contratos firmados, NDAs), llaves de respaldo del cuarto de servidores y discos externos de recuperación de emergencia

Justificación de relevancia	Protección física de última línea para documentos cuyo compromiso tendría consecuencias legales directas; su contenido no puede recuperarse por medios digitales
Impacto si se compromete	Pérdida de documentos legales originales irrecuperables, acceso no autorizado a llaves físicas de infraestructura crítica y pérdida de los respaldos offline de último recurso
Propietario del activo	Director General
Ubicación	Oficina de Dirección General — Sede San Luis Potosí
Proceso asociado	Resguardo de documentación legal y continuidad de negocio
Responsable operativo	Director General
Dependencia tecnológica	Ninguna (activo físico independiente)
Confidencialidad	Alto
Integridad	Alto
Disponibilidad	Medio

ACT-INT-018 — Llaves de Seguridad FIDO2 YubiKey 5C

Campo	Detalle
Código	ACT-INT-018
Nombre	Llaves de Seguridad FIDO2 (YubiKey 5C)
Clasificación	Interno

Información que procesa/almacena/transmite	Tokens criptográficos de autenticación de doble factor (MFA) para el acceso de personal de TI a sistemas críticos y consolas de administración
Justificación de relevancia	Son el control técnico más robusto contra el acceso no autorizado a sistemas críticos; sin MFA activo, las credenciales comprometidas son suficientes para acceder a toda la infraestructura
Impacto si se compromete	Eliminación del segundo factor de autenticación, habilitación del acceso no autorizado con solo credenciales robadas, aumento exponencial del riesgo de intrusión en sistemas críticos
Propietario del activo	Responsable de TI
Ubicación	En posesión del personal de TI autorizado — Sede San Luis Potosí
Proceso asociado	Gestión de accesos y seguridad
Responsable operativo	Responsable de TI
Dependencia tecnológica	Active Directory (ACT-INT-007), Servidor Dell PowerEdge T550 (ACT-INT-003)
Confidencialidad	Alto
Integridad	Alto
Disponibilidad	Alto

ACT-INT-019 — Inventario de Activos de TI

Campo	Detalle
Código	ACT-INT-019

Nombre	Inventario de Activos de TI (JSON/Excel)
Clasificación	Interno
Información que procesa/almacena/transmite	Registro dinámico de todo el hardware y software de ISL: modelos, versiones, licencias, fechas de vencimiento y estado de parcheo de cada activo tecnológico
Justificación de relevancia	Es la base documental que permite gestionar el ciclo de vida de los activos, detectar software desactualizado y mantener la trazabilidad del inventario tecnológico exigida por ISO 27001
Impacto si se compromete	Pérdida de trazabilidad del inventario tecnológico, imposibilidad de detectar activos no gestionados o software EOL, invalidación de los procesos de auditoría interna
Propietario del activo	Responsable de TI
Ubicación	Servidor Dell PowerEdge T550 y Microsoft 365 — Sede San Luis Potosí
Proceso asociado	Gestión de activos del SGSI
Responsable operativo	Responsable de TI
Dependencia tecnológica	Microsoft 365 (ACT-EXT-005), Servidor Dell PowerEdge T550 (ACT-INT-003)
Confidencialidad	Medio
Integridad	Alto
Disponibilidad	Alto

Campo

Detalle

Código	ACT-INT-020
Nombre	Plan de Continuidad de Negocio (BCP v2.1)
Clasificación	Interno
Información que procesa/almacena/transmite	Protocolos de respuesta ante desastres, tiempos de recuperación objetivo (RTO/RPO), procedimientos de activación de contingencias y contactos de emergencia
Justificación de relevancia	Define cómo ISL recupera sus operaciones ante un incidente grave; su disponibilidad en el momento crítico determina la velocidad de recuperación y el impacto económico del incidente
Impacto si se compromete	Ausencia de guía operativa durante una crisis, tiempos de recuperación no controlados, pérdida económica maximizada por falta de respuesta coordinada
Propietario del activo	Director General
Ubicación	Caja Fuerte SentrySafe (copia física) y Servidor Dell PowerEdge T550 (copia digital)
Proceso asociado	Continuidad operativa y gestión de incidentes
Responsable operativo	Gerente de Operaciones
Dependencia tecnológica	Caja Fuerte SentrySafe (ACT-INT-017), Servidor Dell PowerEdge T550 (ACT-INT-003)
Confidencialidad	Alto
Integridad	Alto
Disponibilidad	Alto

7.3 Activos Externos

Activos que influyen en el riesgo de ISL pero que no están bajo su control total.

ACT-EXT-001 — Instancia AWS EC2 t3.medium

Campo	Detalle
Código	ACT-EXT-001
Nombre	Instancia AWS EC2 (t3.medium)
Clasificación	Externo
Información que procesa/almacena/transmite	Aloja el portal de clientes externo donde los clientes pueden consultar el estado de sus inspecciones y descargar reportes técnicos
Justificación de relevancia	Es el punto de contacto digital con los clientes; su indisponibilidad impide que los clientes accedan a sus reportes y daña la percepción del servicio
Impacto si se compromete	Indisponibilidad del portal de clientes, exposición de datos confidenciales almacenados en la instancia, daño reputacional ante clientes que no puedan acceder a sus reportes
Propietario del activo	Amazon Web Services (gestión operativa: Responsable de TI de ISL)
Ubicación	Nube pública AWS — Región us-east-1
Proceso asociado	Emisión y entrega del reporte final
Responsable operativo	Responsable de TI
Dependencia tecnológica	Enlace de Fibra Óptica Telmex (ACT-EXT-004), Certificado SSL Digicert (ACT-EXT-006)

Confidencialidad Alto

Integridad Alto

Disponibilidad Alto

ACT-EXT-002 — Hosting Web HostGator Plan Business

Campo	Detalle
Código	ACT-EXT-002
Nombre	Hosting Web HostGator (Plan Business)
Clasificación	Externo
Información que procesa/almacena/transmite	Archivos de la página pública de ISL, información corporativa, servicios ofrecidos y datos de contacto publicados
Justificación de relevancia	Es la presencia web pública de ISL; su compromiso podría usarse para ataques de phishing suplantando la identidad de la empresa ante sus clientes
Impacto si se compromete	Defacement del sitio web, distribución de malware a visitantes, daño reputacional y uso del dominio para campañas de phishing dirigidas a los clientes de ISL
Propietario del activo	HostGator (gestión operativa: Responsable de TI de ISL)
Ubicación	Infraestructura externa HostGator
Proceso asociado	Comunicación externa y captación de clientes
Responsable operativo	Responsable de TI

Dependencia tecnológica Dominio inspeccionsl.com.mx (ACT-EXT-003),
Certificado SSL Digicert (ACT-EXT-006)

Confidencialidad **Medio**

Integridad **Alto**

Disponibilidad **Medio**

ACT-EXT-003 — Dominio inspeccionsl.com.mx

Campo	Detalle
Código	ACT-EXT-003
Nombre	Dominio "inspeccionsl.com.mx" (Akamai/GoDaddy)
Clasificación	Externo
Información que procesa/almacena/transmite	Activo de identidad digital; resuelve el nombre de dominio hacia los servicios web de ISL para clientes y colaboradores
Justificación de relevancia	El secuestro del dominio (domain hijacking) permitiría redirigir todo el tráfico de clientes hacia sitios fraudulentos, comprometiendo credenciales y reputación
Impacto si se compromete	Secuestro total de la identidad digital de ISL, redirección de clientes a sitios maliciosos, interceptación de comunicaciones y pérdida de control sobre todos los servicios web
Propietario del activo	GoDaddy/Akamai (gestión operativa: Director General de ISL)
Ubicación	Registrador externo GoDaddy

Proceso asociado	Comunicación externa y acceso al portal de clientes
Responsable operativo	Responsable de TI
Dependencia tecnológica	Hosting HostGator (ACT-EXT-002), Instancia AWS EC2 (ACT-EXT-001)
Confidencialidad	Medio
Integridad	Alto
Disponibilidad	Alto

ACT-EXT-004 — Enlace Fibra Óptica Telmex Negocio 500 Mbps

Campo	Detalle
Código	ACT-EXT-004
Nombre	Enlace de Fibra Óptica Telmex Negocio (500 Mbps)
Clasificación	Externo
Información que procesa/almacena/transmite	Canal de transmisión de toda la comunicación digital de ISL: correos, reportes, acceso a sistemas en nube y VPN de inspectores remotos
Justificación de relevancia	Es la conectividad principal de la sede; sin internet, ISL pierde acceso a Microsoft 365, al portal de clientes en AWS y a la sincronización de datos desde campo
Impacto si se compromete	Interrupción total de comunicaciones con clientes, imposibilidad de entregar reportes digitales, desconexión de inspectores remotos de los sistemas centrales
Propietario del activo	Telmex (dependencia total del proveedor)

Ubicación	Infraestructura de red Telmex — Sede San Luis Potosí
Proceso asociado	Todos los procesos que requieren conectividad externa
Responsable operativo	Responsable de TI
Dependencia tecnológica	Switch Cisco Catalyst 9200 (ACT-INT-010)
Confidencialidad	Medio
Integridad	Medio
Disponibilidad	Alto

ACT-EXT-005 — Microsoft 365 Business Premium

Campo	Detalle
Código	ACT-EXT-005
Nombre	Microsoft 365 Business Premium
Clasificación	Externo
Información que procesa/almacena/transmite	Correos electrónicos corporativos, documentos de trabajo en OneDrive, comunicaciones por Teams, calendarios de visitas y reportes en tránsito
Justificación de relevancia	Es la plataforma de productividad y comunicación principal de ISL; concentra el flujo diario de información sensible entre colaboradores y con clientes
Impacto si se compromete	Acceso no autorizado a comunicaciones internas y con clientes, filtración de información contractual enviada por correo, interrupción de la coordinación operativa entre la sede y los inspectores en campo

Propietario del activo	Microsoft Corporation (gestión operativa: Responsable de TI de ISL)
Ubicación	Nube Microsoft — Centros de datos de Microsoft
Proceso asociado	Todos los procesos de comunicación y gestión documental
Responsable operativo	Responsable de TI
Dependencia tecnológica	Enlace Fibra Óptica Telmex (ACT-EXT-004), Active Directory (ACT-INT-007)
Confidencialidad	Alto
Integridad	Alto
Disponibilidad	Alto

ACT-EXT-006 — Certificado SSL Digicert EV

Campo	Detalle
Código	ACT-EXT-006
Nombre	Certificado SSL Digicert (EV)
Clasificación	Externo
Información que procesa/almacena/transmite	Valida la identidad del portal web de ISL y cifra las comunicaciones entre el navegador del cliente y el servidor, protegiendo los datos transmitidos
Justificación de relevancia	Sin certificado SSL válido, los navegadores marcan el portal como inseguro y los datos transmitidos (credenciales, reportes) viajan sin cifrado

Impacto si se compromete	Pérdida de confianza del cliente al navegar el portal, exposición de credenciales de acceso en texto plano, posibilidad de ataques man-in-the-middle sobre las comunicaciones con clientes
Propietario del activo	Digicert (gestión operativa: Responsable de TI de ISL)
Ubicación	Infraestructura Digicert — asociado al dominio ACT-EXT-003
Proceso asociado	Emisión y entrega del reporte final / Seguridad del portal de clientes
Responsable operativo	Responsable de TI
Dependencia tecnológica	Dominio inspeccionesl.com.mx (ACT-EXT-003), Instancia AWS EC2 (ACT-EXT-001)
Confidencialidad	Alto
Integridad	Alto
Disponibilidad	Alto

ACT-EXT-007 — Red VPN de Acceso Remoto IPsec

Campo	Detalle
Código	ACT-EXT-007
Nombre	Red VPN de Acceso Remoto (Protocolo IPsec)
Clasificación	Externo
Información que procesa/almacena/transmite	Canal cifrado que transmite datos entre los inspectores en campo y los sistemas centrales de ISL a través de la infraestructura pública de internet

Justificación de relevancia	Es el único mecanismo que garantiza que los datos capturados en campo lleguen a los servidores centrales de forma segura; sin VPN activa, los datos viajan expuestos por redes públicas
Impacto si se compromete	Interceptación de datos técnicos en tránsito, acceso no autorizado a los sistemas internos de ISL desde internet, exposición de credenciales de Active Directory de los inspectores
Propietario del activo	Infraestructura pública de internet (gestión del túnel: Responsable de TI de ISL)
Ubicación	Canal lógico sobre internet — entre campo y sede central
Proceso asociado	Ejecución técnica en campo / Sincronización de datos de inspección
Responsable operativo	Responsable de TI
Dependencia tecnológica	Enlace Fibra Óptica Telmex (ACT-EXT-004), Red Móvil 5G (ACT-EXT-019), Servidor Dell PowerEdge T550 (ACT-INT-003)
Confidencialidad	Alto
Integridad	Alto
Disponibilidad	Alto

ACT-EXT-008 — API de Facturación SAT v4.0

Campo	Detalle
Código	ACT-EXT-008
Nombre	API de Facturación SAT (v4.0)

Clasificación	Externo
Información que procesa/almacena/transmite	Datos fiscales de ISL y sus clientes transmitidos para la emisión de Comprobantes Fiscales Digitales por Internet (CFDI)
Justificación de relevancia	Su indisponibilidad impide la emisión legal de facturas, bloqueando el cobro de los servicios prestados y el flujo de caja de la empresa
Impacto si se compromete	Emisión de facturas con datos incorrectos, incumplimiento de obligaciones fiscales ante el SAT, bloqueo del flujo de ingresos y posibles sanciones fiscales
Propietario del activo	Servicio de Administración Tributaria (SAT) — México
Ubicación	Infraestructura del SAT — México
Proceso asociado	Facturación y cierre administrativo
Responsable operativo	Coordinador Administrativo
Dependencia tecnológica	Enlace Fibra Óptica Telmex (ACT-EXT-004), Microsoft 365 (ACT-EXT-005)
Confidencialidad	Alto
Integridad	Alto
Disponibilidad	Alto

ACT-EXT-009 — WhatsApp Business API (Meta)

Campo	Detalle
Código	ACT-EXT-009

Nombre	WhatsApp Business API (Meta)
Clasificación	Externo
Información que procesa/almacena/transmite	Comunicaciones rápidas con clientes para coordinación de visitas, confirmación de fechas de inspección y notificaciones urgentes
Justificación de relevancia	Canal de comunicación operativa de alta frecuencia con los clientes; su compromiso podría usarse para enviar comunicaciones fraudulentas suplantando a ISL
Impacto si se compromete	Suplantación de identidad de ISL ante clientes, envío de desinformación sobre inspecciones programadas, daño a la relación comercial y reputacional
Propietario del activo	Meta Platforms Inc.
Ubicación	Infraestructura externa Meta
Proceso asociado	Contratación y coordinación operativa
Responsable operativo	Gerente de Operaciones
Dependencia tecnológica	Enlace Fibra Óptica Telmex (ACT-EXT-004), Red Móvil 5G (ACT-EXT-019)
Confidencialidad	Medio
Integridad	Medio
Disponibilidad	Medio

ACT-EXT-010 — Repositorio GitHub Plan Pro

Campo

Detalle

Código	ACT-EXT-010
Nombre	Repositorio GitHub (Plan Pro)
Clasificación	Externo
Información que procesa/almacena/transmite	Código fuente de la App Inspección SL, scripts de automatización y portafolio de proyectos técnicos de ISL
Justificación de relevancia	Almacena el activo tecnológico de desarrollo de ISL; una mala configuración de permisos podría exponer públicamente código con lógica de negocio sensible o credenciales embebidas
Impacto si se compromete	Exposición pública del código fuente, filtración de credenciales o endpoints embebidos en el código, introducción de código malicioso mediante commits no autorizados
Propietario del activo	GitHub Inc. / Microsoft (gestión operativa: Responsable de TI de ISL)
Ubicación	Infraestructura GitHub — Nube Microsoft
Proceso asociado	Gestión del activo tecnológico App Inspección SL
Responsable operativo	Responsable de TI
Dependencia tecnológica	Enlace Fibra Óptica Telmex (ACT-EXT-004), Credenciales Active Directory (ACT-INT-007)
Confidencialidad	Alto
Integridad	Alto
Disponibilidad	Medio

ACT-EXT-011 — Feed de Inteligencia de Amenazas AlienVault OTX

Campo	Detalle
Código	ACT-EXT-011
Nombre	Feed de Inteligencia de Amenazas (AlienVault OTX)
Clasificación	Externo
Información que procesa/almacena/transmite	Indicadores de compromiso (IoC) actualizados, información sobre nuevas campañas de malware y vulnerabilidades activas relevantes para la infraestructura de ISL
Justificación de relevancia	Provee inteligencia en tiempo real para anticipar ataques; sin este feed, el Responsable de TI opera con información desactualizada sobre el panorama de amenazas
Impacto si se compromete	Pérdida de visibilidad sobre amenazas activas, retraso en la respuesta ante nuevos vectores de ataque, mayor probabilidad de ser víctima de campañas de malware recientes
Propietario del activo	AT&T Cybersecurity / AlienVault
Ubicación	Plataforma externa AlienVault OTX
Proceso asociado	Monitoreo de seguridad y gestión de vulnerabilidades
Responsable operativo	Responsable de TI
Dependencia tecnológica	Enlace Fibra Óptica Telmex (ACT-EXT-004)
Confidencialidad	Bajo
Integridad	Medio

Disponibilidad

Medio

ACT-EXT-012 — Base de Datos CVE (MITRE)

Campo	Detalle
Código	ACT-EXT-012
Nombre	Base de Datos CVE (MITRE)
Clasificación	Externo
Información que procesa/almacena/transmite	Repositorio público de vulnerabilidades conocidas (Common Vulnerabilities and Exposures) para el escaneo y evaluación de la infraestructura de ISL
Justificación de relevancia	Sustenta el proceso de gestión de vulnerabilidades técnicas; es la referencia estándar para identificar si el software en uso por ISL tiene vulnerabilidades explotables conocidas
Impacto si se compromete	Sin acceso a CVE, ISL no puede evaluar el nivel de riesgo real de su software desactualizado ni priorizar parches de seguridad, aumentando el tiempo de exposición ante vulnerabilidades críticas
Propietario del activo	MITRE Corporation / NIST
Ubicación	Plataforma pública cve.mitre.org
Proceso asociado	Gestión de vulnerabilidades técnicas / Auditoría interna
Responsable operativo	Responsable de TI
Dependencia tecnológica	Enlace Fibra Óptica Telmex (ACT-EXT-004)
Confidencialidad	Bajo

Integridad

Medio

Disponibilidad

Medio

ACT-EXT-013 — Pasarela de Pagos Stripe

Campo	Detalle
Código	ACT-EXT-013
Nombre	Pasarela de Pagos Stripe
Clasificación	Externo
Información que procesa/almacena/transmite	Datos de transacciones de pago de clientes por servicios de inspección, información de tarjetas de crédito/débito de clientes procesada bajo estándar PCI-DSS
Justificación de relevancia	Procesa los ingresos económicos de ISL; su compromiso afecta directamente el flujo de caja y la confianza de los clientes que realizan pagos en línea
Impacto si se compromete	Fraude financiero, exposición de datos bancarios de clientes, sanciones bajo PCI-DSS, pérdida de la capacidad de procesar pagos en línea y daño reputacional severo
Propietario del activo	Stripe Inc.
Ubicación	Infraestructura externa Stripe
Proceso asociado	Facturación y cierre administrativo
Responsable operativo	Coordinador Administrativo
Dependencia tecnológica	Enlace Fibra Óptica Telmex (ACT-EXT-004), Dominio inspeccionesl.com.mx (ACT-EXT-003)

Confidencialidad **Alto**

Integridad **Alto**

Disponibilidad **Alto**

ACT-EXT-014 — Plataforma Zoom Video v6.0

Campo	Detalle
Código	ACT-EXT-014
Nombre	Plataforma Zoom Video (v6.0)
Clasificación	Externo
Información que procesa/almacena/transmite	Reuniones virtuales con clientes de otros estados, presentación de resultados de inspección, negociaciones comerciales y sesiones de capacitación remota
Justificación de relevancia	Canal de comunicación para clientes geográficamente dispersos; las reuniones pueden incluir información técnica y comercial sensible que no debe ser interceptada
Impacto si se compromete	Interceptación de conversaciones confidenciales con clientes, filtración de información técnica presentada en reuniones virtuales, acceso no autorizado a sesiones activas
Propietario del activo	Zoom Video Communications Inc.
Ubicación	Infraestructura externa Zoom
Proceso asociado	Contratación y comunicación con clientes remotos
Responsable operativo	Gerente de Operaciones

Dependencia tecnológica

Enlace Fibra Óptica Telmex (ACT-EXT-004), Laptops HP EliteBook (ACT-INT-004)

Confidencialidad

Alto

Integridad

Medio

Disponibilidad

Medio

ACT-EXT-015 — Servidores de Parches Microsoft Update

Campo	Detalle
Código	ACT-EXT-015
Nombre	Servidores de Parches Microsoft Update
Clasificación	Externo
Información que procesa/almacena/transmite	Actualizaciones de seguridad críticas y parches del sistema operativo para las laptops HP EliteBook con Windows 11 Pro
Justificación de relevancia	Sin acceso a los servidores de actualización de Microsoft, las laptops acumulan vulnerabilidades de seguridad conocidas que pueden ser explotadas por atacantes
Impacto si se compromete	Acumulación de vulnerabilidades no parcheadas en las estaciones de trabajo, aumento del riesgo de infección por malware que explote CVEs conocidos en Windows 11
Propietario del activo	Microsoft Corporation
Ubicación	Infraestructura externa Microsoft

Proceso asociado	Gestión de vulnerabilidades técnicas
Responsable operativo	Responsable de TI
Dependencia tecnológica	Enlace Fibra Óptica Telmex (ACT-EXT-004), Laptops HP EliteBook (ACT-INT-004)
Confidencialidad	Bajo
Integridad	Alto
Disponibilidad	Alto

ACT-EXT-016 — Página de Empresa en LinkedIn

Campo	Detalle
Código	ACT-EXT-016
Nombre	Página de Empresa en LinkedIn
Clasificación	Externo
Información que procesa/almacena/transmite	Perfil corporativo de ISL, publicaciones de servicios, datos de contacto públicos y perfiles de los colaboradores vinculados a la empresa
Justificación de relevancia	Canal de reclutamiento y reputación profesional; la información pública de los empleados puede ser usada para ataques de ingeniería social o spear phishing dirigido
Impacto si se compromete	Uso de información de empleados para ataques de spear phishing, suplantación de la identidad corporativa de ISL, daño reputacional ante clientes y candidatos potenciales

Propietario del activo	LinkedIn Corporation / Microsoft
Ubicación	Plataforma externa LinkedIn
Proceso asociado	Gestión de recursos humanos / Comunicación externa
Responsable operativo	Director General
Dependencia tecnológica	Enlace Fibra Óptica Telmex (ACT-EXT-004)
Confidencialidad	Medio
Integridad	Medio
Disponibilidad	Bajo

ACT-EXT-017 — Normativa ISO/IEC 27001:2022

Campo	Detalle
Código	ACT-EXT-017
Nombre	Normativa ISO/IEC 27001:2022 (Estándar Externo)
Clasificación	Externo
Información que procesa/almacena/transmite	Marco de requisitos, controles y directrices que dictan el diseño e implementación del SGSI de ISL
Justificación de relevancia	Es la referencia normativa que legitima todo el sistema; sin su aplicación correcta, el SGSI no es certificable ni comparable con estándares internacionales
Impacto si se compromete	Uso de una versión obsoleta del estándar generaría un SGSI desalineado con los requisitos actuales, invalidando una eventual certificación y desactualizando los controles implementados

Propietario del activo	ISO / IEC
Ubicación	Licencia digital adquirida — repositorio de documentación de ISL
Proceso asociado	Gestión del SGSI / Auditoría interna
Responsable operativo	Responsable de TI
Dependencia tecnológica	Ninguna directa
Confidencialidad	Bajo
Integridad	Alto
Disponibilidad	Alto

ACT-EXT-018 — Red Eléctrica CFE 220V Industrial

Campo	Detalle
Código	ACT-EXT-018
Nombre	Red Eléctrica CFE (220V Industrial)
Clasificación	Externo
Información que procesa/almacena/transmite	Suministro eléctrico del cual depende la operación física de toda la infraestructura tecnológica de ISL
Justificación de relevancia	Es el recurso más básico de la cadena de disponibilidad; sin suministro eléctrico, ningún activo tecnológico de ISL puede operar, independientemente de los demás controles implementados

Impacto si se compromete	Paro total de operaciones tecnológicas, riesgo de corrupción de datos durante interrupciones abruptas (mitigado parcialmente por el UPS ACT-INT-011), imposibilidad de prestar servicios mientras dure el corte
Propietario del activo	Comisión Federal de Electricidad (CFE)
Ubicación	Infraestructura eléctrica CFE — San Luis Potosí
Proceso asociado	Todos los procesos operativos de ISL
Responsable operativo	Responsable de TI (monitoreo)
Dependencia tecnológica	UPS APC Smart-UPS 2200VA (ACT-INT-011) como control compensatorio
Confidencialidad	Bajo
Integridad	Medio
Disponibilidad	Alto

ACT-EXT-019 — Red Móvil 5G Telcel/AT&T

Campo	Detalle
Código	ACT-EXT-019
Nombre	Red Móvil 5G (Telcel/AT&T)
Clasificación	Externo
Información que procesa/almacena/transmite	Conectividad de datos para las tablets de los inspectores en campo, permitiendo la transmisión de resultados de inspección y el acceso a la VPN desde plantas industriales remotas

Justificación de relevancia	Es la única conectividad disponible para los inspectores cuando operan en plantas industriales que no permiten conexión a su red interna
Impacto si se compromete	Imposibilidad de sincronizar datos capturados en campo con los servidores centrales, acumulación de datos críticos solo en las tablets sin respaldo central, pérdida de datos si ocurre un incidente con el dispositivo antes de la sincronización
Propietario del activo	Telcel / AT&T México
Ubicación	Infraestructura de red móvil — cobertura nacional
Proceso asociado	Ejecución técnica en campo
Responsable operativo	Supervisores de Inspección
Dependencia tecnológica	Tablets Samsung Galaxy Tab Active4 Pro (ACT-INT-005), VPN IPsec (ACT-EXT-007)
Confidencialidad	Medio
Integridad	Medio
Disponibilidad	Alto

ACT-EXT-020 — Reputación Online (Google Business)

Campo	Detalle
Código	ACT-EXT-020
Nombre	Reputación Online (Google Business)
Clasificación	Externo

Información que procesa/almacena/transmite	Reseñas públicas, calificaciones y percepción del mercado sobre los servicios de ISL, visible para clientes potenciales que buscan proveedores de inspección en la región
Justificación de relevancia	En el mercado B2B industrial, la reputación digital es un factor de decisión de compra; reseñas negativas o manipuladas pueden bloquear la captación de nuevos clientes
Impacto si se compromete	Publicación de reseñas falsas negativas por competidores o clientes insatisfechos, daño a la captación de nuevos clientes, pérdida de contratos potenciales ante empresas que evalúan proveedores en línea
Propietario del activo	Google LLC (gestión operativa: Director General de ISL)
Ubicación	Plataforma externa Google Business
Proceso asociado	Captación de clientes / Comunicación externa
Responsable operativo	Director General
Dependencia tecnológica	Ninguna directa (activo de percepción pública)
Confidencialidad	Bajo
Integridad	Alto
Disponibilidad	Medio

7.4 Tabla Resumen de Activos — Clasificación CIA y Trazabilidad

Código	Nombre del Activo	Tipo	C	I	D
---------------	--------------------------	-------------	----------	----------	----------

ACT-INT-001	Base de Datos de Clientes SQL Server	Interno	Alto	Alto	Alto
ACT-INT-002	Certificados de Calidad Digitales PDF/A	Interno	Alto	Alto	Medio
ACT-INT-003	Servidor Dell PowerEdge T550	Interno	Alto	Alto	Alto
ACT-INT-004	Laptops HP EliteBook 840 G10	Interno	Alto	Medio	Alto
ACT-INT-005	Tablets Samsung Galaxy Tab Active4 Pro	Interno	Alto	Alto	Medio
ACT-INT-006	Código Fuente App Inspección SL	Interno	Alto	Alto	Medio
ACT-INT-007	Credenciales Active Directory	Interno	Alto	Alto	Alto
ACT-INT-008	Manual de Procedimientos ISO 27001 v1.0	Interno	Medio	Alto	Alto
ACT-INT-009	Discos Externos Respaldo WD 5TB	Interno	Alto	Alto	Alto
ACT-INT-010	Switch Cisco Catalyst 9200	Interno	Medio	Alto	Alto
ACT-INT-011	UPS APC Smart-UPS 2200VA	Interno	Bajo	Alto	Alto
ACT-INT-012	Cámaras IP Hikvision 4K DS-2CD	Interno	Alto	Medio	Medio
ACT-INT-013	Lector Biométrico ZKTeco SpeedFace	Interno	Alto	Alto	Alto
ACT-INT-014	Expedientes de Personal AES-256	Interno	Alto	Alto	Medio
ACT-INT-015	Política de Seguridad PSI-2026	Interno	Bajo	Alto	Alto
ACT-INT-016	Certificaciones Técnicas del Personal	Interno	Alto	Medio	Alto
ACT-INT-017	Caja Fuerte SentrySafe Nivel II	Interno	Alto	Alto	Medio
ACT-INT-018	Llaves de Seguridad FIDO2 YubiKey 5C	Interno	Alto	Alto	Alto
ACT-INT-019	Inventario de Activos de TI JSON/Excel	Interno	Medio	Alto	Alto
ACT-INT-020	Plan de Continuidad de Negocio BCP v2.1	Interno	Alto	Alto	Alto
ACT-EXT-001	Instancia AWS EC2 t3.medium	Externo	Alto	Alto	Alto
ACT-EXT-002	Hosting Web HostGator Plan Business	Externo	Medio	Alto	Medio
ACT-EXT-003	Dominio inspeccionsl.com.mx	Externo	Medio	Alto	Alto
ACT-EXT-004	Enlace Fibra Óptica Telmex 500 Mbps	Externo	Medio	Medio	Alto

ACT-EXT-005	Microsoft 365 Business Premium	Externo	Alto	Alto	Alto
ACT-EXT-006	Certificado SSL Digicert EV	Externo	Alto	Alto	Alto
ACT-EXT-007	Red VPN Acceso Remoto IPsec	Externo	Alto	Alto	Alto
ACT-EXT-008	API Facturación SAT v4.0	Externo	Alto	Alto	Alto
ACT-EXT-009	WhatsApp Business API Meta	Externo	Medio	Medio	Medio
ACT-EXT-010	Repositorio GitHub Plan Pro	Externo	Alto	Alto	Medio
ACT-EXT-011	Feed Inteligencia AlienVault OTX	Externo	Bajo	Medio	Medio
ACT-EXT-012	Base de Datos CVE MITRE	Externo	Bajo	Medio	Medio
ACT-EXT-013	Pasarela de Pagos Stripe	Externo	Alto	Alto	Alto
ACT-EXT-014	Plataforma Zoom Video v6.0	Externo	Alto	Medio	Medio
ACT-EXT-015	Servidores de Parches Microsoft Update	Externo	Bajo	Alto	Alto
ACT-EXT-016	Página de Empresa LinkedIn	Externo	Medio	Medio	Bajo
ACT-EXT-017	Normativa ISO/IEC 27001:2022	Externo	Bajo	Alto	Alto
ACT-EXT-018	Red Eléctrica CFE 220V Industrial	Externo	Bajo	Medio	Alto
ACT-EXT-019	Red Móvil 5G Telcel/AT&T	Externo	Medio	Medio	Alto
ACT-EXT-020	Reputación Online Google Business	Externo	Bajo	Alto	Medio

8. LIDERAZGO

8.1 Política General de Seguridad de la Información

8.1.1 Declaración de la Dirección General

Inspección Certificada SL tiene como misión garantizar que los procesos de sus clientes industriales fluyan sin interrupciones causadas por defectos de calidad, aportando valor mediante la excelencia técnica y la entrega oportuna de información crítica. En coherencia con esta misión y con nuestra visión de convertirnos para 2030 en el referente principal de servicios de inspección industrial en el centro del país mediante la integración de tecnologías de la información, la Dirección General establece formalmente la presente **Política General de Seguridad de la Información**.

Esta política reconoce que la información técnica, contractual y operativa que ISL genera, procesa y custodia constituye un activo estratégico crítico. Su protección no es solo una obligación normativa bajo la norma **ISO/IEC 27001:2022**, sino una condición indispensable para mantener la confianza de nuestros clientes Tier 1 y Tier 2, cumplir con los acuerdos de confidencialidad (NDAs) firmados y garantizar la continuidad del negocio ante los riesgos identificados, entre los cuales destacan el acceso no autorizado a reportes confidenciales (nivel EXTREMO, valor 25), el robo de dispositivos móviles en campo (nivel MUY ALTO, valor 16) y el uso de software de servidores desactualizado (nivel MUY ALTO, valor 15).

8.1.2 Objetivo de la Política

Proteger los activos de información de Inspección Certificada SL garantizando los principios de **Confidencialidad, Integridad y Disponibilidad (Triada CID)** de toda la información generada, procesada, almacenada o transmitida durante el ciclo completo de los servicios de inspección industrial, desde la recepción de planos técnicos del cliente hasta la entrega y resguardo del reporte final, reduciendo los riesgos operativos y de seguridad a niveles aceptables para la organización.

8.1.3 Alcance de la Política

Esta política aplica a:

- La **totalidad de los 23 colaboradores** de ISL, independientemente de su nivel jerárquico, tipo de contrato o modalidad de trabajo (presencial, remoto o en campo).
- Todos los **activos de información internos y externos** documentados en la Sección 4 de este SGSI (ACT-INT-001 a ACT-INT-020 y ACT-EXT-001 a ACT-EXT-020).

- Todos los **procesos del ciclo operativo**: contratación, planificación, ejecución técnica en campo, emisión de reportes y facturación.
- Los **proveedores y terceros** que tengan acceso, aunque sea temporal, a sistemas o información de ISL.
- Las operaciones realizadas tanto en la **sede central de San Luis Potosí** como en las **instalaciones de los clientes** donde operan los inspectores en campo.

8.1.4 Compromiso de la Dirección General

Yo, como Director General de **Inspección Certificada SL**, me comprometo formalmente a:

- Proveer los **recursos humanos, tecnológicos y económicos** necesarios para el establecimiento, implementación, mantenimiento y mejora continua del SGSI, incluyendo las 480 horas de residencia profesional asignadas al proyecto y el presupuesto aprobado para herramientas de seguridad.
- **Aprobar, comunicar y exigir el cumplimiento** de todas las políticas, procedimientos y controles de seguridad establecidos en este documento.
- **Liderar con el ejemplo** en la adopción de las prácticas de seguridad, incluyendo el uso de autenticación multifactor y el manejo confidencial de información estratégica.
- **Impulsar activamente la cultura de seguridad** en toda la organización mediante sesiones de concientización y la integración de la seguridad como valor corporativo.
- **Supervisar periódicamente** la eficacia del SGSI mediante revisiones de dirección, auditorías internas y el seguimiento de los indicadores clave de desempeño (KPIs) establecidos.
- Garantizar que cualquier **no conformidad detectada** reciba los recursos necesarios para su corrección en los plazos establecidos.

Firma y fecha de aprobación: _____ Director General,
Inspección Certificada SL, 2026.

8.2 Políticas Funcionales de Seguridad de la Información

Las siguientes diez políticas operacionalizan la Política General y se aplican a los procesos, activos y personal específico de Inspección Certificada SL.

POLÍTICA 01 — Gestión de Accesos e Identidades

Activos relacionados: ACT-INT-007 (Active Directory), ACT-EXT-007 (VPN IPsec), ACT-EXT-005 (Microsoft 365), ACT-EXT-001 (AWS EC2), ACT-EXT-010 (GitHub)

Riesgo que mitiga: Acceso no autorizado a reportes confidenciales (nivel EXTREMO, valor 25)

Estándar (obligatorio): Todo acceso a los sistemas de información de ISL debe estar autenticado, autorizado formalmente y registrado en el sistema de logs de auditoría. Ningún colaborador puede acceder a recursos para los cuales no tenga una autorización explícita documentada. El principio de mínimo privilegio es obligatorio: cada usuario recibe únicamente los permisos estrictamente necesarios para ejecutar sus funciones. La autenticación multifactor (MFA) mediante YubiKey 5C (ACT-INT-018) es obligatoria para todo acceso administrativo a sistemas críticos.

Directriz (recomendado): Se recomienda aplicar el principio de segregación de funciones para evitar que una sola persona concentre permisos que le permitan crear, aprobar y ejecutar transacciones críticas sin supervisión. Se aconseja implementar revisiones de acceso trimestrales para detectar cuentas inactivas, privilegios acumulados o accesos huérfanos de exempleados. Es conveniente utilizar grupos de seguridad en Active Directory en lugar de permisos individuales para facilitar la gestión y auditoría.

Procedimiento:

1. El Gerente de Operaciones o el Coordinador Administrativo completa el formulario **IC-SGSI-ACC-01** (Alta/Modificación/Baja de Accesos) indicando el usuario, los sistemas requeridos y el nivel de acceso solicitado.
2. El Director General aprueba o rechaza la solicitud dentro de las 24 horas hábiles siguientes.
3. El Responsable de TI ejecuta el alta, modificación o baja en Active Directory dentro de las 4 horas posteriores a la aprobación.
4. Para accesos remotos vía VPN, el Responsable de TI configura el perfil en el servidor VPN IPsec y entrega las credenciales de forma segura al colaborador.
5. El Responsable de TI registra el cambio en el log de auditoría del sistema con fecha, hora y autorización de respaldo.
6. Cada trimestre, el Responsable de TI genera un reporte de revisión de accesos y lo presenta al Director General para validación. Las cuentas no justificadas se eliminan en las siguientes 48 horas.

Línea Base:

- 100% de cuentas de usuario activas con MFA habilitado.
- 0 cuentas de exempleados activas en el sistema.
- 100% de solicitudes de acceso con formulario IC-SGSI-ACC-01 completo y aprobado.
- Revisión de privilegios ejecutada al menos una vez por trimestre con evidencia documentada.

Activos relacionados: ACT-INT-001 (BD Clientes), ACT-INT-002 (Certificados PDF), ACT-INT-006 (Código Fuente), ACT-INT-014 (Expedientes Personal) **Riesgo que mitiga:** Fuga de información por error humano (nivel ALTO, valor 12)

Estándar (obligatorio): Toda la información generada, recibida o procesada por ISL debe clasificarse según su nivel de sensibilidad antes de ser almacenada, transmitida o compartida. Se establecen tres niveles de clasificación obligatorios: **Confidencial** (planos técnicos del cliente, NDAs, credenciales de acceso, expedientes de personal), **Interno** (reportes de inspección, órdenes de servicio, procedimientos operativos) y **Público** (información comercial publicada en el sitio web y LinkedIn). Ninguna información Confidencial puede transmitirse por canales no cifrados.

Directriz (recomendado): Se recomienda etiquetar visualmente los documentos físicos y digitales con su nivel de clasificación en el encabezado o pie de página. Se aconseja utilizar las etiquetas de sensibilidad de Microsoft 365 (ACT-EXT-005) para clasificar automáticamente los correos electrónicos y documentos en OneDrive. Es conveniente realizar una revisión anual de la clasificación de activos para actualizar niveles según cambios en el contexto del negocio.

Procedimiento:

1. Al recibir información del cliente (planos, NDAs, especificaciones), el Gerente de Operaciones la clasifica como **Confidencial** y la registra en el formulario **IC-SGSI-INF-01** (Registro de Recepción de Información del Cliente).
2. El Responsable de TI almacena la información en la carpeta correspondiente del Servidor Dell (ACT-INT-003) con los permisos de acceso restringido configurados en Active Directory.
3. Para transmisión externa, el colaborador verifica que el canal sea cifrado (correo con TLS, portal HTTPS de AWS o VPN activa). Está prohibido el envío de información Confidencial por WhatsApp, correo personal o USB sin cifrar.
4. Al finalizar un contrato, el Gerente de Operaciones notifica al Responsable de TI para archivar o destruir la información del cliente según lo pactado en el NDA correspondiente.
5. La destrucción de información física se realiza mediante destructora de documentos y se registra en el formulario **IC-SGSI-INF-02** (Registro de Destrucción de Información).

Línea Base:

- 100% de información recibida de clientes clasificada y registrada en IC-SGSI-INF-01 antes de su almacenamiento.
- 0 envíos de información Confidencial por canales no cifrados detectados en auditoría.
- 100% de documentos digitales con etiqueta de clasificación visible.

- Revisión de clasificación de activos ejecutada al menos una vez al año.

POLÍTICA 03 — Seguridad de la Infraestructura Tecnológica

Activos relacionados: ACT-INT-003 (Servidor Dell), ACT-INT-010 (Switch Cisco), ACT-INT-011 (UPS APC), ACT-INT-012 (Cámaras IP), ACT-INT-013 (Lector Biométrico), ACT-EXT-018 (Red CFE) **Riesgo que mitiga:** Uso de software desactualizado en servidores (nivel MUY ALTO, valor 15)

Estándar (obligatorio): Toda la infraestructura tecnológica crítica de ISL debe estar protegida contra fallas físicas, accesos no autorizados y vulnerabilidades técnicas. El acceso físico al cuarto de servidores está restringido exclusivamente al Responsable de TI y al Director General, controlado mediante el lector biométrico ZKTeco SpeedFace (ACT-INT-013). Los parches de seguridad críticos deben aplicarse en un plazo máximo de 72 horas tras su publicación oficial. Ningún servicio o puerto innecesario puede permanecer activo en el servidor.

Directriz (recomendado): Se recomienda mantener un entorno de staging (servidor espejo) para probar los parches antes de aplicarlos en producción, evitando interrupciones operativas. Se aconseja configurar alertas automáticas de temperatura, uso de CPU y espacio en disco en el Servidor Dell para anticipar fallas de hardware. Es conveniente revisar trimestralmente la configuración de VLANs en el Switch Cisco Catalyst 9200 (ACT-INT-010) para verificar que la segmentación de red siga siendo efectiva.

Procedimiento:

1. Cada lunes, el Responsable de TI ejecuta el escáner de vulnerabilidades (OpenVAS o Nessus) sobre el Servidor Dell y genera el reporte **IC-SGSI-INF-03** (Reporte Semanal de Vulnerabilidades).
2. Los CVEs identificados se clasifican por severidad consultando la Base de Datos CVE MITRE (ACT-EXT-012): Crítico (parchear en 24h), Alto (parchear en 72h), Medio (parchear en 7 días), Bajo (planificar en el próximo ciclo mensual).
3. El Responsable de TI aplica los parches primero en el entorno de staging. Si no hay incidencias en 4 horas, los aplica en producción dentro de la ventana de mantenimiento establecida (domingos de 22:00 a 02:00 horas).
4. El resultado se documenta en el formulario **IC-SGSI-INF-04** (Registro de Aplicación de Parches) con fecha, versión anterior, versión actualizada y firma del Responsable de TI.
5. Mensualmente, el Responsable de TI verifica físicamente el estado del UPS APC (ACT-INT-011) y registra el nivel de batería y tiempo de autonomía estimado.

Línea Base:

- 0 vulnerabilidades críticas pendientes de parcheo con más de 24 horas de antigüedad.
- 100% de parches críticos documentados en IC-SGSI-INF-04.
- Acceso físico al cuarto de servidores restringido a máximo 2 personas autorizadas.
- Escaneo de vulnerabilidades ejecutado al menos una vez por semana con evidencia documentada.

POLÍTICA 04 — Gestión y Control de Activos de Información

Activos relacionados: ACT-INT-019 (Inventario TI), ACT-INT-004 (Laptops HP), ACT-INT-005 (Tablets Samsung), ACT-INT-008 (Manual ISO), ACT-INT-017 (Caja Fuerte)

Riesgo que mitiga: Pérdida accidental de logs de auditoría (nivel BAJO, valor 4); trazabilidad general del SGSI

Estándar (obligatorio): Todos los activos de información de ISL deben estar identificados, codificados, registrados en el inventario de activos (ACT-INT-019) y asignados a un propietario responsable. Ningún activo puede ser dado de alta, modificado o dado de baja sin actualizar el inventario. El uso de los activos tecnológicos de ISL está restringido exclusivamente a fines laborales. El retiro definitivo de cualquier activo debe incluir la destrucción certificada de la información que contenga antes de su disposición final.

Directriz (recomendado): Se recomienda realizar un inventario físico de activos de hardware al menos una vez por semestre para detectar activos no registrados o en condición de deterioro. Se aconseja asignar etiquetas físicas con el código de activo (ACT-INT-XXX) a cada equipo para facilitar su identificación en auditorías. Es conveniente mantener una copia del inventario en formato offline en la Caja Fuerte SentrySafe (ACT-INT-017) como medida de continuidad.

Procedimiento:

1. Al recibir un nuevo activo, el Responsable de TI asigna el código correspondiente (ACT-INT-XXX o ACT-EXT-XXX), completa la ficha del activo en el inventario (ACT-INT-019) e instala la etiqueta física de identificación.
2. El Responsable de TI configura el activo según los estándares de seguridad: cifrado de disco activado (BitLocker para laptops, cifrado nativo para tablets), antivirus instalado y actualizado, y VPN configurada para acceso remoto.
3. El colaborador que recibe el activo firma el formulario **IC-SGSI-ACT-01** (Resguardo de Activo Tecnológico), aceptando su responsabilidad sobre el uso adecuado y la devolución en buen estado.
4. Ante la pérdida, robo o daño de un activo, el colaborador notifica al Responsable de TI en máximo 2 horas. El Responsable de TI ejecuta el borrado remoto (MDM) si aplica y registra el incidente.

5. Al dar de baja un activo, el Responsable de TI ejecuta el borrado seguro de datos (mínimo 3 pasadas) y documenta el proceso en el formulario **IC-SGSI-ACT-02** (Retiro y Destrucción de Activos).

Línea Base:

- 100% de activos de TI registrados en el inventario ACT-INT-019 con código, propietario y estado actualizados.
- 100% de laptops con BitLocker activo y 100% de tablets con cifrado de dispositivo habilitado.
- 0 activos dados de baja sin evidencia de destrucción segura de datos documentada.
- Inventario físico ejecutado al menos una vez por semestre con reporte al Director General.

POLÍTICA 05 — Seguridad en Dispositivos Móviles y Trabajo en Campo

Activos relacionados: ACT-INT-005 (Tablets Samsung), ACT-INT-018 (YubiKey), ACT-EXT-007 (VPN IPsec), ACT-EXT-019 (Red Móvil 5G) **Riesgo que mitiga:** Robo o extravío de tablets en campo (nivel MUY ALTO, valor 16)

Estándar (obligatorio): Todos los dispositivos móviles utilizados por los inspectores en campo deben tener habilitado el cifrado de disco completo, bloqueo automático por inactividad (máximo 5 minutos), PIN de acceso de mínimo 8 caracteres y software MDM activo con capacidad de borrado remoto. Ningún inspector puede almacenar información del cliente en el dispositivo móvil más allá de lo estrictamente necesario para la inspección en curso. Al terminar cada jornada de campo, los datos capturados deben sincronizarse con el servidor central vía VPN antes de las 20:00 horas.

Directriz (recomendado): Se recomienda que los inspectores no utilicen redes Wi-Fi públicas o de los clientes para sincronizar datos; deben usar exclusivamente la red móvil 5G (ACT-EXT-019) con VPN activa. Se aconseja activar la función de localización GPS de las tablets para facilitar la recuperación en caso de extravío. Es conveniente realizar simulacros semestrales de borrado remoto para verificar que el MDM funciona correctamente antes de necesitarlo en una situación real.

Procedimiento:

1. Antes de cada salida a campo, el Supervisor de Inspección verifica que la tablet asignada tenga: batería mayor al 80%, VPN configurada y funcional, cifrado de disco activo y sincronización pendiente en cero.
2. Durante la inspección, el inspector captura datos exclusivamente en la App Inspección SL (ACT-INT-006) y no en aplicaciones personales o de terceros no autorizadas.

3. Al concluir la jornada en campo, el inspector activa la VPN mediante el cliente IPsec y ejecuta la sincronización automática con el servidor central (ACT-INT-003). Confirma al Supervisor que la sincronización fue exitosa.
4. En caso de extravío o robo del dispositivo, el inspector notifica al Supervisor de forma inmediata (máximo 30 minutos tras detectar la pérdida). El Supervisor escala al Responsable de TI, quien ejecuta el borrado remoto vía MDM dentro de la hora siguiente y registra el incidente.
5. El Responsable de TI verifica semanalmente que el 100% de los dispositivos móviles tienen el agente MDM activo y reporta al Gerente de Operaciones.

Línea Base:

- 100% de tablets con MDM activo, cifrado habilitado y sincronización diaria verificada.
 - Tiempo máximo de notificación ante pérdida de dispositivo: 30 minutos.
 - Tiempo máximo de ejecución de borrado remoto desde la notificación: 60 minutos.
 - 0 dispositivos de campo sin agente MDM activo en la verificación semanal.
-

POLÍTICA 06 — Seguridad en Servicios y Proveedores Externos

Activos relacionados: ACT-EXT-001 (AWS EC2), ACT-EXT-002 (HostGator), ACT-EXT-004 (Telmex), ACT-EXT-005 (Microsoft 365), ACT-EXT-006 (SSL Digicert), ACT-EXT-013 (Stripe) **Riesgo que mitiga:** Dependencia de proveedores externos críticos sin evaluación formal de riesgos

Estándar (obligatorio): Todos los servicios tecnológicos externos que procesen, almacenen o transmitan información de ISL o de sus clientes deben ser evaluados formalmente antes de su contratación y de forma anual durante su vigencia. Los contratos con proveedores críticos deben incluir cláusulas de seguridad de la información, niveles de servicio (SLA) definidos y el derecho de ISL a realizar auditorías. Ningún proveedor externo puede acceder a sistemas internos de ISL sin autorización previa documentada y con acceso temporal y monitoreado.

Directriz (recomendado): Se recomienda priorizar proveedores con certificaciones de seguridad reconocidas (ISO 27001, SOC 2) al momento de evaluar nuevas contrataciones. Se aconseja mantener siempre un proveedor alternativo identificado para los servicios más críticos (conectividad, correo electrónico, almacenamiento en nube) para reducir la dependencia de un único proveedor. Es conveniente revisar anualmente los Acuerdos de Nivel de Servicio (SLA) para verificar que siguen alineados con las necesidades operativas de ISL.

Procedimiento:

1. Antes de contratar un nuevo servicio externo, el Responsable de TI completa el formulario **IC-SGSI-PROV-01** (Evaluación de Riesgo de Proveedor), calificando al proveedor en criterios de seguridad, disponibilidad y cumplimiento normativo.
2. El Director General aprueba la contratación solo si la evaluación supera el umbral mínimo establecido (70/100 puntos en el formulario IC-SGSI-PROV-01).
3. El contrato de servicio incluye obligatoriamente las cláusulas de seguridad estándar de ISL (confidencialidad, notificación de incidentes en máximo 24 horas, derecho a auditoría).
4. El Responsable de TI realiza una evaluación anual de cada proveedor crítico usando el formulario IC-SGSI-PROV-01 actualizado y presenta los resultados al Director General.
5. Si un proveedor incumple los requisitos de seguridad, el Gerente de Operaciones inicia el proceso de búsqueda de alternativa en un plazo máximo de 30 días.

Línea Base:

- 100% de proveedores críticos con evaluación IC-SGSI-PROV-01 completada y vigente.
- 100% de contratos con proveedores de servicios en nube con cláusulas de seguridad incluidas.
- Evaluación anual de proveedores ejecutada y documentada para el 100% de los servicios listados en la Sección 4.3.
- 0 accesos de proveedores externos a sistemas internos sin autorización documentada.

POLÍTICA 07 — Gestión de Incidentes de Seguridad de la Información

Activos relacionados: Todos los activos (ACT-INT-001 a ACT-EXT-020) **Riesgo que mitiga:** Infección por phishing al personal administrativo (nivel ALTO, valor 12); todos los riesgos identificados en Sección 10

Estándar (obligatorio): Todo evento o incidente de seguridad de la información, sin importar su aparente severidad, debe ser reportado al Responsable de TI en un plazo máximo de 2 horas desde su detección. Ningún colaborador puede intentar resolver un incidente de seguridad por su cuenta sin notificar primero al Responsable de TI. Todos los incidentes deben quedar registrados en el sistema de tickets de soporte con su clasificación, impacto estimado, acciones tomadas y lección aprendida.

Directriz (recomendado): Se recomienda establecer un canal de comunicación de emergencias exclusivo para incidentes de seguridad (grupo de WhatsApp Business con el Responsable de TI, Gerente de Operaciones y Director General) para garantizar la notificación inmediata fuera del horario laboral. Se aconseja realizar simulacros de incidentes semestrales para entrenar al personal en la identificación y reporte correcto de

eventos de seguridad. Es conveniente revisar y actualizar el Plan de Respuesta a Incidentes al menos una vez al año.

Procedimiento:

1. El colaborador que detecta un posible incidente (correo sospechoso, dispositivo con comportamiento anómalo, acceso no autorizado detectado) lo reporta al Responsable de TI mediante ticket de soporte o mensaje directo en el grupo de emergencias.
2. El Responsable de TI clasifica el incidente según su severidad en el formulario **IC-SGSI-INC-01** (Registro de Incidente de Seguridad): **Crítico** (impacto en operación inmediata), **Alto** (riesgo de propagación), **Medio** (afectación parcial) o **Bajo** (sin impacto operativo inmediato).
3. Para incidentes Críticos y Altos, el Responsable de TI notifica al Director General en máximo 30 minutos y activa el protocolo de contención correspondiente (aislamiento de red, borrado remoto, cambio de credenciales).
4. El Responsable de TI documenta las acciones de contención, erradicación y recuperación en el formulario IC-SGSI-INC-01 con timestamps de cada acción.
5. Dentro de los 5 días hábiles posteriores al cierre del incidente, el Responsable de TI elabora el **Informe Post-Mortem** (IC-SGSI-INC-02) con análisis de causa raíz, costo estimado (tiempo y recursos) y acciones correctivas para evitar recurrencia.

Línea Base:

- Tiempo máximo de reporte de incidente desde su detección: 2 horas.
- 100% de incidentes registrados en IC-SGSI-INC-01 con clasificación de severidad asignada.
- 100% de incidentes Críticos y Altos con Informe Post-Mortem IC-SGSI-INC-02 elaborado dentro de los 5 días hábiles siguientes al cierre.
- Simulacro de incidente ejecutado al menos una vez por semestre con evidencia documentada.

POLÍTICA 08 — Continuidad del Negocio y Respaldo de Información

Activos relacionados: ACT-INT-009 (Discos WD), ACT-INT-020 (BCP v2.1), ACT-INT-003 (Servidor Dell), ACT-INT-011 (UPS APC), ACT-EXT-001 (AWS EC2) **Riesgo que mitiga:** Pérdida accidental de logs de auditoría (nivel BAJO, valor 4); garantía de disponibilidad general

Estándar (obligatorio): ISL debe mantener en todo momento la capacidad de recuperar sus operaciones críticas ante cualquier evento disruptivo (falla de hardware, ransomware, desastre físico o corte eléctrico prolongado). La estrategia de respaldo obligatoria sigue la **Regla 3-2-1:** 3 copias de los datos, en 2 medios distintos (servidor local y nube AWS), con

1 copia fuera de línea (discos WD en Caja Fuerte SentrySafe). Los respaldos deben ejecutarse de forma automatizada y su integridad debe verificarse mediante prueba de restauración al menos una vez por mes.

Directriz (recomendado): Se recomienda documentar el Tiempo de Recuperación Objetivo (RTO) y el Punto de Recuperación Objetivo (RPO) para cada servicio crítico: RTO máximo de 4 horas para el servidor central, RPO máximo de 24 horas para la base de datos de clientes. Se aconseja mantener el BCP v2.1 (ACT-INT-020) con una copia física en la Caja Fuerte y una copia digital accesible desde un dispositivo independiente (tablet personal del Director General) para garantizar su disponibilidad durante una crisis cuando los sistemas principales no estén operativos.

Procedimiento:

1. El Responsable de TI configura los respaldos automáticos diarios de la base de datos SQL Server y los repositorios de reportes hacia la instancia AWS EC2 (ACT-EXT-001), programados para las 02:00 horas cuando la carga del sistema es mínima.
2. Cada viernes, el Responsable de TI realiza una copia incremental en los discos externos WD My Passport (ACT-INT-009) y los resguarda en la Caja Fuerte SentrySafe (ACT-INT-017). Registra el proceso en el formulario **IC-SGSI-BCP-01** (Registro Semanal de Respaldo Offline).
3. El primer lunes de cada mes, el Responsable de TI ejecuta una prueba de restauración usando el respaldo más reciente en un ambiente de prueba y documenta el resultado en el formulario **IC-SGSI-BCP-02** (Prueba de Restauración de Respaldo).
4. Si la prueba de restauración falla, el Responsable de TI escala inmediatamente al Director General y ejecuta el protocolo de revisión del sistema de respaldo dentro de las 4 horas siguientes.
5. El BCP v2.1 (ACT-INT-020) se revisa y actualiza al menos una vez al año o tras cualquier cambio significativo en la infraestructura tecnológica de ISL.

Línea Base:

- 100% de respaldos automáticos diarios ejecutados sin error, verificados en el log de backup cada lunes.
- Prueba de restauración exitosa ejecutada al menos una vez por mes con evidencia en IC-SGSI-BCP-02.
- Copia offline en discos WD actualizada y resguardada en Caja Fuerte cada viernes.
- RTO máximo de 4 horas y RPO máximo de 24 horas documentados y probados al menos una vez al año.

Activos relacionados: ACT-INT-001 (BD Clientes), ACT-INT-002 (Certificados PDF), ACT-INT-005 (Tablets Samsung), ACT-INT-006 (App Inspección SL), ACT-INT-017 (Caja Fuerte) **Riesgo que mitiga:** Fuga de información del cliente (nivel Severo en matriz de impacto); incumplimiento de NDAs

Estándar (obligatorio): Toda la información proporcionada por los clientes de ISL (planos industriales, diseños CAD, criterios de aceptación/rechazo, especificaciones técnicas y acuerdos de confidencialidad) se clasifica automáticamente como **Confidencial** —

Propiedad del Cliente desde el momento de su recepción. Esta información solo puede ser accedida por el personal autorizado para la inspección específica, nunca puede compartirse con terceros sin autorización escrita del cliente y debe eliminarse o devolverse al cliente al término del contrato según lo estipulado en el NDA correspondiente.

Directriz (recomendado): Se recomienda crear en el Servidor Dell (ACT-INT-003) una carpeta exclusiva por cliente con permisos de acceso restringidos en Active Directory (ACT-INT-007), garantizando que el inspector asignado solo vea la información del cliente con el que trabaja. Se aconseja no imprimir planos técnicos del cliente salvo que sea estrictamente necesario para la ejecución de la inspección; en ese caso, los documentos impresos deben destruirse con destructora al término del trabajo.

Procedimiento:

1. Al recibir información del cliente, el Gerente de Operaciones registra la recepción en el formulario **IC-SGSI-CLI-01** (Registro de Recepción de Información del Cliente) indicando: nombre del cliente, descripción de la información, formato (digital/físico), nivel de confidencialidad declarado por el cliente y plazo de retención acordado en el NDA.
2. El Responsable de TI crea la carpeta del cliente en el Servidor Dell con permisos de acceso restringidos solo al personal asignado al proyecto y configura la trazabilidad de accesos en el log de Active Directory.
3. El Gerente de Operaciones asigna los planos y criterios técnicos al inspector correspondiente a través de la App Inspección SL (ACT-INT-006), que registra automáticamente quién accedió a qué información y cuándo.
4. Al concluir el contrato, el Gerente de Operaciones notifica al Responsable de TI para ejecutar el proceso de cierre: archivo o eliminación de la información del cliente según el NDA, actualización del formulario IC-SGSI-CLI-01 con la fecha de cierre y el método de disposición final.
5. Si se detecta un acceso no autorizado a información de cliente, se activa inmediatamente la Política 07 (Gestión de Incidentes) y se notifica al cliente afectado dentro de las 24 horas siguientes.

Línea Base:

- 100% de información de clientes registrada en IC-SGSI-CLI-01 antes de su almacenamiento en el servidor.
 - 0 accesos a información de clientes sin registro en el log de Active Directory.
 - 100% de contratos con cláusula de confidencialidad (NDA) firmada antes del inicio del servicio.
 - 100% de cierres de contrato con evidencia documentada de disposición final de información del cliente.
-

POLÍTICA 10 — Concientización, Capacitación y Cumplimiento del SGSI

Activos relacionados: ACT-INT-015 (PSI-2026), ACT-INT-016 (Certificaciones del Personal), ACT-INT-008 (Manual ISO), ACT-EXT-005 (Microsoft 365 — Teams) **Riesgo que mitiga:** Infección por phishing al personal administrativo (nivel ALTO, valor 12); error humano general

Estándar (obligatorio): Todo colaborador de ISL, sin excepción, debe completar el programa de inducción al SGSI dentro de los primeros 5 días hábiles tras su incorporación a la empresa. La capacitación anual en seguridad de la información es obligatoria para los 23 colaboradores. Ningún colaborador puede operar activos de información de ISL sin haber acreditado el examen de conocimientos básicos del SGSI con una calificación mínima de 80/100. El incumplimiento de las políticas de seguridad por parte de cualquier colaborador está sujeto a las medidas disciplinarias establecidas en el reglamento interno de ISL.

Directriz (recomendado): Se recomienda complementar la capacitación formal con comunicaciones periódicas de seguridad (boletines mensuales, alertas ante amenazas activas detectadas en el feed AlienVault OTX ACT-EXT-011) para mantener la cultura de seguridad viva entre las sesiones anuales. Se aconseja utilizar simulacros de phishing trimestrales para medir la resiliencia del personal ante ataques de ingeniería social y reforzar el entrenamiento en las áreas con mayor tasa de clics en correos de prueba.

Procedimiento:

1. El Responsable de TI, con apoyo del Gerente de Operaciones, diseña el programa anual de capacitación en seguridad con al menos los siguientes módulos: Política General del SGSI y sus responsabilidades, uso seguro de dispositivos (laptops y tablets), identificación y reporte de intentos de phishing, manejo seguro de información del cliente, y procedimiento de reporte de incidentes.
2. Las sesiones de capacitación se registran en las listas de asistencia **IC-SGSI-CAP-01**. Cada colaborador firma su asistencia y completa el examen de acreditación al finalizar la sesión.
3. El Responsable de TI ejecuta simulacros de phishing trimestrales usando una plataforma de simulación. Los resultados (tasa de clics, reportes correctos) se

documentan en el formulario **IC-SGSI-CAP-02** (Resultado de Simulacro de Phishing) y se presentan al Director General.

4. Los colaboradores que hagan clic en el correo de prueba reciben una sesión de refuerzo individualizada dentro de los 3 días hábiles siguientes al simulacro.
5. El Responsable de TI mantiene el registro actualizado de las acreditaciones vigentes de cada colaborador en el inventario de competencias (IC-SGSI-CAP-03) y alerta al Gerente de Operaciones cuando alguna certificación está próxima a vencer.

Línea Base:

- 100% de colaboradores con inducción al SGSI completada y acreditada dentro de los primeros 5 días hábiles de incorporación.
- 100% de colaboradores con capacitación anual acreditada con calificación mínima de 80/100.
- Tasa de clics en simulacros de phishing menor al 5% (meta establecida en la Sección 12).
- Simulacro de phishing ejecutado al menos una vez por trimestre con reporte IC-SGSI-CAP-02 documentado.

8.3 Matriz RACI — Políticas del SGSI

8.3.1 Definición de Roles RACI

Rol	Símbolo	Significado	Titular en ISL
Responsible	R	Quien ejecuta la tarea directamente y es responsable de su realización	Responsable de TI, Supervisores de Inspección, Coordinador Administrativo
Accountable	A	Autoridad final que rinde cuentas del resultado; aprueba o rechaza. Solo puede haber un A por tarea	Director General, Gerente de Operaciones
Consulted	C	Aporta conocimiento o criterio antes de que se tome la decisión o se ejecute la tarea; comunicación bidireccional	Responsable de TI, Gerente de Operaciones
Informed	I	Recibe notificación del resultado o del avance; comunicación unidireccional	Todo el personal, Coordinador Administrativo, Cuerpo de Inspectores

8.3.2 Tabla RACI — Políticas de Seguridad ISL

<i>Política</i>	<i>Director General</i>	<i>Gerente de Operaciones</i>	<i>Responsable de TI</i>	<i>Supervisores de Inspección</i>	<i>Cuerpo de Inspectores</i>	<i>Coordinador Administrativo</i>
POL-01 <i>Gestión de Accesos e Identidades</i>	A	C	R	I	I	I
POL-02 <i>Clasificación y Protección de la Información</i>	A	R	C	I	I	C
POL-03 <i>Seguridad de la Infraestructura Tecnológica</i>	A	I	R	I	I	I
POL-04 <i>Gestión y Control de Activos de Información</i>	A	C	R	C	I	I
POL-05 <i>Seguridad en Dispositivos Móviles y Campo</i>	A	A	C	R	R	I
POL-06 <i>Seguridad en Servicios y Proveedores Externos</i>	A	C	R	I	I	C
POL-07 <i>Gestión de Incidentes de Seguridad</i>	A	C	R	C	I	I

POL-08 <i>Continuidad del Negocio y Respaldo</i>	A	C	R	I	I	I
POL-09 <i>Clasificación y Manejo de Información del Cliente</i>	A	R	C	I	I	I
POL-10 <i>Concientización, Capacitación y Cumplimiento</i>	A	C	R	C	I	I

8.3.3 Lectura de la Matriz RACI por Rol

Director General: Es el **Accountable (A)** de todas las políticas del SGSI. Esto refleja que la seguridad de la información es una responsabilidad de la Alta Dirección. No ejecuta directamente ninguna política (ese rol corresponde a los responsables operativos), pero aprueba, revisa y rinde cuentas ante clientes, auditores y entes reguladores sobre el cumplimiento del sistema.

Gerente de Operaciones: Es **Accountable (A)** compartido en la POL-05 (dado que los inspectores son su equipo directo) y **Responsible (R)** en POL-02 y POL-09, que son las políticas que afectan directamente el ciclo operativo del servicio de inspección. Es **Consulted (C)** en las políticas técnicas donde su criterio operativo es necesario pero la ejecución es de TI.

Responsable de TI: Es **Responsible (R)** en la mayoría de las políticas técnicas (POL-01, POL-03, POL-04, POL-06, POL-07, POL-08, POL-10), siendo el ejecutor principal del SGSI. Es **Consulted (C)** en políticas operativas donde aporta criterio técnico pero la responsabilidad de ejecución recae en Operaciones.

Supervisores de Inspección: Son **Responsible (R)** en POL-05, siendo los ejecutores directos de los controles de seguridad en campo. Son **Consulted (C)** en políticas que afectan directamente a su equipo de inspectores.

Cuerpo de Inspectores: Son **Responsible (R)** en POL-05 para la ejecución de los procedimientos de campo y son **Informed (I)** en las demás políticas, recibiendo comunicación de las actualizaciones y cumpliendo lo establecido.

Coordinador Administrativo: Es **Consulted (C)** en POL-02 y POL-06 por su conocimiento de los procesos de facturación y contratación. Es **Informed (I)** en las demás políticas para garantizar la alineación de los procesos administrativos con el SGSI.

9. PLANIFICACIÓN — EVALUACIÓN Y TRATAMIENTO DE RIESGOS

9.1 Metodología de Evaluación de Riesgos

9.1.1 Marco Metodológico

La evaluación de riesgos del presente SGSI se fundamenta en los lineamientos de la norma **ISO/IEC 27005:2022** (*Information security, cybersecurity and privacy protection — Guidance on managing information security risks*), adoptando un enfoque cuantitativo basado en la multiplicación de dos variables: **Probabilidad** e **Impacto**.

Fórmula de cálculo:

$$\text{Nivel de Riesgo} = \text{Probabilidad (P)} \times \text{Impacto (I)}$$

Los riesgos evaluados están directamente vinculados a los activos de información inventariados en la Sección 4 de este documento (ACT-INT-001 a ACT-INT-020 y ACT-EXT-001 a ACT-EXT-020), garantizando que ningún riesgo identificado esté desconectado del inventario de activos de ISL.

9.1.2 Escala de Probabilidad

Valor	Nivel	Criterio de interpretación para ISL
5	Casi Seguro	Se espera que ocurra en la mayoría de las circunstancias; ha ocurrido antes en ISL o en empresas del mismo sector, o las condiciones actuales lo hacen prácticamente inevitable sin controles
4	Probable	Existe evidencia de que podría ocurrir; las condiciones de operación de ISL (trabajo en campo, dispositivos móviles, acceso remoto) lo hacen frecuente
3	Moderado	Podría ocurrir en algún momento; no hay evidencia directa pero el contexto de ISL lo hace posible
2	Poco Probable	No se ha presentado en ISL; requeriría condiciones específicas o inusuales para materializarse
1	Raro	Ocurriría solo en circunstancias excepcionales; muy poco común incluso en el sector industrial

9.1.3 Escala de Impacto

Valor	Nivel	Criterio de interpretación para ISL
5	Severo	Consecuencias catastróficas: pérdida de clientes clave, cierre de operaciones, demandas legales, daño reputacional irreparable o pérdida total de datos sin posibilidad de recuperación
4	Mayor	Consecuencias graves: incumplimiento contractual con clientes Tier 1/Tier 2, pérdida económica significativa, interrupción prolongada del servicio (más de 24 horas) o violación grave de NDAs
3	Significativo	Consecuencias moderadas: interrupción parcial del servicio, retrabajo extenso, pérdida de información recuperable, daño a la relación con clientes específicos
2	Menor	Consecuencias leves: retrasos en la entrega de reportes, retrabajo puntual, afectación a procesos no críticos, recuperable en menos de 4 horas
1	Insignificante	Consecuencias despreciables: incomodidad operativa menor, sin afectación al servicio al cliente ni a la información confidencial

9.1.4 Clasificación del Nivel de Riesgo

Valor del Riesgo	Clasificación	Color de referencia	Acción requerida
20 – 25	EXTREMO	☐ Rojo	Acción inmediata obligatoria; escalar a Dirección General
12 – 19	MUY ALTO	☐ Naranja	Tratamiento prioritario en menos de 30 días
8 – 11	ALTO	☐ Amarillo oscuro	Tratamiento planificado en menos de 90 días
4 – 7	MEDIO	☐ Amarillo	Monitoreo activo; tratar en el siguiente ciclo de planificación
1 – 3	BAJO	☐ Verde	Aceptable; documentar y revisar anualmente

9.2 Matriz de Evaluación y Tratamiento de Riesgos

La matriz se presenta en dos partes complementarias que comparten el mismo identificador de riesgo (RGS-XX) para facilitar la lectura e integración en el documento.

PARTE A — Identificación y Valoración de Riesgos

RGS-01

Campo	Detalle
ID del Riesgo	RGS-01
Nombre del Riesgo	Acceso no autorizado a reportes confidenciales vía VPN/AD
Amenaza	Atacante externo o interno que explota credenciales comprometidas para acceder a los sistemas de ISL sin autorización
Vulnerabilidad	Ausencia de autenticación multifactor (MFA) en el acceso remoto por VPN y falta de revisión periódica de privilegios en Active Directory
Activo(s) Afectado(s)	ACT-INT-007 (Active Directory), ACT-EXT-007 (VPN IPsec), ACT-INT-001 (BD Clientes), ACT-INT-002 (Certificados PDF)
Consecuencia	Acceso total a reportes de inspección y datos de clientes, incumplimiento masivo de NDAs, pérdida de clientes Tier 1 y Tier 2, sanciones legales y daño reputacional irreparable
Justificación de Probabilidad	Valor 5 — Casi Seguro: actualmente no existe MFA implementado en el acceso VPN; las credenciales son el único control de acceso remoto, lo que hace prácticamente inevitable una brecha ante un ataque de phishing exitoso
Probabilidad (P)	5

Impacto (I) 5

Valor del Riesgo 25

Clasificación ☐ EXTREMO

RGS-02

Campo	Detalle
ID del Riesgo	RGS-02
Nombre del Riesgo	Robo o extravío de tablets de inspectores en campo
Amenaza	Robo físico o extravío accidental de dispositivos móviles durante operaciones en instalaciones industriales de clientes
Vulnerabilidad	Los inspectores operan en entornos industriales externos de alto tráfico sin custodia permanente de sus dispositivos; ausencia de cifrado de disco y borrado remoto configurados
Activo(s) Afectado(s)	ACT-INT-005 (Tablets Samsung Galaxy Tab Active4 Pro), ACT-INT-006 (App Inspección SL), información técnica del cliente almacenada temporalmente en el dispositivo
Consecuencia	Exposición de planos técnicos y criterios de inspección del cliente, pérdida de evidencia fotográfica de inspecciones en curso, acceso no autorizado a la red interna de ISL si las credenciales VPN almacenadas se ven comprometidas, incumplimiento de NDAs

Justificación de Probabilidad	Valor 4 — Probable: los inspectores realizan múltiples salidas semanales a plantas industriales; la probabilidad de extravío o robo en estos entornos es estadísticamente alta sin controles MDM activos
Probabilidad (P)	4
Impacto (I)	4
Valor del Riesgo	16
Clasificación	☐ MUY ALTO

RGS-03

Campo	Detalle
ID del Riesgo	RGS-03
Nombre del Riesgo	Uso de software desactualizado en servidores con CVEs activos
Amenaza	Atacante externo que explota vulnerabilidades conocidas (CVEs publicados) en versiones de software sin parches aplicados en el Servidor Dell PowerEdge T550
Vulnerabilidad	Ausencia de un proceso formal de gestión de parches y ventana de mantenimiento establecida; posible software EOL (End of Life) sin soporte del fabricante

Activo(s) Afectado(s)	ACT-INT-003 (Servidor Dell PowerEdge T550), ACT-INT-001 (BD Clientes SQL Server 2022), ACT-INT-007 (Active Directory)
Consecuencia	Compromiso total del servidor central, acceso no autorizado a toda la base de datos de clientes, posible instalación de ransomware que cifre todos los datos operativos, paro total de operaciones por tiempo indeterminado
Justificación de Probabilidad	Valor 5 — Casi Seguro: sin un proceso de parcheo formal documentado, la acumulación de CVEs críticos no parcheados es prácticamente inevitable en el tiempo; los servidores expuestos a internet son objetivo frecuente de escaneos automatizados
Probabilidad (P)	5
Impacto (I)	3
Valor del Riesgo	15
Clasificación	☐ MUY ALTO

RGS-04

Campo	Detalle
ID del Riesgo	RGS-04
Nombre del Riesgo	Ataque de ransomware a la infraestructura central de ISL

Amenaza	Grupo de ciberdelincuentes que despliega ransomware mediante phishing, RDP expuesto o vulnerabilidades del servidor, cifrando todos los datos operativos de ISL
Vulnerabilidad	Ausencia de segmentación de red efectiva entre equipos de usuarios y servidor; falta de respaldos offline verificados y plan de respuesta a ransomware documentado
Activo(s) Afectado(s)	ACT-INT-003 (Servidor Dell), ACT-INT-001 (BD Clientes), ACT-INT-002 (Certificados PDF), ACT-INT-004 (Laptops HP), ACT-INT-009 (Discos WD)
Consecuencia	Cifrado de todos los datos operativos incluyendo histórico de inspecciones, imposibilidad de emitir reportes, parálisis total del negocio, extorsión económica, pérdida permanente de datos si no existen respaldos verificados
Justificación de Probabilidad	Valor 4 — Probable: el sector industrial manufacturero es objetivo frecuente de grupos de ransomware; la combinación de phishing (vector de entrada probable) y la ausencia de controles de segmentación de red aumenta significativamente la probabilidad
Probabilidad (P)	4
Impacto (I)	5
Valor del Riesgo	20
Clasificación	☐ EXTREMO

Campo	Detalle
ID del Riesgo	RGS-05
Nombre del Riesgo	Infección por phishing dirigido al personal administrativo
Amenaza	Campaña de spear phishing dirigida específicamente al personal administrativo de ISL, diseñada para robar credenciales o instalar malware
Vulnerabilidad	Personal sin capacitación formal en identificación de phishing; ausencia de filtros avanzados de correo electrónico y simulacros de entrenamiento
Activo(s) Afectado(s)	ACT-INT-004 (Laptops HP EliteBook), ACT-INT-007 (Active Directory), ACT-EXT-005 (Microsoft 365), ACT-INT-001 (BD Clientes)
Consecuencia	Robo de credenciales de acceso a sistemas internos, instalación de malware que sirva como punto de entrada persistente para el atacante, compromiso de correos corporativos con información confidencial de clientes
Justificación de Probabilidad	Valor 3 — Moderado: el phishing es el vector de ataque más común globalmente; sin capacitación formal el personal administrativo es un objetivo vulnerable, aunque no hay evidencia de ataques previos en ISL
Probabilidad (P)	3
Impacto (I)	4
Valor del Riesgo	12

Clasificación ☐ ALTO

RGS-06

Campo	Detalle
ID del Riesgo	RGS-06
Nombre del Riesgo	Interrupción del portal de clientes por falla en AWS EC2
Amenaza	Falla en la infraestructura del proveedor de nube AWS o mal configuración que deje inaccesible el portal donde los clientes descargan sus reportes
Vulnerabilidad	Dependencia de un único proveedor de nube sin plan de failover; ausencia de monitoreo automatizado de disponibilidad del portal
Activo(s) Afectado(s)	ACT-EXT-001 (Instancia AWS EC2 t3.medium), ACT-EXT-006 (Certificado SSL Digicert), ACT-INT-002 (Certificados PDF almacenados)
Consecuencia	Clientes sin acceso a sus reportes de inspección durante la interrupción, incumplimiento de plazos de entrega acordados en contratos, daño a la percepción del servicio y potencial incumplimiento de SLAs
Justificación de Probabilidad	Valor 3 — Moderado: AWS tiene alta disponibilidad pero las malas configuraciones por parte de ISL son posibles; sin monitoreo activo, el tiempo de detección y respuesta ante una caída puede ser largo
Probabilidad (P)	3

Impacto (I)	3
Valor del Riesgo	9
Clasificación	☐ ALTO

RGS-07

Campo	Detalle
ID del Riesgo	RGS-07
Nombre del Riesgo	Filtración de información confidencial del cliente en Microsoft 365
Amenaza	Colaborador interno que comparte por error documentos confidenciales del cliente a destinatarios no autorizados mediante correo electrónico o OneDrive
Vulnerabilidad	Ausencia de etiquetas de clasificación de sensibilidad en Microsoft 365; falta de políticas de prevención de pérdida de datos (DLP) configuradas en la plataforma
Activo(s) Afectado(s)	ACT-EXT-005 (Microsoft 365 Business Premium), ACT-INT-001 (BD Clientes), ACT-INT-002 (Certificados PDF), información de NDAs
Consecuencia	Exposición de planos técnicos, criterios de inspección o resultados confidenciales a competidores o terceros no autorizados, incumplimiento de NDAs firmados, posibles demandas legales por parte del cliente afectado

Justificación de Probabilidad	Valor 3 — Moderado: el error humano en el envío de correos es uno de los incidentes más frecuentes en empresas de servicios; sin controles DLP el riesgo es constante
Probabilidad (P)	3
Impacto (I)	4
Valor del Riesgo	12
Clasificación	☐ ALTO

RGS-08

Campo	Detalle
ID del Riesgo	RGS-08
Nombre del Riesgo	Acceso físico no autorizado al cuarto de servidores
Amenaza	Persona no autorizada (empleado de otro departamento, visitante, proveedor externo) que accede físicamente al cuarto de servidores y manipula o extrae hardware
Vulnerabilidad	Control de acceso biométrico como único mecanismo de protección física; ausencia de registro de visitas al cuarto de servidores y sin monitoreo de video dedicado al interior

Activo(s)
Afectado(s) ACT-INT-003 (Servidor Dell PowerEdge T550), ACT-INT-009 (Discos WD Respaldo), ACT-INT-010 (Switch Cisco), ACT-INT-013 (Lector Biométrico ZKTeco)

Consecuencia Robo o manipulación física del servidor, extracción de discos de almacenamiento con datos de clientes, instalación de dispositivos de escucha o captura de tráfico, sabotaje de la infraestructura de red

Justificación de Probabilidad Valor 2 — Poco Probable: existe el lector biométrico ZKTeco como control; sin embargo, visitas de proveedores técnicos sin supervisión adecuada representan un vector de riesgo residual

Probabilidad (P) 2

Impacto (I) 5

Valor del Riesgo 10

Clasificación ☐ ALTO

RGS-09

Campo	Detalle
ID del Riesgo	RGS-09
Nombre del Riesgo	Falla crítica del Servidor Dell PowerEdge T550

Amenaza	Falla de hardware (disco duro, fuente de poder, memoria RAM) que deje inoperativo el servidor central de ISL
Vulnerabilidad	Servidor físico único sin redundancia de hardware; dependencia total de un solo nodo para todos los servicios internos de ISL
Activo(s) Afectado(s)	ACT-INT-003 (Servidor Dell PowerEdge T550), ACT-INT-001 (BD Clientes), ACT-INT-007 (Active Directory), ACT-INT-002 (Certificados PDF)
Consecuencia	Interrupción total de operaciones internas, imposibilidad de acceder a datos históricos de inspecciones, paro en la emisión de reportes, tiempo de recuperación de 24 a 72 horas dependiendo de la disponibilidad de repuestos
Justificación de Probabilidad	Valor 2 — Poco Probable: el Servidor Dell PowerEdge T550 es hardware empresarial de alta confiabilidad; sin embargo, sin monitoreo de temperatura y estado de discos, una falla puede ser impredecible
Probabilidad (P)	2
Impacto (I)	5
Valor del Riesgo	10
Clasificación	☐ ALTO

RGS-10

Campo

Detalle

ID del Riesgo	RGS-10
Nombre del Riesgo	Secuestro o expiración del dominio inspeccionsl.com.mx
Amenaza	Atacante que ejecuta domain hijacking aprovechando credenciales de GoDaddy comprometidas, o expiración accidental del dominio por falta de renovación oportuna
Vulnerabilidad	Gestión del dominio centralizada en una sola cuenta de GoDaddy sin MFA habilitado; ausencia de alertas automáticas de vencimiento con suficiente anticipación
Activo(s) Afectado(s)	ACT-EXT-003 (Dominio inspeccionsl.com.mx), ACT-EXT-001 (AWS EC2 portal clientes), ACT-EXT-002 (Hosting HostGator), ACT-EXT-006 (Certificado SSL Digicert)
Consecuencia	Pérdida total del control sobre la identidad digital de ISL, redirección de clientes a sitios fraudulentos, interceptación de correos corporativos enviados al dominio, daño reputacional severo e inmediato
Justificación de Probabilidad	Valor 2 — Poco Probable: el secuestro de dominio requiere un ataque dirigido; sin embargo, la expiración accidental por falta de renovación es un riesgo operativo real en empresas pequeñas sin procesos formales
Probabilidad (P)	2
Impacto (I)	4
Valor del Riesgo	8
Clasificación	☐ MEDIO

RGS-11

Campo	Detalle
ID del Riesgo	RGS-11
Nombre del Riesgo	Error humano en configuración de repositorio GitHub
Amenaza	Colaborador del área de TI que configura accidentalmente el repositorio de código fuente como público, exponiendo el código y posibles credenciales embebidas
Vulnerabilidad	Ausencia de revisiones de seguridad del código (code review) antes de commits; posibilidad de credenciales o endpoints embebidos directamente en el código fuente
Activo(s) Afectado(s)	ACT-EXT-010 (Repositorio GitHub Plan Pro), ACT-INT-006 (Código Fuente App Inspección SL)
Consecuencia	Exposición pública del código fuente con lógica de negocio de ISL, filtración de credenciales de bases de datos o APIs embebidas en el código, posibilidad de que competidores o atacantes repliquen o exploten la aplicación
Justificación de Probabilidad	Valor 2 — Poco Probable: requiere un error específico de configuración; sin embargo, sin un proceso formal de revisión de permisos de repositorios es posible que ocurra inadvertidamente
Probabilidad (P)	2
Impacto (I)	4

Valor del Riesgo 8

Clasificación ☐ MEDIO

RGS-12

Campo	Detalle
ID del Riesgo	RGS-12
Nombre del Riesgo	Pérdida accidental de logs de auditoría e historial de incidentes
Amenaza	Eliminación accidental o corrupción de los registros de auditoría del Active Directory y del servidor por sobrescritura automática o falla de almacenamiento
Vulnerabilidad	Política de retención de logs no definida formalmente; logs almacenados únicamente en el servidor local sin respaldo independiente dedicado
Activo(s) Afectado(s)	ACT-INT-003 (Servidor Dell — logs del sistema), ACT-INT-007 (Active Directory — logs de auditoría), ACT-INT-009 (Discos WD Respaldo)
Consecuencia	Imposibilidad de reconstruir el historial de accesos ante una investigación de incidente, invalidación de la evidencia de auditoría interna, incumplimiento de los requisitos de trazabilidad de ISO/IEC 27001:2022
Justificación de Probabilidad	Valor 2 — Poco Probable: la pérdida de logs requiere condiciones específicas de falla; sin embargo, sin una política de retención y respaldo de logs definida, el riesgo de sobrescritura automática es real

Probabilidad (P) 2

Impacto (I) 2

Valor del Riesgo 4

Clasificación ☐ BAJO

PARTE B — Tratamiento de Riesgos

RGS-01 — Tratamiento

Campo	Detalle
ID del Riesgo	RGS-01
Opción de Tratamiento	MITIGAR
Plan de Tratamiento Detallado	Implementar autenticación multifactor (MFA) obligatoria mediante YubiKeys FIDO2 (ACT-INT-018) para todos los accesos administrativos al Active Directory y la VPN IPsec. Configurar políticas de acceso condicional en Active Directory que bloqueen automáticamente sesiones desde ubicaciones geográficas no reconocidas. Establecer revisión mensual de privilegios de usuario con el formulario IC-SGSI-ACC-01, eliminando cuentas inactivas en 48 horas. Activar alertas automáticas ante más de 3 intentos fallidos de autenticación en 5 minutos
Control Preventivo	Implementación de MFA obligatorio antes del acceso a cualquier sistema crítico vía VPN
Control	Alertas automáticas en el SIEM ante intentos de acceso fallidos repetidos;

Detectivo	revisión mensual de logs de autenticación del Active Directory
Control Correctivo	Bloqueo automático de cuentas comprometidas detectadas; revocación inmediata de credenciales y emisión de nuevas con MFA reconfigurado
Política Asociada	POL-01 — Gestión de Accesos e Identidades
Responsable	Responsable de TI
Fecha Límite	15 de junio de 2026

RGS-02 — Tratamiento

Campo	Detalle
ID del Riesgo	RGS-02
Opción de Tratamiento	MITIGAR
Plan de Tratamiento Detallado	Configurar software MDM (Mobile Device Management) en el 100% de las tablets Samsung (ACT-INT-005) con capacidad de borrado remoto activado, cifrado de disco completo habilitado y bloqueo automático tras 5 minutos de inactividad. Establecer procedimiento obligatorio de sincronización diaria de datos capturados en campo con el servidor central antes de las 20:00 horas vía VPN. Implementar política de no almacenamiento local de planos técnicos del cliente más allá de la jornada de trabajo en curso. Activar localización GPS de los dispositivos para facilitar la recuperación en caso de extravío

Control Preventivo	Cifrado de disco completo activo en todos los dispositivos; política de mínimo almacenamiento local de información del cliente
Control Detectivo	Consola MDM con monitoreo en tiempo real del estado de cifrado y agente de todos los dispositivos; alerta automática si un dispositivo pierde conectividad por más de 24 horas
Control Correctivo	Ejecución de borrado remoto vía MDM en máximo 60 minutos tras la notificación de extravío o robo; registro del incidente y notificación al cliente afectado si sus datos estaban en el dispositivo
Política Asociada	POL-05 — Seguridad en Dispositivos Móviles y Trabajo en Campo
Responsable	Responsable de TI / Supervisores de Inspección
Fecha Límite	30 de junio de 2026

RGS-03 — Tratamiento

Campo	Detalle
ID del Riesgo	RGS-03
Opción de Tratamiento	MITIGAR

Plan de Tratamiento Detallado	Establecer una ventana de mantenimiento semanal fija (domingos de 22:00 a 02:00 horas) para la aplicación de parches de seguridad críticos en el Servidor Dell (ACT-INT-003). Ejecutar escaneo semanal de vulnerabilidades con OpenVAS o Nessus referenciando la Base de Datos CVE MITRE (ACT-EXT-012). Clasificar CVEs por severidad: Crítico parchear en 24h, Alto en 72h, Medio en 7 días. Levantar un entorno de staging para probar parches antes de aplicarlos en producción. Documentar cada aplicación de parches en el formulario IC-SGSI-INF-04. Verificar versiones de SQL Server 2022 y sistemas operativos contra la Base de Datos CVE mensualmente
Control Preventivo	Proceso formal de gestión de parches con calendario definido; suscripción a alertas de seguridad del fabricante (Microsoft Security Response Center) para notificación inmediata de CVEs críticos
Control Detectivo	Escaneo semanal automatizado con OpenVAS; feed de inteligencia de amenazas AlienVault OTX (ACT-EXT-011) para detección temprana de exploits activos dirigidos a las versiones de software de ISL
Control Correctivo	Aplicación de parches de emergencia en máximo 24 horas para CVEs críticos; activación del Modo Búnker (aislamiento en VLAN) si el parche no puede aplicarse inmediatamente por incompatibilidad
Política Asociada	POL-03 — Seguridad de la Infraestructura Tecnológica
Responsable	Responsable de TI
Fecha Límite	1 de julio de 2026

RGS-04 — Tratamiento

Campo

Detalle

ID del Riesgo RGS-04

Opción de Tratamiento MITIGAR

Plan de Tratamiento Detallado Implementar la Regla 3-2-1 de respaldos: copia automática diaria al AWS EC2 (ACT-EXT-001), copia local en el Servidor Dell y copia offline semanal en los discos WD (ACT-INT-009) resguardados en la Caja Fuerte SentrySafe (ACT-INT-017). Configurar segmentación de red mediante VLANs en el Switch Cisco Catalyst 9200 (ACT-INT-010) para aislar el servidor de las estaciones de trabajo. Activar EDR (Endpoint Detection and Response) en todas las laptops. Establecer procedimiento de respuesta a ransomware: identificar, aislar el equipo afectado de la red inmediatamente, notificar al Responsable de TI y activar el BCP v2.1 (ACT-INT-020). Probar la restauración de respaldos mensualmente

Control Preventivo Segmentación de red mediante VLANs que limita la propagación lateral del ransomware; respaldos offline que garantizan la recuperación sin pago de rescate

Control Detectivo EDR en estaciones de trabajo que detecta comportamientos típicos de ransomware (cifrado masivo de archivos) y genera alerta inmediata; monitoreo de actividad anómala en el servidor vía SIEM

Control Correctivo Aislamiento inmediato del equipo afectado de la red; restauración desde el respaldo más reciente verificado; análisis forense post-incidente para identificar el vector de entrada

Política Asociada POL-08 — Continuidad del Negocio y Respaldo de Información

Responsable Responsable de TI

Fecha Límite 15 de julio de 2026

RGS-05 — Tratamiento

Campo	Detalle
ID del Riesgo	RGS-05
Opción de Tratamiento	MITIGAR
Plan de Tratamiento Detallado	Ejecutar programa de concientización obligatorio para los 23 colaboradores con módulo específico de identificación de phishing, simulacros trimestrales y sesiones de refuerzo individualizadas para quien haga clic en correos de prueba. Configurar filtros avanzados antiphishing en Microsoft 365 (ACT-EXT-005) con análisis de reputación de remitentes y sandboxing de adjuntos. Implementar el protocolo DMARC/DKIM/SPF en el dominio de correo de ISL para reducir la suplantación de identidad entrante. Meta: tasa de clics en simulacros menor al 5%
Control Preventivo	Capacitación formal en identificación de phishing; filtros antiphishing en Microsoft 365 configurados con política estricta de cuarentena para remitentes desconocidos
Control Detectivo	Simulacros trimestrales de phishing con medición de tasa de clics; alertas del sistema ante adjuntos maliciosos bloqueados en la plataforma de correo
Control Correctivo	Sesión de refuerzo individualizada en máximo 3 días hábiles para colaboradores que hagan clic en simulacros; aislamiento inmediato del equipo comprometido si se detecta infección real
Política Asociada	POL-10 — Concientización, Capacitación y Cumplimiento del SGSI
Responsable	Gerente de Operaciones / Responsable de TI

Fecha Límite 15 de agosto de 2026

RGS-06 — Tratamiento

Campo	Detalle
ID del Riesgo	RGS-06
Opción de Tratamiento	MITIGAR / TRANSFERIR
Plan de Tratamiento Detallado	Configurar monitoreo de disponibilidad del portal AWS EC2 (ACT-EXT-001) con alertas automáticas al Responsable de TI ante caídas superiores a 5 minutos (herramientas: UptimeRobot o AWS CloudWatch). Documentar el RTO máximo de 4 horas para el portal de clientes en el BCP v2.1. Revisar y mantener actualizado el contrato con AWS incluyendo SLA de disponibilidad del 99.9%. La porción de transferencia implica que AWS asume contractualmente la responsabilidad por la disponibilidad de la infraestructura subyacente mediante su SLA
Control Preventivo	Configuración de alertas proactivas de disponibilidad; revisión mensual del estado de la instancia EC2 y del certificado SSL Digicert (ACT-EXT-006)
Control Detectivo	Monitoreo automatizado 24/7 de disponibilidad del portal con notificación inmediata al Responsable de TI ante caída detectada
Control Correctivo	Protocolo de reinicio de instancia EC2 documentado en el BCP; comunicación proactiva a clientes afectados durante la interrupción con tiempo estimado de recuperación
Política Asociada	POL-06 — Seguridad en Servicios y Proveedores Externos

Responsable Responsable de TI

Fecha Límite 15 de julio de 2026

RGS-07 — Tratamiento

Campo	Detalle
ID del Riesgo	RGS-07
Opción de Tratamiento	MITIGAR
Plan de Tratamiento Detallado	Activar las etiquetas de sensibilidad de Microsoft 365 (Confidencial, Interno, Público) en todos los documentos y correos que contengan información de clientes. Configurar políticas DLP (Data Loss Prevention) en Microsoft 365 que bloqueen el envío externo de archivos clasificados como Confidencial sin aprobación del Gerente de Operaciones. Capacitar al personal en el uso correcto de las etiquetas de clasificación. Establecer como estándar que los reportes finales solo se compartan con clientes a través del portal seguro AWS, no por correo electrónico directo
Control Preventivo	Políticas DLP en Microsoft 365 que bloquean automáticamente el envío no autorizado de documentos confidenciales hacia dominios externos no aprobados
Control Detectivo	Alertas automáticas de Microsoft 365 ante intentos de compartir documentos clasificados como Confidencial fuera de la organización; revisión mensual del log de actividad de OneDrive
Control Correctivo	Notificación inmediata al cliente afectado si se detecta un envío no autorizado de su información; revisión del acceso del colaborador involucrado y acción

disciplinaria según reglamento interno

Política Asociada POL-02 — Clasificación y Protección de la Información / POL-09 — Manejo de Información del Cliente

Responsable Responsable de TI

Fecha Límite 1 de agosto de 2026

RGS-08 — Tratamiento

Campo	Detalle
ID del Riesgo	RGS-08
Opción de Tratamiento	MITIGAR
Plan de Tratamiento Detallado	Mantener el lector biométrico ZKTeco SpeedFace (ACT-INT-013) como control de acceso primario, restringido exclusivamente al Responsable de TI y al Director General. Implementar bitácora física de visitas al cuarto de servidores para registro de entradas con fecha, hora, motivo y firma. Todo proveedor técnico externo que requiera acceso al cuarto de servidores debe ser acompañado en todo momento por el Responsable de TI. Verificar mensualmente el correcto funcionamiento del lector biométrico y de las cámaras IP Hikvision (ACT-INT-012) que cubren el acceso al cuarto
Control Preventivo	Control biométrico de acceso físico restringido a 2 personas autorizadas; acompañamiento obligatorio de proveedores externos dentro del cuarto de servidores

Control Detectivo	Cámaras IP Hikvision 4K con grabación continua y detección de movimiento en el acceso al cuarto de servidores; revisión semanal de grabaciones ante cualquier evento inusual
Control Correctivo	Revisión forense del video ante cualquier incidente físico detectado; cambio inmediato de credenciales de todos los sistemas si se confirma acceso no autorizado al servidor
Política Asociada	POL-03 — Seguridad de la Infraestructura Tecnológica
Responsable	Responsable de TI
Fecha Límite	30 de junio de 2026

RGS-09 — Tratamiento

Campo	Detalle
ID del Riesgo	RGS-09
Opción de Tratamiento	MITIGAR

Plan de Tratamiento Detallado	Configurar monitoreo proactivo de hardware del Servidor Dell PowerEdge T550 (ACT-INT-003): alertas de temperatura, estado de discos (SMART), uso de CPU y memoria RAM mediante Dell OpenManage. Garantizar que los respaldos bajo la Regla 3-2-1 estén actualizados y verificados mensualmente para minimizar el RPO. Mantener contrato de soporte hardware vigente con Dell para garantizar tiempo de respuesta de reemplazo de componentes en máximo 4 horas (NBD - Next Business Day). Documentar el RTO de 4 horas para la restauración del servidor en el BCP v2.1 (ACT-INT-020)
Control Preventivo	Monitoreo proactivo de estado de hardware con alertas tempranas ante indicadores de fallo inminente; contrato de soporte Dell NBD para reemplazo rápido de componentes
Control Detectivo	Alertas automáticas de Dell OpenManage ante umbrales críticos de temperatura, errores de disco o fallos de memoria detectados antes de la falla total
Control Correctivo	Activación del BCP v2.1 ante falla del servidor; restauración desde el respaldo más reciente en AWS EC2 como infraestructura temporal mientras se repara el hardware local
Política Asociada	POL-08 — Continuidad del Negocio y Respaldo de Información
Responsable	Responsable de TI
Fecha Límite	15 de julio de 2026

RGS-10 — Tratamiento

Campo

Detalle

ID del Riesgo RGS-10

Opción de Tratamiento MITIGAR

Plan de Tratamiento Detallado Habilitar MFA en la cuenta de GoDaddy que gestiona el dominio inspeccionesl.com.mx (ACT-EXT-003). Configurar alertas automáticas de renovación del dominio con 90, 60 y 30 días de anticipación a la fecha de expiración. Habilitar el bloqueo de transferencia (registrar lock) en el dominio para prevenir transferencias no autorizadas. Revisar anualmente las credenciales de acceso al panel de GoDaddy y rotar contraseñas. Registrar en el inventario de activos la fecha de vencimiento del dominio y del certificado SSL Digicert (ACT-EXT-006)

Control Preventivo MFA habilitado en la cuenta del registrador; bloqueo de transferencia activo; alertas de renovación con 90 días de anticipación

Control Detectivo Monitoreo mensual del estado del dominio y del certificado SSL; verificación de que el DNS no ha sido modificado sin autorización mediante herramientas de monitoreo DNS

Control Correctivo Protocolo de recuperación de dominio con GoDaddy documentado en el BCP; notificación inmediata a clientes ante cualquier anomalía detectada en el dominio

Política Asociada POL-06 — Seguridad en Servicios y Proveedores Externos

Responsable Responsable de TI

Fecha Límite 15 de julio de 2026

Campo	Detalle
ID del Riesgo	RGS-11
Opción de Tratamiento	MITIGAR
Plan de Tratamiento Detallado	Establecer política de revisión trimestral de los permisos de todos los repositorios en GitHub Plan Pro (ACT-EXT-010), verificando que ninguno esté configurado como público sin autorización. Implementar escaneo automático de secretos (credenciales, tokens, contraseñas) en el código usando GitHub Secret Scanning. Prohibir formalmente el embebido de credenciales directamente en el código; usar variables de entorno o servicios de gestión de secretos. Configurar protección de rama principal (branch protection) para requerir code review antes de cualquier merge
Control Preventivo	Política de repositorios privados por defecto; prohibición formal de credenciales en código; branch protection activo en repositorios críticos
Control Detectivo	GitHub Secret Scanning habilitado con alertas automáticas ante detección de credenciales en commits; revisión trimestral de configuración de permisos de repositorios
Control Correctivo	Revocación inmediata de credenciales expuestas detectadas; rotación de todos los tokens y contraseñas referenciados en el código comprometido; análisis del historial de commits para identificar el alcance de la exposición
Política Asociada	POL-01 — Gestión de Accesos e Identidades
Responsable	Responsable de TI
Fecha Límite	1 de agosto de 2026

RGS-12 — Tratamiento

Campo	Detalle
ID del Riesgo	RGS-12
Opción de Tratamiento	MITIGAR
Plan de Tratamiento Detallado	Definir formalmente la política de retención de logs: mínimo 12 meses de logs de Active Directory y del servidor accesibles en línea, más 24 meses adicionales en archivo comprimido en los discos WD (ACT-INT-009). Configurar el tamaño máximo del log de eventos de Windows para evitar sobrescritura automática prematura. Incluir los logs de auditoría en el proceso de respaldo diario automatizado hacia AWS EC2 (ACT-EXT-001). Verificar mensualmente la integridad de los logs respaldados
Control Preventivo	Política formal de retención de logs con tamaños de buffer configurados para evitar sobrescritura; inclusión de logs en el proceso de respaldo diario
Control Detectivo	Alerta automática ante reducción inesperada del volumen de logs almacenados; verificación mensual de la integridad de los archivos de log en el respaldo
Control Correctivo	Restauración de logs desde el respaldo más reciente ante pérdida detectada; investigación de la causa de la pérdida y ajuste de la política de retención
Política Asociada	POL-08 — Continuidad del Negocio y Respaldo de Información
Responsable	Responsable de TI

Fecha Límite 1 de agosto de 2026

9.3 Tabla Resumen de la Matriz de Riesgos

ID	Nombre del Riesgo	Activos	P	I	Valor	Clasificación	Tratamiento	Política
RGS-01	Acceso no autorizado vía VPN/AD	ACT-INT-007, ACT-EXT-007	5	5	25	☐ EXTREMO	Mitigar	POL-01
RGS-04	Ataque de ransomware a infraestructura	ACT-INT-003, ACT-INT-001	4	5	20	☐ EXTREMO	Mitigar	POL-08
RGS-02	Robo/extravío de tablets en campo	ACT-INT-005, ACT-INT-006	4	4	16	☐ MUY ALTO	Mitigar	POL-05
RGS-03	Software desactualizado en servidores	ACT-INT-003, ACT-INT-001	5	3	15	☐ MUY ALTO	Mitigar	POL-03
RGS-05	Infección por phishing al personal	ACT-INT-004, ACT-EXT-005	3	4	12	☐ ALTO	Mitigar	POL-10

RGS-07	Filtración info cliente en M365	ACT-EXT-005, ACT-INT-002	3	4	12	☐ ALTO	Mitigar	POL-02, POL-09
RGS-08	Acceso físico no autorizado a servidores	ACT-INT-003, ACT-INT-009	2	5	10	☐ ALTO	Mitigar	POL-03
RGS-09	Falla crítica del Servidor Dell	ACT-INT-003, ACT-INT-001	2	5	10	☐ ALTO	Mitigar	POL-08
RGS-06	Interrupción portal clientes AWS EC2	ACT-EXT-001, ACT-EXT-006	3	3	9	☐ ALTO	Mitigar/Transferir	POL-06
RGS-10	Secuestro/expiración del dominio	ACT-EXT-003, ACT-EXT-001	2	4	8	☐ MEDIO	Mitigar	POL-06
RGS-11	Error humano en GitHub	ACT-EXT-010, ACT-INT-006	2	4	8	☐ MEDIO	Mitigar	POL-01

RGS-12	Pérdida de logs de auditoría	ACT-003, ACT-INT-007	2	2	4	☐ BAJO	Mitigar	POL-08
--------	------------------------------	----------------------	---	---	---	-------------------------------	---------	--------

9.4 Priorización de Riesgos

9.4.1 Justificación del Orden de Atención

Los riesgos identificados se priorizan considerando tres factores simultáneos: **valor numérico del riesgo**, **urgencia operativa** (impacto inmediato en la capacidad de prestar el servicio) y **costo relativo de mitigación** (controles con mayor relación costo-beneficio se implementan primero).

PRIORIDAD 1 — Atención Inmediata (Riesgos EXTREMO): RGS-01 y RGS-04

RGS-01 y RGS-04 reciben atención inmediata porque representan los escenarios de pérdida total: acceso no autorizado con credenciales comprometidas (RGS-01, valor 25) y ransomware que paraliza todas las operaciones (RGS-04, valor 20). Ambos comparten el mismo vector de entrada probable (phishing + ausencia de MFA) lo que hace que la implementación de MFA (control de RGS-01) sea simultáneamente preventiva para RGS-04. La mitigación de RGS-01 tiene el mayor retorno de inversión de toda la matriz: una sola medida (MFA) reduce drásticamente la probabilidad del riesgo más crítico del sistema.

Fecha límite: 15 de junio de 2026.

PRIORIDAD 2 — Atención Urgente (Riesgos MUY ALTO): RGS-02 y RGS-03

RGS-02 (tablets en campo, valor 16) se atiende de forma urgente porque afecta directamente la operación diaria: los inspectores salen a campo cada semana y el riesgo de extravío es constante. La implementación de MDM es de bajo costo relativo y alto impacto preventivo. RGS-03 (software desactualizado, valor 15) se atiende en la misma prioridad porque el proceso de gestión de parches, una vez establecido, funciona de forma automática y continua, resolviendo un riesgo acumulativo que crece con el tiempo si no se atiende.

Fecha límite: 1 de julio de 2026.

PRIORIDAD 3 — Atención Planificada (Riesgos ALTO): RGS-05, RGS-07, RGS-08, RGS-09, RGS-06

RGS-05 (phishing, valor 12) y RGS-07 (filtración en M365, valor 12) se atienden en esta prioridad porque sus controles (capacitación y configuración DLP) requieren planificación y coordinación con todo el personal. RGS-08 y RGS-09 (acceso físico y falla de servidor, ambos valor 10) tienen menor probabilidad gracias a controles físicos existentes (biométrico, UPS) pero requieren

formalización documental. RGS-06 (AWS, valor 9) depende parcialmente del proveedor externo por lo que se complementa con la cláusula de transferencia vía SLA.

Fecha límite: 15 de agosto de 2026.

PRIORIDAD 4 — Monitoreo Activo (Riesgos MEDIO y BAJO): RGS-10, RGS-11, RGS-12

RGS-10, RGS-11 y RGS-12 tienen probabilidad baja y sus controles son de implementación simple (MFA en GoDaddy, revisión de permisos GitHub, política de retención de logs). Se documentan, se implementan sus controles básicos dentro del ciclo actual y se revisan anualmente. No requieren recursos adicionales significativos.

Fecha límite: 1 de agosto de 2026.

9.4.2 Mapa de Calor de Riesgos ISL

P \ I	1 Insignificante	2 Menor	3 Significativo	4 Mayor	5 Severo
5 Casi Seguro			RGS-03 ☐		RGS-01 ☐
4 Probable				RGS-05 RGS-07 ☐	RGS-04 ☐ RGS-02 ☐
3 Moderado			RGS-06 ☐		
2 Poco Probable		RGS-12 ☐		RGS-10 RGS-11 ☐	RGS-08 RGS-09 ☐
1 Raro					

10. MINUTA DE REUNIÓN: PRESENTACIÓN DEL SISTEMA DE GESTIÓN DE CALIDAD

Proyecto: Diseño e Implementación del Sistema de Gestión de Calidad bajo la norma ISO 27001

Organización: Inspección Certificada SL

Fecha: 9 de mayo de 2026

Ubicación: Sede San Luis Potosí, SLP

10.1 Participantes

- Palomo Cerda Jose Armando
- Pedro Damian Jasso Dávila
- Zarate Dominguez David
- Gisela Geraldine Moreno Solis
- Zorrilla Rivera Eduardo
- Aguilar Espinoza Juan Diego
- Representantes de la Dirección de Inspección Certificada SL Brian Carcamo Baza

10.2 Objetivo de la Sesión

Presentar formalmente el plan de trabajo para la implementación del Sistema de Gestión de Seguridad de la Información (SGSI) alineado a la norma ISO/IEC 27001:2022, detallando el alcance, los activos de información involucrados y la estrategia de mitigación de riesgos durante el periodo de residencia profesional (480 horas).

10.3 Puntos Tratados

10.3.1 Diagnóstico de la Situación Actual

Se expusieron los principales retos y vulnerabilidades detectadas en la operación actual de la empresa, la cual cuenta con 23 colaboradores:

- **Gestión de Riesgos y Accesos:** Necesidad de unificar y documentar los criterios de acceso a la información confidencial de los clientes (planos, NDAs) y sistemas internos.
- **Protección y Trazabilidad:** Mejora en el control y protección de registros (Triada CID) desde la recepción de la información del cliente hasta la entrega segura del reporte final.
- **Políticas de Seguridad (SOPs):** Formalización de políticas de seguridad

operativas (contraseñas, uso de VPN, dispositivos móviles en campo) para reducir el riesgo de error humano y exposición de datos.

- **Métricas de Seguridad:** Establecimiento de KPIs para monitorear incidentes, eficacia de los controles tecnológicos y concientización del personal.

10.3.2 Alcance del Sistema y Exclusiones

El SGSI abarca la protección de la información en todas las actividades de inspección industrial y control de calidad gestionadas desde la sede de San Luis Potosí, incluyendo la recolección de datos en campo. Se formaliza la exclusión de los **controles 8.25 a 8.31 (Desarrollo seguro de software) y 5.30 (Preparación de las TIC para la continuidad del negocio)** del Anexo A de la norma, cuya justificación quedará documentada en la Declaración de Aplicabilidad (SoA).

10.3.3 Gestión de Activos y Seguridad

Se identificaron los activos de información críticos para la continuidad segura del servicio:

- **Internos:** Base de datos SQL Server, Servidor Dell PowerEdge, infraestructura de red y Dispositivos móviles (Tablets en campo).
- **Externos:** Servicios en la nube (Instancia AWS EC2), Microsoft 365 y enlaces de comunicación. En cuanto a controles técnicos iniciales, se establece la necesidad del uso obligatorio de MFA (Autenticación Multifactor) y el control de accesos vía Active Directory/VPN IPsec para mitigar riesgos críticos de filtración o robo de datos.

10.4 Acuerdos y Compromisos

- **Aprobación del Plan:** La dirección autoriza el inicio de la Etapa 1 del proyecto.
- **Diagnóstico Inicial:** Se programan las primeras 40 horas para la ejecución del Gap Analysis contra la norma ISO/IEC 27001:2022 y entrevistas con el personal.
- **Matriz RACI de Seguridad:** Se acuerda seguir la asignación de responsabilidades presentada para la gestión de las políticas de seguridad de la información.

10.5 Cierre

La reunión finaliza con la validación de los lineamientos académicos de la Universidad Politécnica de San Luis Potosí (UPSLP) para el desarrollo del proyecto técnico.

11. OPERACIÓN

11.1 Política Seleccionada y Justificación Estratégica

Para la implementación operativa de esta sección se seleccionó la **POL-10 — Concientización, Capacitación y Cumplimiento del SGSI**, definida en la Sección 8.2 del presente documento.

La justificación de esta selección es estratégica y no arbitraria. Del análisis de la Matriz de Riesgos (Sección 9) se desprende que el **factor humano es el vector de entrada más frecuente y transversal** a los riesgos de mayor criticidad identificados en ISL. El riesgo RGS-05 (Infección por phishing al personal administrativo, clasificación ALTO, valor 12) tiene como causa raíz directa la ausencia de capacitación formal en identificación de amenazas. Más importante aún, este mismo vector humano es la puerta de entrada más probable hacia los riesgos EXTREMO: RGS-01 (Acceso no autorizado vía VPN/AD, valor 25) y RGS-04 (Ataque de ransomware, valor 20), ambos clasificados como de atención inmediata.

Un colaborador que no identifica un correo de phishing es el eslabón que compromete las credenciales de Active Directory (ACT-INT-007), lo que a su vez habilita el acceso no autorizado a reportes confidenciales y puede desencadenar un ataque de ransomware sobre el Servidor Dell PowerEdge T550 (ACT-INT-003). Por tanto, fortalecer la cultura de seguridad del personal **es el control preventivo de mayor retorno de inversión en la cadena de riesgos de ISL**: una sola medida reduce simultáneamente la probabilidad de los tres riesgos más críticos del sistema.

Adicionalmente, la POL-10 es la política que habilita la eficacia de todas las demás: de nada sirve implementar MFA, MDM o cifrado si los colaboradores no comprenden por qué existen esos controles ni cómo operarlos correctamente.

11.2 Relación con Activos, Riesgos y Controles Definidos

<i>Elemento del SGSI</i>	<i>Referencia Específica</i>
Riesgo principal mitigado	RGS-05 — Infección por phishing al personal administrativo (P:3 × I:4 = 12, ALTO)

Riesgos relacionados que reduce	RGS-01 (valor 25, EXTREMO) y RGS-04 (valor 20, EXTREMO) al cerrar el vector de entrada humano
Activos protegidos	ACT-INT-004 (Laptops HP EliteBook 840 G10), ACT-INT-007 (Credenciales Active Directory), ACT-EXT-005 (Microsoft 365 Business Premium), ACT-INT-001 (Base de Datos de Clientes SQL Server)
Activo documental activado	ACT-INT-015 (Política de Seguridad PSI-2026), ACT-INT-008 (Manual de Procedimientos ISO 27001 v1.0)
Controles ISO/IEC 27002:2022 asociados	Control 6.3 (Concientización, educación y formación en seguridad de la información), Control 6.8 (Reporte de eventos de seguridad de la información)
Política del SGSI activada	POL-10 — Concientización, Capacitación y Cumplimiento del SGSI
Formularios de control vinculados	IC-SGSI-CAP-01 (Lista de asistencia), IC-SGSI-CAP-02 (Resultado de simulacro de phishing), IC-SGSI-CAP-03 (Registro de acreditaciones vigentes)
Responsable de ejecución	Responsable de TI (ejecución técnica), Gerente de Operaciones (coordinación del personal)
Vulnerabilidad que atiende	Personal sin capacitación formal en identificación de phishing; ausencia de simulacros de entrenamiento documentados

11.3 Procedimiento Operativo Paso a Paso

Nombre del procedimiento: Implementación del Programa de Concientización y Simulacro de Phishing

Versión: 1.0

Fecha de vigencia: Mayo 2026

Condición previa: La Política PSI-2026 (ACT-INT-015) debe estar aprobada y firmada por el Director General antes de iniciar este procedimiento.

FASE 1 — Diseño del Programa de Capacitación

Paso 1. El Responsable de TI, en coordinación con el Gerente de Operaciones, diseña el programa anual de capacitación en seguridad de la información. El programa debe incluir obligatoriamente los siguientes módulos:

- Módulo A: Política General del SGSI y responsabilidades individuales (PSI-2026)
- Módulo B: Identificación y reporte de intentos de phishing y spear phishing
- Módulo C: Uso seguro de laptops HP EliteBook (ACT-INT-004) y tablets Samsung (ACT-INT-005)

- Módulo D: Manejo confidencial de información del cliente y cumplimiento de NDAs
- Módulo E: Procedimiento de reporte de incidentes (formulario IC-SGSI-INC-01)

Salida del paso 1: Programa de capacitación documentado con fechas, módulos y duración estimada (mínimo 3 horas en total por sesión).

Paso 2. El Responsable de TI prepara el material de capacitación en formato de presentación (Microsoft PowerPoint vía Microsoft 365, ACT-EXT-005) y lo almacena en la carpeta centralizada del repositorio IC-SGSI-DOC del Servidor Dell (ACT-INT-003) con clasificación "Interno".

Salida del paso 2: Material de capacitación listo y almacenado en el repositorio con control de versiones (IC-SGSI-DOC-CAP-01).

FASE 2 — Convocatoria y Ejecución de la Capacitación

Paso 3. El Gerente de Operaciones envía convocatoria formal a los 23 colaboradores mediante correo electrónico corporativo (Microsoft 365, ACT-EXT-005) con un mínimo de **5 días hábiles de anticipación**. La convocatoria debe incluir: fecha, hora, lugar o enlace de Teams, módulos a tratar y carácter obligatorio de la asistencia.

Salida del paso 3: Correo de convocatoria enviado y confirmado en el sistema Microsoft 365.

Paso 4. En la fecha programada, el Responsable de TI ejecuta la sesión de capacitación. Para colaboradores en campo, la sesión se transmite en tiempo real por Microsoft Teams (ACT-EXT-005). Durante la sesión se desarrollan los 5 módulos del programa con ejemplos reales de ataques de phishing dirigidos a empresas del sector industrial manufacturero.

Salida del paso 4: Sesión ejecutada con registro de asistencia en tiempo real.

Paso 5. Al finalizar la sesión presencial o virtual, cada colaborador firma (o confirma digitalmente) la **lista de asistencia IC-SGSI-CAP-01**. El Responsable de TI verifica que el 100% del personal haya firmado antes de continuar.

Decisión: Si algún colaborador no asistió → se reprograma una sesión de recuperación dentro de los siguientes 5 días hábiles. No se puede operar activos de ISL sin haber completado la capacitación.

Salida del paso 5: Formulario IC-SGSI-CAP-01 con firmas completas archivado en el repositorio IC-SGSI-DOC.

Paso 6. Inmediatamente después de la sesión, el Responsable de TI aplica el **examen de acreditación** de 20 preguntas de opción múltiple (distribuido vía Microsoft Forms en Microsoft 365). Calificación mínima aprobatoria: **80/100**. El examen tiene un tiempo límite de 20 minutos.

Decisión: Si un colaborador no aprueba → recibe sesión de refuerzo individualizada dentro de los 3 días hábiles siguientes y repite el examen una vez más. Si vuelve a reprobar → se escala al Director General para acción disciplinaria conforme al reglamento interno.

Salida del paso 6: Resultados del examen descargados de Microsoft Forms y registrados en IC-SGSI-CAP-03.

FASE 3 — Simulacro de Phishing

Paso 7. El Responsable de TI configura una campaña de simulacro de phishing utilizando la herramienta **GoPhish** (plataforma de código abierto) instalada en un servidor de pruebas separado de la infraestructura de producción. La campaña debe simular un correo de phishing realista con las siguientes características:

- Remitente falsificado que aparente ser un proveedor conocido (ej. "soporte@microsoft.com") o un cliente de ISL
- Asunto relacionado con el contexto operativo (ej. "Reporte de inspección pendiente de validación")
- Enlace que dirija a una página de captura controlada por el Responsable de TI (sin recopilar datos reales)
- Adjunto simulado con nombre como "Reporte_Inspeccion_Final.pdf"

Salida del paso 7: Campaña de simulacro configurada y lista para lanzar, con lista de destinatarios igual al 100% de los 23 colaboradores.

Paso 8. El Responsable de TI lanza la campaña de simulacro **sin previo aviso** al personal, al menos 7 días después de la sesión de capacitación. La campaña permanece activa durante 48 horas. GoPhish registra automáticamente: quién abrió el correo, quién hizo clic en el enlace y quién reportó el correo como sospechoso al Responsable de TI.

Salida del paso 8: Panel de resultados de GoPhish con métricas en tiempo real.

Paso 9. Al concluir las 48 horas, el Responsable de TI descarga el reporte de resultados de GoPhish y documenta los hallazgos en el formulario **IC-SGSI-CAP-02 (Resultado de Simulacro de Phishing)**, registrando:

- Número total de correos enviados
- Número y porcentaje de correos abiertos
- Número y porcentaje de clics en el enlace
- Número y porcentaje de reportes correctos al Responsable de TI
- Nombres de colaboradores que hicieron clic (para seguimiento individualizado)

Meta establecida: Tasa de clics menor al **5%** (máximo 1 colaborador de 23).

Salida del paso 9: Formulario IC-SGSI-CAP-02 completado y archivado en IC-SGSI-DOC.

FASE 4 — Acciones Correctivas y Cierre

Paso 10. El Responsable de TI notifica individualmente y de forma privada a cada colaborador que hizo clic en el enlace del simulacro, informándole del resultado y agendando una **sesión de refuerzo individualizada** dentro de los 3 días hábiles siguientes.

Paso 11. El Responsable de TI actualiza el **registro IC-SGSI-CAP-03 (Inventario de Acreditaciones Vigentes)** con el estatus de cada colaborador: aprobado, pendiente de refuerzo o no acreditado. Este registro se mantiene activo y se revisa trimestralmente.

Paso 12. El Responsable de TI elabora un **informe ejecutivo de resultados** y lo presenta al Director General y al Gerente de Operaciones dentro de los 5 días hábiles posteriores al cierre del simulacro. El informe incluye: tasa de clics, comparativa con el objetivo (<5%), acciones correctivas tomadas y recomendaciones para el siguiente ciclo.

Salida del paso 12: Informe ejecutivo de resultados entregado y archivado. Ciclo de capacitación cerrado formalmente.

11.6 Responsables, Frecuencia, Criterios Mínimos y Posibles Fallos

Campo	Detalle
Responsable de diseño	Responsable de TI
Responsable de coordinación de personal	Gerente de Operaciones
Responsable de validación y reporte	Responsable de TI
Accountable final	Director General (aprueba resultados y acciones disciplinarias)
Frecuencia de capacitación formal	Una vez al año (obligatoria para los 23 colaboradores)
Frecuencia de simulacros de phishing	Una vez por trimestre (4 veces al año)
Frecuencia de revisión de IC-SGSI-CAP-03	Mensual por el Responsable de TI; trimestral ante el Director General
Criterio mínimo de éxito — capacitación	100% de colaboradores acreditados con calificación $\geq 80/100$

Criterio mínimo de éxito — simulacro	Tasa de clics menor al 5% (máximo 1 persona de 23)
Criterio mínimo de éxito — reporte	Tasa de reporte correcto de correos sospechosos mayor al 70%

Posibles fallos del procedimiento y acciones de contingencia:

Posible Fallo	Probabilidad	Acción de Contingencia
Baja asistencia a la sesión de capacitación	Media	Reprogramar sesión de recuperación dentro de los 5 días hábiles siguientes; registrar la inasistencia como no conformidad en IC-SGSI-INC-01
Colaborador no aprueba el examen (< 80/100)	Baja	Sesión de refuerzo individualizada en máximo 3 días hábiles; segunda oportunidad de examen; si reincide, escalar al Director General
Plataforma GoPhish no disponible para el simulacro	Baja	Usar alternativa: enviar correo de prueba manual desde una cuenta controlada por el Responsable de TI; documentar el cambio de herramienta en IC-SGSI-CAP-02
Personal en campo no puede conectarse a Teams	Media	Grabar la sesión y enviar el enlace de reproducción; el colaborador firma IC-SGSI-CAP-01 con nota "Capacitación asíncrona" y realiza el examen en Microsoft Forms de forma remota
Tasa de clics supera el 5% en el simulacro	Media	Lanzar sesiones de refuerzo grupales en máximo 5 días hábiles; adelantar el siguiente simulacro trimestral a 6 semanas; reportar situación al Director General con plan de acción en IC-SGSI-CAP-02
Colaborador nuevo se incorpora fuera del ciclo anual	Alta	Ejecutar inducción individual al SGSI dentro de los primeros 5 días hábiles de incorporación; aplicar examen de acreditación antes de que opere cualquier activo de ISL

11.7 Acciones para Tratar los Riesgos (Resumen Actualizado)

Riesgo (ID y Nombre)	Acciones para tratar el Riesgo	Recursos Necesarios	Responsable	Fecha Límite	Indicador de Eficacia
RGS-05 — <i>Infeción por phishing al personal administrativo</i>	Programa de capacitación anual obligatoria (5 módulos) + simulacros trimestrales de phishing con GoPhish + sesiones de refuerzo individualizadas para quien haga clic	Microsoft 365 (ACT-EXT-005), GoPhish instalado en servidor de prueba, material de capacitación IC-SGSI-DOC-CAP-01, Microsoft Forms para examen	Responsable de TI / Gerente de Operaciones	15 de agosto de 2026	Tasa de clics en simulacro < 5%; 100% colaboradores acreditados ≥ 80/100
RGS-01 — <i>Acceso no autorizado a reportes vía VPN/AD</i>	Implementación de MFA obligatorio con YubiKey 5C (ACT-INT-018) + revisión mensual de privilegios en Active Directory (ACT-INT-007) + capacitación en uso correcto de credenciales	YubiKey 5C (ACT-INT-018), Active Directory configurado (ACT-INT-007), formulario IC-SGSI-ACC-01	Responsable de TI	15 de junio de 2026	100% de cuentas con MFA activo; 0 cuentas de exempleados activas
RGS-02 — <i>Robo o extravío de tablets en campo</i>	Configuración de MDM con borrado remoto + cifrado de disco completo + sincronización diaria obligatoria antes de las 20:00 h vía VPN (ACT-EXT-007)	Consola MDM, conexión a internet, VPN IPsec (ACT-EXT-007), formulario IC-SGSI-BCP-01	Responsable de TI / Supervisores de Inspección	30 de junio de 2026	100% de tablets con MDM activo y cifrado habilitado; tiempo de borrado remoto ≤ 60 min

RGS-03 — <i>Software desactualizado en servidores con CVEs activos</i>	Ventana de mantenimiento semanal (domingos 22:00-02:00 h) + escaneo con OpenVAS/Nessus referenciando CVE MITRE (ACT-EXT-012) + clasificación por severidad y parcheo en tiempos definidos	Servidor de staging, OpenVAS o Nessus, formularios IC-SGSI-INF-03 e IC-SGSI-INF-04, Base CVE MITRE (ACT-EXT-012)	Responsable de TI	1 de julio de 2026	0 vulnerabilidades críticas pendientes > 24 h; 100% de parches documentados en IC-SGSI-INF-04
--	---	--	-------------------	--------------------	---

12. EVALUACIÓN DEL DESEMPEÑO — AUDITORÍA INTERNA DEL SGSI

12.1 Programa de Auditoría Interna

12.1.1 Declaración del Programa

De conformidad con la Cláusula 9.2 de la norma **ISO/IEC 27001:2022**, Inspección Certificada SL establece el presente programa de auditoría interna con el objetivo de determinar si el Sistema de Gestión de Seguridad de la Información cumple con los requisitos de la norma, con las políticas y controles definidos internamente, y si se encuentra implementado y mantenido de manera eficaz.

12.1.2 Ficha General del Programa de Auditoría

Campo	Detalle
Tipo de auditoría	Auditoría interna de primera parte
Norma de referencia	ISO/IEC 27001:2022 — Cláusulas 4 a 10 y Anexo A
Alcance	Totalidad del SGSI implementado en la sede central de ISL, San Luis Potosí, SLP, incluyendo operaciones en campo
Periodo auditado	Mayo — Agosto 2026 (fase de implementación base)
Fecha de ejecución	Agosto 2026 (Etapa 6 del cronograma, Sección 4)
Auditor líder	Residente Profesional (independiente del área auditada)
Criterios de auditoría	ISO/IEC 27001:2022, Políticas POL-01 a POL-10, Controles del Anexo A aplicables según SoA (Sección 3.4)
Método	Revisión documental, entrevistas al personal, observación directa de controles técnicos y verificación de evidencias
Confidencialidad	Los hallazgos se reportan exclusivamente al Director General y al Responsable de TI conforme a la Cláusula 6.2.2

12.2 Formatos de Auditoría Interna

12.2.1 Formato A — Checklist de Verificación de Controles (IC-SGSI-

Este checklist se aplica a cada política y control del SGSI. La escala de evaluación es:

- **C** = Cumple (evidencia completa y verificada)
- **CP** = Cumplimiento Parcial (evidencia incompleta o control implementado pero no documentado)
- **NC** = No Cumple (sin evidencia o control ausente)
- **NA** = No Aplica (excluido en SoA)

ID	Control / Requisito Auditado	Política Asociada	Evidencia Solicitada	Resultado	Observaciones del Auditor
CHK-01	¿Existe una Política de Seguridad de la Información aprobada y firmada por la Dirección?	POL-10 / Cláusula 5.2	Documento PSI-2026 con firma del Director General	C	PSI-2026 (ACT-INT-015) localizada en repositorio IC-SGSI-DOC. Firmada por Director General en mayo 2026.
CHK-02	¿Está definido y documentado el alcance del SGSI?	Cláusula 4.3	Documento de alcance (Sección 3 del SGSI)	C	Alcance documentado en Sección 3. Incluye sede central y operaciones en campo. Exclusiones justificadas.
CHK-03	¿Existe un inventario completo de activos de información?	POL-04 / Control 5.9	Inventario ACT-INT-019 con todos los activos registrados	CP	Inventario documentado en Sección 7 (40 activos). Sin embargo, el inventario físico semestral aún no ha sido ejecutado formalmente con evidencia registrada.

CHK-04	¿Está implementado el MFA obligatorio para accesos administrativos?	POL-01 / Control 8.5	Configuración de Active Directory + evidencia de YubiKey 5C activas	NC	Al momento de la auditoría, el MFA mediante YubiKey 5C (ACT-INT-018) no ha sido habilitado en el 100% de las cuentas administrativas. Solo el Responsable de TI tiene MFA activo. Fecha límite de mitigación: 15 de junio 2026 (RGS-01).
CHK-05	¿Existe procedimiento formal de gestión de parches con ventana de mantenimiento definida?	POL-03 / Control 8.8	Formulario IC-SGSI-INF-04 con registros de parches aplicados	NC	No existe evidencia de aplicación formal de parches en el periodo auditado. La ventana de mantenimiento semanal (domingos 22:00-02:00 h) está documentada en POL-03 pero no hay registros de ejecución (IC-SGSI-INF-04 sin datos).

CHK-06	¿Están configuradas las tablets de inspectores con MDM y cifrado de disco activo?	POL-05 / Control 8.1	Consola MDM mostrando estado de los dispositivos	CP	De las tablets Samsung Galaxy Tab Active4 Pro (ACT-INT-005), se verificó que 4 de 6 dispositivos tienen MDM instalado. 2 dispositivos en campo no tienen el agente MDM activo. El cifrado de disco está habilitado en el 100% de los dispositivos verificados.
CHK-07	¿Existe un programa de capacitación en seguridad ejecutado con evidencia?	POL-10 / Control 6.3	Formulario IC-SGSI-CAP-01 con firmas + resultados de examen	CP	Se realizó la sesión de capacitación en mayo 2026. El formulario IC-SGSI-CAP-01 está firmado por 21 de 23 colaboradores. Dos inspectores en campo no completaron la capacitación por ausencia en el periodo. No se ha ejecutado el primer simulacro de phishing trimestral.

CHK-08	¿Están configurados los respaldos automáticos diarios bajo la Regla 3-2-1?	POL-08 / Control 8.13	Log de backup automatizado + evidencia de copia offline en Caja Fuerte	CP	Los respaldos automáticos diarios hacia AWS EC2 están configurados y ejecutándose. Sin embargo, la copia offline semanal en discos WD (ACT-INT-009) solo tiene 2 registros en IC-SGSI-BCP-01 en los últimos 30 días (debería tener 4). No se ha ejecutado la prueba mensual de restauración IC-SGSI-BCP-02.
CHK-09	¿Están definidas y documentadas las responsabilidades de seguridad de cada rol?	Matriz RACI / Cláusula 5.3	Matriz RACI documentada y comunicada al personal	C	Matriz RACI documentada en Sección 8.3 con roles y responsabilidades para las 10 políticas. Comunicada al personal en la sesión de capacitación de mayo 2026.

CHK-10	¿Existe un procedimiento formal de gestión de incidentes?	POL-07 / Control 5.24	Procedimiento documentado + formularios IC-SGSI-INC-01 e INC-02	CP	El procedimiento está documentado en POL-07. Los formularios IC-SGSI-INC-01 e INC-02 existen como plantillas pero no hay registros de incidentes gestionados formalmente en el periodo auditado. El canal de emergencias WhatsApp Business no ha sido configurado.
CHK-11	¿Existe clasificación de la información con etiquetas de sensibilidad en Microsoft 365?	POL-02 / Control 5.12	Captura de etiquetas de sensibilidad configuradas en Microsoft 365	NC	Las etiquetas de clasificación (Confidencial, Interno, Público) no han sido configuradas en Microsoft 365 (ACT-EXT-005). Los documentos en OneDrive no tienen etiquetas de sensibilidad visibles. Las políticas DLP tampoco han sido configuradas.

CHK-12	¿Tiene el dominio inspeccionesl.com.mx MFA habilitado en GoDaddy y alertas de renovación?	POL-06 / Control 5.19	Captura del panel GoDaddy con MFA activo y alertas configuradas	NC	Se verificó que la cuenta de GoDaddy que gestiona el dominio (ACT-EXT-003) no tiene MFA habilitado. No se encontraron alertas de renovación configuradas con 90 días de anticipación.
CHK-13	¿Existe evaluación formal de proveedores críticos (IC-SGSI-PROV-01)?	POL-06 / Control 5.19	Formularios IC-SGSI-PROV-01 completados para AWS, Microsoft 365, Telmex	NC	No existe ningún formulario IC-SGSI-PROV-01 completado para ninguno de los proveedores críticos identificados en la Sección 7.3.
CHK-14	¿Está habilitado el acceso biométrico al cuarto de servidores con lista de acceso restringida?	POL-03 / Control 7.3	Configuración del lector ZKTeco + lista de personas autorizadas	C	El lector biométrico ZKTeco SpeedFace (ACT-INT-013) está operativo. Acceso restringido a 2 personas: Responsable de TI y Director General. Verificado físicamente durante la auditoría.

CHK-15	¿Existe una Declaración de Aplicabilidad (SoA) documentada y justificada?	Cláusula 6.1.3	Documento SoA con controles incluidos y excluidos del Anexo A	C	SoA documentada en Sección 3.4. Incluye justificación de exclusión de controles 8.25-8.31 y control 5.30. Alineada con el contexto de ISL.
--------	---	----------------	---	---	--

12.2.2 Formato B — Guía de Entrevista al Personal (IC-SGSI-AUD-02)

Las siguientes preguntas se aplican durante las entrevistas individuales realizadas al personal clave durante la auditoría. Se documentan las respuestas textuales para contrastarlas con la evidencia documental.

Entrevista dirigida al Responsable de TI

ID	Pregunta	Respuesta Obtenida	Verificación
ENT-TI-01	¿Puede describir el proceso que sigue cuando se detecta una vulnerabilidad crítica en el servidor?	<i>"Cuando el escáner detecta algo grave, lo clasifico según el CVE y lo parcheo en la ventana del domingo. Si es muy crítico lo hago antes."</i>	Inconsistencia detectada: El proceso descrito verbalmente existe en POL-03, pero no hay registros IC-SGSI-INF-04 que demuestren su ejecución. El proceso existe en papel pero no hay evidencia de aplicación.
ENT-TI-02	¿Con qué frecuencia se realizan las copias de respaldo offline y dónde se resguardan?	<i>"Cada semana se hace la copia en los discos WD y se guardan en la caja fuerte de la dirección."</i>	Inconsistencia detectada: Solo se encontraron 2 registros en IC-SGSI-BCP-01 en los últimos 30 días. La respuesta verbal indica cumplimiento pero la evidencia documental muestra cumplimiento parcial.
ENT-TI-03	¿Todos los inspectores tienen el agente MDM instalado en sus tablets?	<i>"La mayoría sí, creo que hay un par que tuvieron problemas con la instalación pero ya se están revisando."</i>	Confirmación de hallazgo CHK-06: La respuesta confirma que 2 de 6 tablets no tienen MDM activo, consistente con lo verificado en la consola MDM.

ENT-TI-04	¿Está habilitado el MFA en todas las cuentas administrativas del Active Directory?	<i>"En mi cuenta sí está con la YubiKey. Para los demás administradores está en proceso de configuración, no se ha terminado."</i>	Confirmación de hallazgo CHK-04: El MFA no está habilitado en el 100% de las cuentas administrativas. Este es el riesgo RGS-01 clasificado como EXTREMO.
-----------	--	--	---

Entrevista dirigida al Gerente de Operaciones

ID	Pregunta	Respuesta Obtenida	Verificación
ENT-OP-01	¿Qué hace un inspector si pierde o le roban la tablet durante una visita a campo?	<i>"Nos llama de inmediato para avisarnos y nosotros le decimos al de TI para que borre el dispositivo."</i>	Cumplimiento parcial: El proceso verbal es correcto. Sin embargo, no existe evidencia de que el protocolo esté documentado en un lugar accesible para los inspectores fuera de la sede (POL-05 no está disponible offline en las tablets).
ENT-OP-02	¿Cómo se asegura que la información técnica del cliente se elimina al terminar un contrato?	<i>"Le avisamos a TI para que borre las carpetas del servidor y archivamos el NDA en la caja fuerte."</i>	Cumplimiento parcial: El proceso existe informalmente pero no hay formularios IC-SGSI-CLI-01 completados que demuestren los cierres de contrato con evidencia de disposición final de información.

Entrevista dirigida a Inspector de Campo (muestra de 2 inspectores)

ID	Pregunta	Respuesta Obtenida	Verificación
ENT-INS-01	¿Qué haces si recibes un correo sospechoso en tu cuenta corporativa?	<i>Inspector 1: "Lo borro y ya." / Inspector 2: "Le aviso al de sistemas por WhatsApp."</i>	Hallazgo: Solo 1 de 2 inspectores entrevistados conoce el procedimiento correcto de reporte. El Inspector 1 no reporta el correo, lo que impide la detección y respuesta ante phishing. Refuerzo de capacitación requerido.

ENT- ¿Sabes qué es el Inspector 1: "Sí, es
INS- MDM en tu tablet y para que puedan
02 para qué sirve? borrar el celular si lo pierdo." / Inspector 2:
"No, no sé qué es eso."

Hallazgo: Brecha de conocimiento en el 50% de la muestra entrevistada. La capacitación de POL-10 no cubrió efectivamente a todo el cuerpo de inspectores.

12.2.3 Formato C — Lista de Revisión Documental (IC-SGSI-AUD-03)

Documento Solicitado	Código	¿Existe?	¿Está Actualizado?	¿Tiene Aprobación?	Estado
Política de Seguridad PSI-2026	ACT-INT-015	Sí	Sí (mayo 2026)	Sí (Director General)	Completo
Inventario de Activos	ACT-INT-019	Sí	Sí (40 activos)	Sí	Completo
Declaración de Aplicabilidad SoA	Sección 3.4	Sí	Sí	Sí	Completo
Matriz de Riesgos	Sección 9	Sí	Sí (12 riesgos)	Sí	Completo
Manual de Procedimientos ISO 27001	ACT-INT-008	Sí	Sí (v1.0)	Sí	Completo
Plan de Continuidad BCP v2.1	ACT-INT-020	Sí	Pendiente de actualización	Sí	Parcial
Formulario de Alta/Baja de Accesos IC-SGSI-ACC-01	IC-SGSI-ACC-01	Sí (plantilla)	Sin registros completados	N/A	Parcial
Registros de aplicación de parches IC-SGSI-INF-04	IC-SGSI-INF-04	Sí (plantilla)	Sin registros completados	N/A	No Cumple
Lista de asistencia capacitación IC-SGSI-CAP-01	IC-SGSI-CAP-01	Sí	Mayo 2026 (21/23 firmas)	Sí	Parcial

Resultados de simulacro de phishing IC-SGSI-CAP-02	IC-SGSI-CAP-02	Sí (plantilla)	Sin registros (no ejecutado)	N/A	No Cumple
Registro de acreditaciones IC-SGSI-CAP-03	IC-SGSI-CAP-03	Sí	21 colaboradores registrados	N/A	Parcial
Evaluación de proveedores IC-SGSI-PROV-01	IC-SGSI-PROV-01	No	No existe	N/A	No Cumple
Registro semanal de respaldo offline IC-SGSI-BCP-01	IC-SGSI-BCP-01	Sí	Solo 2 registros de 4 esperados	Sí	Parcial
Prueba mensual de restauración IC-SGSI-BCP-02	IC-SGSI-BCP-02	Sí (plantilla)	Sin registros (no ejecutada)	N/A	No Cumple
Registro de incidentes IC-SGSI-INC-01	IC-SGSI-INC-01	Sí (plantilla)	Sin registros de incidentes	N/A	Parcial

12.3 Simulación de la Auditoría — Resultados por Área

12.3.1 Resumen de Resultados del Checklist CHK

Resultado	Cantidad	Porcentaje	Controles
Cumple (C)	4	26.7%	CHK-01, CHK-02, CHK-09, CHK-14, CHK-15
Cumplimiento Parcial (CP)	6	40%	CHK-03, CHK-06, CHK-07, CHK-08, CHK-10, CHK-13
No Cumple (NC)	5	33.3%	CHK-04, CHK-05, CHK-11, CHK-12, CHK-13

<i>No Aplica (NA)</i>	0	0%	—
TOTAL	15	100%	

12.4 Hallazgos, No Conformidades, Observaciones y Oportunidades de Mejora

12.4.1 No Conformidades Identificadas

Las no conformidades representan incumplimientos directos a requisitos obligatorios de ISO/IEC 27001:2022 o de las políticas internas del SGSI de ISL.

NC-01 — Autenticación Multifactor no implementada en el 100% de cuentas administrativas

Campo	Detalle
ID	NC-01
Tipo	No Conformidad Mayor
Requisito incumplido	POL-01 (Gestión de Accesos e Identidades) — Estándar obligatorio: "La autenticación multifactor (MFA) mediante YubiKey 5C es obligatoria para todo acceso administrativo a sistemas críticos." / ISO/IEC 27002:2022 Control 8.5
Riesgo vinculado	RGS-01 — Acceso no autorizado a reportes confidenciales vía VPN/AD (Valor 25, EXTREMO)
Activos afectados	ACT-INT-007 (Active Directory), ACT-EXT-007 (VPN IPsec), ACT-INT-001 (BD Clientes)
Evidencia observada	Verificación en consola de Active Directory: de 3 cuentas con privilegios administrativos, solo 1 (Responsable de TI) tiene MFA activo con YubiKey 5C. Las otras 2 cuentas administrativas acceden únicamente con usuario y contraseña. Confirmado adicionalmente en entrevista ENT-TI-04.
Impacto potencial	Sin MFA en el 100% de las cuentas administrativas, el riesgo RGS-01 permanece en nivel EXTREMO (valor 25). Un ataque de phishing exitoso que comprometa las credenciales de una cuenta administrativa sin MFA otorgaría acceso total a todos los sistemas de ISL sin ninguna barrera adicional.

NC-02 — Proceso de gestión de parches sin evidencia de ejecución

Campo	Detalle
ID	NC-02
Tipo	No Conformidad Mayor
Requisito incumplido	POL-03 (Seguridad de la Infraestructura Tecnológica) — Estándar obligatorio: "Los parches de seguridad críticos deben aplicarse en un plazo máximo de 72 horas tras su publicación oficial." / ISO/IEC 27002:2022 Control 8.8
Riesgo vinculado	RGS-03 — Software desactualizado en servidores con CVEs activos (Valor 15, MUY ALTO)
Activos afectados	ACT-INT-003 (Servidor Dell PowerEdge T550), ACT-INT-001 (BD Clientes SQL Server 2022)
Evidencia observada	No existe ningún registro completado en el formulario IC-SGSI-INF-04 (Registro de Aplicación de Parches). La ventana de mantenimiento semanal está documentada en POL-03 pero el Responsable de TI confirmó verbalmente (ENT-TI-01) que las aplicaciones de parches se realizan sin documentación formal. El escaneo de vulnerabilidades con OpenVAS/Nessus tampoco tiene reportes IC-SGSI-INF-03 generados.
Impacto potencial	Sin documentación de parches aplicados, es imposible demostrar ante una auditoría externa que el servidor está protegido contra CVEs conocidos. El riesgo RGS-03 permanece activo y acumulativo.

NC-03 — Clasificación de información y políticas DLP no configuradas en Microsoft 365

Campo	Detalle
ID	NC-03
Tipo	No Conformidad Mayor

Requisito incumplido	POL-02 (Clasificación y Protección de la Información) — Estándar obligatorio: "Toda la información generada, recibida o procesada por ISL debe clasificarse según su nivel de sensibilidad antes de ser almacenada, transmitida o compartida." / ISO/IEC 27002:2022 Control 5.12
Riesgo vinculado	RGS-07 — Filtración de información confidencial del cliente en Microsoft 365 (Valor 12, ALTO)
Activos afectados	ACT-EXT-005 (Microsoft 365 Business Premium), ACT-INT-002 (Certificados de Calidad Digitales), ACT-INT-001 (BD Clientes)
Evidencia observada	Verificación directa en el panel de administración de Microsoft 365: las etiquetas de sensibilidad (Confidencial, Interno, Público) no han sido creadas ni configuradas. Las políticas DLP (Data Loss Prevention) no existen en el tenant de ISL. Los documentos revisados en OneDrive corporativo no tienen ninguna etiqueta de clasificación visible.
Impacto potencial	Sin etiquetas DLP, cualquier colaborador puede enviar un documento clasificado como Confidencial a un destinatario externo sin ningún control automático que lo bloquee o lo alerte. El riesgo de incumplimiento de NDAs con clientes Tier 1 y Tier 2 es inmediato.

NC-04 — Evaluaciones de proveedores críticos no realizadas

Campo	Detalle
ID	NC-04
Tipo	No Conformidad Menor
Requisito incumplido	POL-06 (Seguridad en Servicios y Proveedores Externos) — Estándar obligatorio: "Todos los servicios tecnológicos externos que procesen, almacenen o transmitan información de ISL deben ser evaluados formalmente antes de su contratación y de forma anual durante su vigencia." / ISO/IEC 27002:2022 Control 5.19
Riesgo vinculado	RGS-06 — Interrupción del portal de clientes por falla en AWS EC2 (Valor 9, ALTO)

Activos afectados	ACT-EXT-001 (AWS EC2), ACT-EXT-004 (Telmex), ACT-EXT-005 (Microsoft 365), ACT-EXT-013 (Stripe)
Evidencia observada	No existe ningún formulario IC-SGSI-PROV-01 completado para ninguno de los proveedores críticos listados en la Sección 7.3. Los servicios de AWS, Microsoft 365 y Telmex se utilizan sin evaluación formal de riesgo documentada ni revisión de SLAs.
Impacto potencial	ISL no puede demostrar que sus proveedores cumplen con los requisitos de seguridad exigidos por la norma ni por los clientes Tier 1 que auditan la cadena de suministro.

12.4.2 Observaciones Identificadas

Las observaciones representan situaciones que no constituyen incumplimiento formal pero que, de no atenderse, pueden derivar en no conformidades futuras.

OBS-01 — Dos tablets de inspectores sin agente MDM activo

Campo	Detalle
ID	OBS-01
Tipo	Observación
Referencia	POL-05 / CHK-06 / RGS-02
Situación detectada	De 6 tablets Samsung Galaxy Tab Active4 Pro (ACT-INT-005), 2 unidades no tienen el agente MDM instalado y activo al momento de la auditoría. El Responsable de TI confirmó que están "en proceso de configuración". El cifrado de disco está habilitado en los dispositivos verificados.
Riesgo asociado	Si alguna de las 2 tablets sin MDM es robada o extraviada en campo, no es posible ejecutar el borrado remoto, quedando la información del cliente expuesta sin control de mitigación.

Diferencia con NC No se clasifica como NC Mayor porque la situación es transitoria y el Responsable de TI tiene conocimiento del pendiente, pero debe resolverse antes de la fecha límite de RGS-02 (30 de junio 2026).

OBS-02 — Capacitación de seguridad incompleta para 2 inspectores en campo

Campo	Detalle
ID	OBS-02
Tipo	Observación
Referencia	POL-10 / CHK-07 / RGS-05
Situación detectada	El formulario IC-SGSI-CAP-01 de la sesión de capacitación de mayo 2026 tiene 21 de 23 firmas. Dos inspectores en campo no asistieron a la sesión por encontrarse en plantas industriales de clientes durante esa fecha. No se ha reprogramado la sesión de recuperación.
Riesgo asociado	Estos 2 colaboradores operan activos críticos (tablets con información confidencial de clientes) sin haber recibido capacitación formal en identificación de phishing ni en el procedimiento de reporte de incidentes.
Diferencia con NC	No se clasifica como NC Mayor porque la sesión de recuperación está contemplada en POL-10 y el plazo de 5 días hábiles para reprogramación aún puede cumplirse. Sin embargo, si no se ejecuta antes de la próxima salida a campo de estos inspectores, escalará a no conformidad.

OBS-03 — Respaldos offline ejecutados con frecuencia irregular

Campo	Detalle
ID	OBS-03
Tipo	Observación

Referencia POL-08 / CHK-08 / RGS-04

Situación detectada El formulario IC-SGSI-BCP-01 (Registro Semanal de Respaldo Offline) muestra solo 2 registros en los últimos 30 días cuando deberían existir 4 (uno por semana). Los respaldos automáticos diarios hacia AWS EC2 funcionan correctamente, pero la copia offline en discos WD tiene una brecha de ejecución del 50% en el periodo auditado.

Riesgo asociado Si ocurriera un ataque de ransomware que cifrara simultáneamente el servidor local y la instancia AWS (posible si ambos están sincronizados), la última copia offline verificada podría tener hasta 14 días de antigüedad, implicando pérdida de 2 semanas de operación.

13.4.3 Oportunidades de Mejora Identificadas

ID	Descripción	Beneficio Esperado
OM-01	Implementar un SIEM básico (ej. Wazuh, versión gratuita) para centralizar logs del Servidor Dell, Active Directory y laptops HP EliteBook en un solo panel de visualización	Reducción del tiempo de detección de incidentes; mejora directa sobre RGS-01, RGS-03 y RGS-04; facilita la evidencia para auditorías futuras
OM-02	Configurar Microsoft Secure Score en el tenant de Microsoft 365 para obtener una línea base automática del nivel de seguridad de la plataforma y priorizar las configuraciones de DLP y etiquetas de sensibilidad	Visibilidad inmediata del estado de seguridad de Microsoft 365 (ACT-EXT-005); facilita la resolución de NC-03 con guía paso a paso del propio proveedor
OM-03	Crear una versión simplificada (tarjeta de bolsillo plastificada) de los procedimientos críticos de campo: qué hacer si pierdes la tablet, cómo reportar un correo sospechoso, cómo activar la VPN. Distribuir la a todos los inspectores	Refuerza POL-05 y POL-10 en el entorno de campo donde el acceso al Manual de Procedimientos digital puede no estar disponible; reduce el tiempo de respuesta ante incidentes en campo

14. MEJORA — GESTIÓN DE INCIDENTES Y MEJORA CONTINUA DEL SGSI

El objetivo de esta sección es establecer el marco operativo para reaccionar ante eventos de seguridad, mitigar impactos y asegurar la evolución constante del

Sistema de Gestión de Seguridad de la Información (SGSI) conforme a los requisitos de los capítulos 10.1 y 10.2 de la norma ISO/IEC 27001:2022.

14.1. Planificación y Preparación para la Gestión de Incidentes (Control Anexo A.5.24)

Para responder de manera ágil y coordinada, se define un proceso formal de gestión de incidentes que abarca desde la detección en la infraestructura local o en la nube, hasta la remediación en los dispositivos utilizados en campo por los colaboradores durante las inspecciones operativas.

14.2. Detección y Reporte de Eventos de Seguridad

La identificación temprana de anomalías se apoya en dos pilares técnicos principales:

- **Monitoreo Activo (FIM - File Integrity Monitoring):** Implementación de herramientas de detección y análisis de seguridad como *Wazuh* para monitorear componentes críticos del sistema operativo y alertar sobre modificaciones no autorizadas en archivos del sistema o configuraciones de red.
- **Mecanismos de Engaño (Honeytokens):** Colocación de recursos señuelo (por ejemplo, archivos de credenciales falsos o rutas inactivas). Cualquier intento de interacción con estos elementos generará una alerta inmediata en el sistema, notificando la presencia de un posible intruso en la red.

14.3. Evaluación y Decisión sobre Eventos de Seguridad (Control Anexo A.5.25)

No toda anomalía constituye un incidente de seguridad. Los eventos detectados serán clasificados por el equipo técnico bajo tres niveles de criticidad (Bajo, Medio, Alto) evaluando el impacto potencial sobre la confidencialidad, integridad o disponibilidad de los datos técnicos y reportes de inspección de los clientes.

14.4. Respuesta, Contención y Recopilación de Evidencia (Controles Anexo A.5.26 y A.5.28)

Una vez confirmado un incidente crítico, se ejecutarán los protocolos de contención predefinidos (como el aislamiento de instancias en la nube o la revocación temporal de accesos en la VPN). Durante esta fase, se priorizará la preservación y recolección de evidencia digital de manera segura,

garantizando la cadena de custodia para posteriores análisis forenses o auditorías.

14.5. Lecciones Aprendidas e Informe Post-Mortem (Control Anexo A.5.27)

Una vez contenida y superada la crisis, se cerrará el ciclo mediante la elaboración de un informe *Post-Mortem*. Este análisis detallará:

- La causa raíz del incidente.
- El impacto real medido en tiempo de inactividad, costos operativos o exposición de datos.
- Las debilidades del control actual que permitieron el evento.
- Las recomendaciones de mejora para evitar la recurrencia del escenario.

14.6. Tratamiento de No Conformidades y Acciones Correctivas (Cláusula 10.1)

Ante cualquier desviación de los objetivos del SGSI, fallas en las auditorías internas o incidentes de seguridad recurrentes, se abrirá un registro de No Conformidad. Se determinarán las acciones correctivas necesarias para eliminar las causas de raíz, evaluando su eficacia en revisiones posteriores con la Dirección General.

14.7 Mantenimiento y Mejora Continua del SGSI (Cláusula 10.2)

Para garantizar que el diseño base implementado mantenga su efectividad frente a nuevas amenazas, se establecen los siguientes mecanismos de mejora continua:

- **Política de Ciclo de Vida Tecnológico:** Restricción operativa que impide la ejecución de software, librerías o sistemas operativos que se encuentren a menos de dos versiones de desfase respecto a la versión estable actual.
- **Calendario de Parcheo Automatizado:** Programación y automatización del despliegue de actualizaciones críticas de seguridad en servidores de bases de datos, sistemas centrales y herramientas en la nube.
- **Revisiones de Concientización:** Evaluaciones periódicas del nivel de cultura de seguridad de los colaboradores para ajustar las campañas de capacitación según las brechas detectadas en la operación diaria.

15. BIBLIOGRAFÍA

15.1 Documentación Interna

- **Inspección Certificada SL.**

Documentación corporativa interna:

- Anteproyecto de residencia profesional
- Manuales operativos
- Organigrama institucional
- Procesos de operación y control de calidad

San Luis Potosí, México, 2026.

15.2 Lineamientos Académicos

- **Universidad Politécnica de San Luis Potosí (UPSLP).**

Lineamientos para la elaboración de proyectos de residencia profesional.

San Luis Potosí, México.

15.3 Nota Ejecutiva

Las fuentes utilizadas garantizan que el diseño e implementación del Sistema de Gestión de Calidad se encuentra alineado con estándares reconocidos internacionalmente, así como con requisitos regulatorios y prácticas organizacionales reales, fortaleciendo la confiabilidad, trazabilidad y aplicabilidad del proyecto en un entorno empresarial.

Implementación **SGSI** ISO/IEC 27001:2022

Inspección Certificada SL: Protegiendo la integridad y confidencialidad en la
inspección industrial.

Presentan:

Jose Armando Palomo Cerda
Pedro Damian Jasso Dávila
David Zarate Dominguez
Gisela Geraldine Moreno Solis
Eduardo Zorrilla Rivera
Juan Diego Aguilar Espinoza

Inspección Certificada SL (ISL)

Misión Estratégica

Garantizar que los procesos de nuestros clientes fluyan sin interrupciones por defectos de calidad, aportando valor mediante la excelencia técnica.

Capacidad Operativa

Plantilla activa de 23 colaboradores especializados en inspección y control de calidad para la industria automotriz y manufacturera.



| Departamento de Operaciones

El núcleo operativo donde se gestiona la propiedad intelectual de los clientes (planos CAD, NDAs) y se genera evidencia técnica con valor contractual.

- 🛡️ Captura de datos sensibles en campo.
- 📄 Emisión de certificados PDF con firma RSA.
- 📡 Transmisión segura desde plantas externas.



| Retos y Vulnerabilidades



Trazabilidad

El flujo de información carece de un sistema de control de registros que asegure la integridad histórica.



Dependencia

El conocimiento crítico reside en individuos y no en una estructura institucional documentada.



Ciberseguridad

Uso de dispositivos móviles en entornos externos sin controles formales de seguridad previos.

| Valor Estratégico

2027

Año Meta para Certificación

Competitividad en Tier 1 & 2

En el sector automotriz, la confidencialidad es un requisito contractual. Este SGSI garantiza a los clientes que sus diseños están protegidos frente a amenazas digitales.

Minimizar vulnerabilidades reduce el riesgo de ataques de **Ransomware** y asegura la continuidad del negocio.

| Objetivos de Implementación

-  **Gap Analysis:** Diagnóstico inicial frente a los 93 controles de la norma.
 -  **SoA:** Elaboración de la Declaración de Aplicabilidad y Políticas.
 -  **KPIs:** Diseño de tableros para monitorear incidentes y eficacia de controles.
 -  **Sensibilización:** Capacitar a los 23 colaboradores en cultura de seguridad.
-

| Alcance del **SGSI**

Aplica a todas las actividades administrativas y operativas gestionadas desde la sede central en San Luis Potosí y su extensión en campo.

- ✓ Reducción de superficie de ataque en red interna.
- ✓ Seguridad en dispositivos móviles (MDM).
- ✓ Control de acceso físico y lógico (VPN/AD).



| Activos de Información



Internos

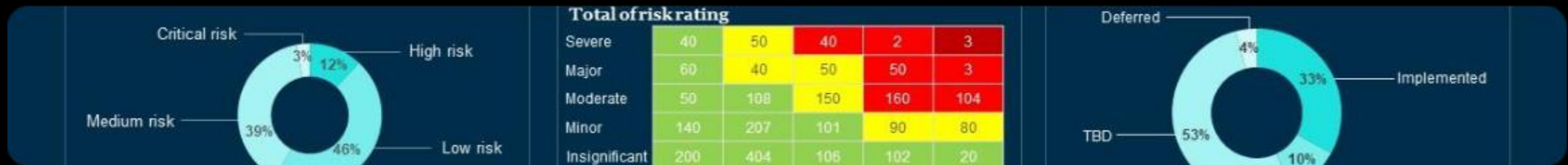
- Servidor Dell PowerEdge T550
- Switch Cisco Catalyst 9200
- Tablets Samsung Galaxy Tab
- Base de Datos SQL Server



Externos

- Instancia AWS EC2 (Portal Clientes)
- Microsoft 365 Business Premium
- Red VPN IPsec Acceso Remoto
- Repositorio GitHub Plan Pro

Valoración de Riesgos



| Hito: Minuta 9 Mayo 2026

"La Dirección General autoriza el despliegue técnico del SGSI, priorizando el uso de MFA y el control de accesos remotos para proteger la propiedad

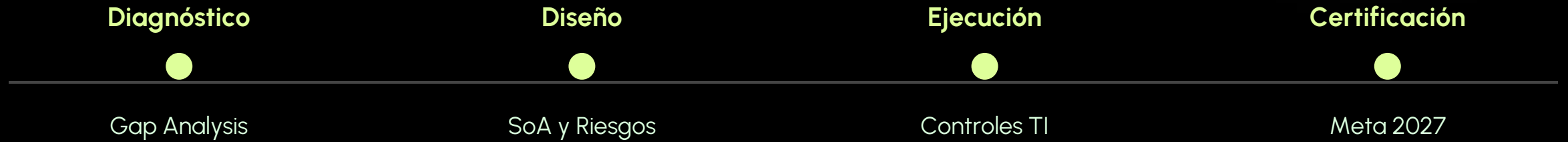
intelectual del cliente."
— Brian Carcamo Baza (Director General, ISL)

Validación de Alcance

Aprobación de SoA

Compromiso de Recursos

| Ruta de Implementación





¿Preguntas?

inspeccionesl.com | San Luis Potosí, México
